

Daily Vulnerability Report - 2026-09-26

Window (UTC): 2026-09-25T05:32 to 2026-09-26T05:32 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-26 05:34:05 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
818	782	33	3	3	23	214	199	352	381

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100382	New	10.0	CRIT				Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in Wikimedia Foundation Mediawiki - ExternalData Extension allows OS Command Injection. This issue affects Mediawiki - ExternalData Extension: from * before 3.7.
CVE-2026-100075	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: RDMA/srpt: Fix srpt_alloc_rw_ctxs() unwind counters When srpt_alloc_rw_ctxs() fails partway through a multi-buffer indirect descriptor, the unwind path destroys RDMA contexts but leaves stale n_rw_ctx and n_rdma values (and a dangling rw_ctxs pointer). Later sq_wr_avail accounting in srpt_queue_response() ...
CVE-2026-14281	New	9.8	CRIT		0.005		The Automation Web Platform – Notifications and OTP for WooCommerce, Advanced Country Code plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 4.8.6. This is due to missing permission enforcement on the publicly accessible REST route `POST /wp-json/wamp/v1/signup/<op>` and the absence of a key allowlist in the `finish_registration...
CVE-2026-92161	New	9.8	CRIT			composer:fof/oauth	FriendsOfFlarum OAuth allows users to log in to Flarum with GitHub, Twitter, Facebook, and other providers. Prior to 1.7.4 and 2.0.0-beta.4, the Discord OAuth provider does not check the verified field returned for an OAuth email before passing the address to Flarum core as trusted through provideTrustedEmail(). When Discord sign-in is enabled, an unauthenticated attacker wh...
CVE-2026-92609	New	9.8	CRIT		0.002		Session fixation in HTTP management authentication allows remote attackers to gain unauthorized access to an authenticated management session via reuse of a session identifier retained across successful authentication. This issue affects Apache Qpid Broker-J: through 10.1.0. Users are recommended to upgrade to version 10.1.1, which fixes the issue.
CVE-2026-93643	New	9.8	CRIT				When OnlyOffice/Document Editing is available, an unauthenticated remote attacker with access to an existing supported public Briefcase document can abuse unsigned save fields to perform path-traversal writes and execute commands as zimbra.
CVE-2026-48482	New	9.4	CRIT				GLPI is a free asset and IT management software package. From 11.0.0 until 11.0.8, a form administrator can use Form import with a crafted illustration or scene identifier that traverses outside the intended custom-asset directory. The imported file can be written to an executable server location, allowing a malicious script to be invoked remotely. This issue is fixed in ver...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93641	New	9.3	CRIT				An unauthenticated sender can forge a share notification that triggers stored XSS when a signed-in Zimbra Classic recipient clicks Accept Share, allowing the attacker to access mailbox data and act as the victim.
CVE-2026-93642	New	9.3	CRIT				An unauthenticated sender can forge a share notification that triggers stored XSS when a signed-in Zimbra Modern recipient clicks Accept Share, allowing the attacker to access mailbox data and act as the victim.
CVE-2026-93647	New	9.3	CRIT				An unauthenticated calendar sender can place active markup in a COUNTER message's RFC From address. Selecting the message in Zimbra Classic triggers stored XSS, allowing the attacker to access mailbox data and act as the victim.
CVE-2026-95832	New	9.3	CRIT				Improper Neutralization of Special Elements in Output Used by a Downstream Component in the colour control escape code handler in kitty from 0.47.3 before 0.49.0 allows a program writing to the terminal to execute an arbitrary command in the user's shell, because color_control() in kitty/window.py answers a query for an unrecognised field name by placing that field name into...
CVE-2026-39353	New	9.1	CRIT				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2-rc-1, InvoicePlane builds its permitted template list by scanning a PHP template directory that can be written through an administrator-controlled file-write capability. A malicious PHP file placed in the directory is automatically trusted by Mdl_templates and c...
CVE-2026-42322	New	9.1	CRIT				Piwigo is a full featured open source photo gallery application for the web. Prior to 16.4.0, admin/themes_standard_pages.php validates uploaded logo content by MIME type but reuses the attacker-controlled extension from std_pgs_logo when constructing the stored filename. An authenticated administrator can upload image content with a server-executable final extension, causin...
CVE-2026-62262	New	9.1	CRIT				Piwigo is a full featured open source photo gallery application for the web. In 17.0.0beta1 and earlier, when rating is enabled, an unauthenticated guest can call pwg.images.filteredSearch.create with a crafted ratings[] value and then open the returned search URL. include/ws_functions/pwg.images.php stores the unvalidated value in the search rules, and include/functions_sea...
CVE-2026-84458	New	9.1	CRIT				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, when the "Automatic account link on initial logon" setting is enabled, Zammad binds an incoming third-party (SSO) identity to an existing local account by matching the email address the identity provider reports, without verifying that the provider actually confirmed ownership of that email. ...
CVE-2026-89055	New	9.1	CRIT		0.004		The Customer Reviews for WooCommerce plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 5.120.0. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to permanently delete arbitrary attachments from the Media Library — including admin...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93399	New	9.1	CRIT		0.004		The Bookly plugin for WordPress is vulnerable to Insecure Direct Object Reference in versions up to, and including, 28.2 via the 'bookly_get_form_id', 'bookly_render_complete', 'bookly_add_to_calendar' and 'bookly_rollback_order' AJAX actions. This is due to the 'bookly_get_form_id' handler blindly storing the attacker-controlled 'order_id' from the submitted form_data into ...
CVE-2026-97063	New	9.1	CRIT				X-SpringBoot through 6.0 returns login verification codes in HTTP responses from unauthenticated endpoints GET /sys/mobile/code and GET /sys/email/code without sending them to account owners. Attackers can request codes using known mobile numbers or email addresses, read them from responses, and authenticate as victims via POST /sys/emailOrMobileLogin/login to hijack accounts.
CVE-2026-97064	New	9.1	CRIT				X-SpringBoot through 6.0 ships with a hardcoded static master login verification code 172839 enabled by default in the database seed. Unauthenticated attackers can authenticate as any user by submitting the public master code to the emailOrMobileLogin endpoint with a known email or mobile number.
CVE-2025-51457	New	8.8	HIGH				D-Link DAP-2610 up to 2.06B08r099 contains an authenticated command injection vulnerability within the web interface at the /index.xgi endpoint. An attacker with authenticated access can exploit some parameters to execute arbitrary system commands.
CVE-2026-100520	New	8.8	HIGH				Laranode versions before 1.2.1 contain a path traversal vulnerability in the POST /filemanager/upload-file endpoint that allows authenticated users to write arbitrary files outside their home directory. Attackers can supply directory traversal sequences in the path parameter to write PHP files into other tenants' web roots and execute code as those tenants.
CVE-2026-100544	New	8.8	HIGH				openclaw's @openclaw/voice-call package before 2026.8.1 launches the configured agent for classic inbound voice calls without propagating the caller's identity or non-owner status. As a result, owner-only tool filtering can fail open and expose the agent's normal tool authority to a remote caller. A caller who is admitted by the configured inbound-call policy (open, pairing,...
CVE-2026-100552	New	8.8	HIGH				OpenClaw (npm package 'openclaw') before 2026.8.1 does not correctly enforce per-chat tool policies for Codex app-server runtime tools. A conversation-level tools.allow rule filtered OpenClaw tools but did not restrict the shell, process, file, and patch tools owned by the Codex runtime. When a lower-trust conversation was assigned to a Codex runtime and restricted with a pe...
CVE-2026-100575	New	8.8	HIGH				OpenClaw Slack versions before 2026.8.1 fail to properly enforce sender allowlists in multi-person direct messages. Disallowed participants can trigger Slack agents and access tools and data granted to those agents by bypassing configured sender policies.
CVE-2026-100580	New	8.8	HIGH				OpenClaw (npm package 'openclaw') before 2026.7.1 improperly handles case sensitivity in the model-facing cron tool: a mixed-case payload kind can pass the agent-facing shell-execution guard and later normalize into a command job. An actor able to steer a tool-enabled agent can therefore create a persistent cron job that executes attacker-selected commands with the privilege...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100586	New	8.8	HIGH				OpenClaw Codex before 2026.7.1 fails to properly enforce owner authorization when creating native conversation bindings. Non-owner channel senders with command access can create bindings to the native Codex runtime and execute host-capable turns with access to files, tools, and processes.
CVE-2026-100587	New	8.8	HIGH				OpenClaw versions before 2026.7.1 fail to properly validate owner authorization in the Codex computer-use installation command. Non-owner channel senders can install arbitrary plugins and execute MCP processes with OpenClaw user privileges, affecting host confidentiality, integrity, and availability.
CVE-2026-100596	New	8.8	HIGH				OpenClaw versions before 2026.7.1 fail to properly authorize non-owner users executing MCP configuration changes through /mcp set and /mcp unset commands. Attackers can persist arbitrary stdio MCP commands that execute with OpenClaw process privileges when configuration loads, compromising host confidentiality, integrity, and availability.
CVE-2026-100599	New	8.8	HIGH				OpenClaw versions 2026.5.1 through 2026.7.0 fail to apply the configured exec approval path to Google Meet node commands. The googlemmeet.chrome command accepts caller-supplied audio command arrays and executes them on a paired node without going through the normal system.run approval flow. In deployments with the Google Meet plugin enabled, a paired Chrome node, and the goog...
CVE-2026-19804	New	8.8	HIGH		0.01		The s2Member – Excellent for All Kinds of Memberships, Content Restriction Paywalls & Member Access Subscriptions plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 260814 via the 'first_name' parameter parameter. This is due to insufficient sanitization of the first_name parameter via esc_refs(), which strips only regex backref...
CVE-2026-61525	New	8.8	HIGH				Zammad is a web based open source helpdesk/customer support system. In 7.0.2 and 7.1.0, zammad's session management for websocket and long-polling connections is susceptible to a path traversal attack. Session identifiers supplied by the client are insufficiently validated before being used to construct internal file paths. When the file-based session store is active (the de...
CVE-2026-62062	New	8.8	HIGH		0.001		Cross-Site Request Forgery (CSRF) vulnerability in Elementor Website Builder allows Cross Site Request Forgery. This issue affects Elementor Website Builder: from n/a through 4.3.1.
CVE-2026-85542	New	8.8	HIGH				IBM Guardium Data Protection 12.2 is affected by a command injection vulnerability in the GIM bundle import functionality. An authenticated attacker can provide a crafted GIM bundle that causes attacker-controlled arguments to be passed to the tar command, resulting in arbitrary command execution with elevated privileges on the Central Manager.
CVE-2026-89426	New	8.8	HIGH		0.005		The Knit Pay – Cashfree, Instamojo, Razorpay, PayPal and more plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 9.6.1.0. This is due to the `maybe_update_user_role()` function reading the target role directly from an attacker-controlled Gravity Forms entry field — configured via the feed's `user_role_field_id` — and passing it t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93834	New	8.8	HIGH				A use-after-free vulnerability was found in QEMU's 9pfs subsystem. A race condition between the main thread and a worker thread when processing concurrent Tlcreate and Twalk requests allows a malicious guest user to craft a fid path containing stale heap data, bypassing directory traversal restrictions and escaping the shared directory boundary. This can lead to arbitrary ho...
CVE-2026-94445	New	8.8	HIGH				A malicious txtar could escape the intended execution context and force arbitrary writes to the playground host's trusted filesystem. Disjointly, one of the three possible paths to invoke go vet on the playground host did not correctly restrict the execution environment. This permitted a Go process to make a read for an environment configuration file rooted in the playgro...
CVE-2026-96795	New	8.8	HIGH				Horilla is an HR and CRM software. Prior to 2.0.0, HorillaListView.export_data in horilla_views/generic/cbv/views.py accepts an authenticated user's columns POST parameter, takes field_tuple[1], interpolates it into dynamic_fn_str as Python source, and passes the generated function definition to exec(). A crafted string that remains valid under ast.literal_eval can inject Py...
CVE-2026-96812	New	8.8	HIGH				Improper Exposure of Resource to Wrong Sphere in the host file helper (gofer) in Google gVisor prior to commit 573a9e73cf844f on Linux platforms with CUSE enabled allows a local attacker with container image deployment privileges to achieve root code execution on the host system. By including a /dev/cuse character device node in a container image, opening the device passes t...
CVE-2026-97527	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Serialize NVMe unsol ctx list with a per-fcport lock The fcport->unsol_ctx_head list is modified from several contexts without a common lock. Entries are added in qla2xxx_process_purbs_iocb() from the response queue ISR (under the qpair qp_lock), while they are removed from qla2xxx_process_p...
CVE-2026-97528	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Unlink NVMe unsol ctx before freeing on LS reject error qla_nvme_xmt_ls_rsp() obtains uctx, which was linked into fcport->unsol_ctx_head by qla2xxx_process_purbs_iocb() and is still linked when the NVMe transport calls back to transmit the LS response. On the error (out:) path the function f...
CVE-2026-97555	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: smb: client: fix heap overflow in DACL owner/group rewrite When id_mode_to_cifs_acl rewrites an existing DACL, it allocates a buffer sized according to the on-disk DACL length reported by dacl_ptr->size. However, replace_sids_and_copy_aces may rewrite each ACE with a new owner/group SID obtained from the c...
CVE-2026-97957	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: net: hinic: fix mailbox segment buffer overflow check_mbox_seq_id_and_seg_len() validates that seq_id does not exceed SEQ_ID_MAX_VAL (42) and seg_len does not exceed MBOX_SEG_LEN (48). However, this allows the last segment (seq_id=42) to carry a full 48-byte payload, writing to offset 42*48=2016 for 48 by...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98115	New	8.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: ksmbd: safely drain sessions during logoff SMB3 multichannel allows requests for one session to run on multiple connections. Wait for all channels bound to a session before freeing shared session objects. A deferred byte-range lock remains counted as a running request and only wakes when its file closes. ...
CVE-2026-56725	New	8.7	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, summary An unauthenticated request to POST /api/v1/import/otrs/import_check blocks a Zammad request worker for roughly two minutes. The import_check and import_status actions are missing the setup_done_response guard that other actions in the same controller carry, so they execute on fully se...
CVE-2026-56733	New	8.7	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2 and 7.1.0, this issue concerns a lack of discursive validation within the authorization cascade. It has been determined that the system-level enforcement of access restrictions during the initialization of new identity objects exhibits a discrepancy: Under specific conditions, the granular res...
CVE-2026-84462	New	8.6	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, a security filter that protects Zammad's AI Agent configuration can be bypassed by entering specially crafted text into one of an AI Agent's fields. An administrator with permission to create or edit AI Agents could exploit this to run arbitrary commands on the server that hosts Zammad, poten...
CVE-2026-100172	New	8.5	HIGH				The AIL Framework (ail-project/ail-framework) contains a stored cross-site scripting (XSS) vulnerability in two Jinja2 templates that render popovers for matched, tracked, or tagged content: var/www/templates/chats_explorer/block_message.html and var/www/templates/objects/item/show_item.html. In both templates, dynamic values associated with this content, including icon colo...
CVE-2026-100176	New	8.5	HIGH				The AIL Framework's username timeline feature is vulnerable to stored cross-site scripting (XSS). Usernames imported from chats and crawled forums are stored without character restrictions. When an authenticated analyst views the username timeline, the application renders these stored usernames into the DOM using D3's html() method in the tooltip. Because the username value ...
CVE-2026-47679	New	8.5	HIGH				GLPI is a free asset and IT management software package. From 10.0.0 until 10.0.26 and 11.0.8, any logged-in GLPI user can exploit insufficient path validation in the profile-picture update flow to request deletion of an attacker-selected file hosted by the server. This issue is fixed in versions 11.0.8 and 10.0.26.
CVE-2026-55214	New	8.5	HIGH				GLPI is a free asset and IT management software package. From 11.0.6 until 11.0.8, an authenticated technician can store active markup in supplier website fields. Any user who opens the affected item's suppliers list triggers the stored cross-site scripting payload. This issue is fixed in version 11.0.8.
CVE-2026-71483	New	8.5	HIGH				Horilla is an HR and CRM software. Prior to 1.6.0, the search parameter at /employee/employee-filter-view is reflected by jQuery .html() in employee/templates/employee_nav.html without HTML neutralization. An external attacker can craft and deliver a link that causes JavaScript to execute when an authenticated employee or administrator reaches the employee filter, allowing a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100248	New	8.4	HIGH				The Rattadan Cosmowarp smart contract before 56c6147 can have a comparison to an unintended value of current_admin.
CVE-2026-100368	New	8.4	HIGH			nuget:AlastairLundy.CliInvoke.Specializations, nuget:CliInvoke.Specializations	CliInvoke is a .NET library for invoking command-line programs, and its `CliInvoke.Specializations` packages provide specialized wrappers for shells such as PowerShell and Windows Command Prompt. `CliInvoke.Specializations` versions 2.2.0 through 2.8.4, 2.9.0 through 2.9.3, 2.10.0 through 2.10.4, 3.0.0-alpha.1 through 3.0.0-alpha.4, and 3.0.0-alpha.8 through 3.0.0-alpha.10, ...
CVE-2026-100369	New	8.4	HIGH			nuget:AlastairLundy.CliInvoke, nuget:CliInvoke	CliInvoke and its formerly named `AlastairLundy.CliInvoke` package are .NET libraries for invoking command-line programs and wrapping executable processes. `CliInvoke` versions 2.0.0 through 2.8.4, 2.9.0 through 2.9.3, 2.10.0 through 2.10.4, and 3.0.0-alpha.1 through 3.0.0-beta.1, as well as `AlastairLundy.CliInvoke` versions 2.0.0-alpha.1 through 2.0.0, contain an argument-...
CVE-2026-56731	New	8.4	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.1, a low-privilege authenticated user may inject arbitrary HTML markup, including JavaScript event handlers, into a ticket title via the standard ticket creation workflow. The title is persisted without sanitization. This issue is fixed in version 7.0.1.
CVE-2026-97898	New	8.4	HIGH				Insecure Direct Object Reference / missing object-level authorization in the Akia keyless entry cloud service. The unlock action is relying on a client-supplied room/door identifier that is not properly authorized server-side against the authenticated guest's booking. An authenticated guest could unlock rooms other than their own, resulting in unauthorized physical access to...
CVE-2026-100551	New	8.3	HIGH				OpenClaw for iOS versions >= 2026.7.1 and < 2026.8.11 do not enforce saved Gateway TLS pins in the Control UI. While native connections enforced the saved Gateway fingerprint, the authenticated Terminal and session Dashboard WebViews omitted it. If a user had accepted a Gateway fingerprint, an attacker able to redirect the same host and port and present a different certifica...
CVE-2026-100557	New	8.3	HIGH				OpenClaw versions before 2026.8.1 contain an authorization bypass vulnerability in skill tool dispatch that fails to carry the sender's owner status. Non-owner senders authorized to invoke skill commands can access owner-only tools and server credentials reserved for owners.
CVE-2026-100568	New	8.3	HIGH				OpenClaw versions before 2026.8.1 fail to properly restrict access to operator command cron jobs, allowing model-visible agent callers to read and execute ownerless command jobs. Attackers can inspect stored environment variables and force-run disabled or unscheduled command jobs to access secrets and execute operator-authored commands.
CVE-2026-100588	New	8.3	HIGH				OpenClaw (npm package 'openclaw') before 2026.7.1 does not enforce the administrator scope requirement on browser control when it is reached through the node.invoke method, although direct browser.request access requires administrator scope. In Gateway deployments that honor caller identity and narrower operator scopes, a write-scoped caller with access to a connected browse...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100589	New	8.3	HIGH				OpenClaw versions before 2026.7.1 contain a sandbox bypass vulnerability in the browser tool that allows sandboxed sessions to access paired node browser actions despite allowHostControl=false configuration. Attackers with control over sandboxed agent input can select a paired node and perform host browser operations, inspecting or manipulating the connected browser profile ...
CVE-2026-100391	New	8.2	HIGH				MediaFlow Proxy through 2.4.9 contains a server-side request forgery vulnerability in the /proxy routes due to missing and incomplete destination validation in the d query parameter. Remote attackers can supply arbitrary internal URLs including loopback and cloud metadata endpoints to read full responses from the proxy server.
CVE-2026-100567	New	8.2	HIGH				OpenClaw is an agent gateway distributed as the npm package 'openclaw'. In versions >= 2026.4.5 and < 2026.8.1, the Gateway validated a single DNS resolution result for a configured remote Chrome DevTools Protocol (CDP) hostname, but the raw WebSocket and Playwright transports performed a later, independent DNS resolution, discarding the DNS pinning enforced at validation ti...
CVE-2026-67236	New	8.2	HIGH				RabbitMQ is a messaging and streaming broker. From 4.2.0 until 4.2.8 and 4.3.2, a successful POST /login caused is_authorized/2 to set an auth cookie containing base64-encoded username:password credentials without HttpOnly, Secure, SameSite, or expiration protections. Because base64 is encoding rather than encryption, an attacker with same-origin cross-site scripting, an HTTP...
CVE-2026-67409	New	8.2	HIGH				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 4.3.3, 4.2.9, 4.1.14, 4.0.23, and 3.13.18, JWKS Fetch Ignores HTTP Response Status Code - Signing Key Destruction Causes Authentication DoS (CVE-252). the JWKS key fetching mechanism in uaajwt.erl does not validate the HTTP response status code when downloading signing keys from the OAuth2 provider's JWKS endpoint...
CVE-2026-67410	New	8.2	HIGH				RabbitMQ is a messaging and streaming broker. From 4.2.0 until 4.3.3 and 4.2.9, OAuth2 Client Secret Exposed via Unauthenticated JavaScript Endpoint (CVE-200). when OAuth2 authentication is enabled for the RabbitMQ Management UI and the configured flow, IDP use a client secret, the oauthclientsecret configuration value is included in the JavaScript served by the unauthentica...
CVE-2026-97525	New	8.2	HIGH				In the Linux kernel, the following vulnerability has been resolved: x86/mm/pat: Allocate split page tables as kernel page tables A PTE is allocated directly without going through the standard page table allocation routines (such as pte_alloc_one_kernel()) when the CPA code splits a large page (__split_large_page()). This means the page table constructor is never called no...
CVE-2026-100387	New	8.1	HIGH				pgPointcloud through 1.2.5 contains a heap out-of-bounds read vulnerability in dimensional patch WKB deserialization that allows authenticated database users to read adjacent heap memory. Attackers can supply crafted pcpatch values with attacker-controlled size fields to copy heap memory into stored patches for exfiltration or crash the PostgreSQL backend.
CVE-2026-100389	New	8.1	HIGH				GestSup versions before 3.2.61 contain a remote code execution vulnerability in the basic IMAP connector's attachment handling that fails to skip blocked file extensions. Unauthenticated attackers can send emails with PHP attachments to monitored mailboxes, which are written to the web-accessible upload/ticket directory and executed when accessed.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100532	New	8.1	HIGH				@openclaw/whatsapp (npm) before 2026.8.1 exposes the WhatsApp login tool through the generic channel-tool path without preserving the originating sender's owner status, so the owner-only tool boundary is not enforced. An admitted non-owner sender able to steer the tool can request a forced login and receive a new QR code for a configured account, disconnecting the Gateway's ...
CVE-2026-44642	New	8.1	HIGH				Piwigo is a full featured open source photo gallery application for the web. Prior to 16.4.0, check_upgrade_access_rights() in admin/include/functions_upgrade.php conditionally escapes the submitted username only when the removed get_magic_quotes_gpc function exists, so PHP 8 and later concatenate an unauthenticated username directly into the upgrade authentication SQL query...
CVE-2026-51773	New	8.1	HIGH				An issue in the VMware datastore driver of OpenStack glance_store. When an authenticated attacker provides a maliciously crafted image location URI pointing to an external server, the _retry_request function fails to validate the destination host before attaching sensitive authentication headers.
CVE-2026-92713	New	8.1	HIGH		0.003		The Modula Image Gallery – Photo Grid & Video Gallery plugin for WordPress is vulnerable to arbitrary file deletion due to insufficient file path validation in the upload_image function in all versions up to, and including, 3.0.2. This makes it possible for authenticated attackers, with author-level access and above, to delete arbitrary files on the server. The path restrict...
CVE-2026-97570	New	8.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: bnxt_en: Bound SW TPA IDs to prevent crashes FW supports up to 1024 concurrent TPAs, so the FW TPA ID is in the range 0..1023 (see commit ec4d8e7cf024 ("bnxt_en: Add TPA ID mapping logic for 57500 chips.")). bnxt_alloc_agg_idx is intended to wrap the FW ID down to a software ID which is used to index rxr->...
CVE-2026-97573	New	8.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: bnxt_en: Handle buffer allocation failure in bnxt_rx_ring_reset() bnxt_rx_ring_reset() frees the ring buffers and then reallocates them, ignoring the result. bnxt_alloc_one_rx_ring() can fail in bnxt_alloc_one_tpa_info_data(), which returns -ENOMEM on the first failed allocation and leaves the remaining r...
CVE-2026-97875	New	8.1	HIGH				Rojo's "rojo serve" HTTP API (default port 34872) has no Host/Origin header validation, making it vulnerable to DNS rebinding. A malicious webpage can read all project source, write malicious code to files on disk, and launch local programs via opener::open() with no user interaction beyond visiting the page.
CVE-2026-98069	New	8.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: net/rds: acquire the fastpath locks in rds_conn_shutdown() rds_conn_shutdown() quiesces the transmit and receive-refill paths by waiting for RDS_IN_XMIT and RDS_RECV_REFILL to be sampled clear, and then runs the transport shutdown and rds_conn_path_reset(). Sampling the bits clear is not the same as ownin...
CVE-2026-98070	New	8.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: net/rds: acquire RDS_IN_XMIT in rds_tcp_reset_callbacks() rds_tcp_reset_callbacks() quiesces the transmit path by setting the path state to RDS_CONN_RESETTING and then waiting for RDS_IN_XMIT to be sampled clear before swapping the underlying socket and calling rds_send_path_reset(). Sampling the bit clea...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98130	New	8.1	HIGH				In the Linux kernel, the following vulnerability has been resolved: sctp: fix a TOCTOU race in SCTP_CMD_TIMER_START The SCTP_CMD_TIMER_START handler checks timer_pending() before calling timer_reduce(). The timer can expire and detach between these operations, causing timer_reduce() to rearm the timer without taking the association reference required for the newly armed ti...
CVE-2026-100559	New	8.0	HIGH				OpenClaw versions before 2026.8.1 contain a command parser vulnerability where escaped newlines confuse exec allowlist parsing, allowing hidden commands to execute. Attackers can craft input with escaped newlines to bypass allowlist validation and execute additional commands without expected authorization prompts.
CVE-2026-100561	New	8.0	HIGH				OpenClaw (npm package 'openclaw') versions >= 2026.3.22 and < 2026.8.1 contain an approval-bypass flaw in the exec approval policy: the policy could trust a command-running wrapper without inspecting the command carried in its arguments. After an operator allowlisted or permanently approved a benign wrapper invocation, a later agent turn could substitute an arbitrary inner c...
CVE-2026-100585	New	8.0	HIGH				OpenClaw (npm package 'openclaw') before 2026.7.1 fails to enforce the owner-only authorization requirement for Claude Code permission prompts delivered through the MCP channel bridge. An authorized non-owner channel sender with channel command access can approve or deny a pending permission request intended for the owner, causing the requested action to proceed without owne...
CVE-2026-100570	New	7.8	HIGH				OpenClaw (npm package 'openclaw') versions >= 2026.3.28 and < 2026.8.1 allow an untrusted workspace .env file to set the CLOUDSDK_PYTHON_ARGS environment variable. When an operator starts OpenClaw in attacker-controlled workspace content and then runs the Gmail setup flow, that value is inherited when gcloud is launched, and the gcloud launcher passes it as arguments to the ...
CVE-2026-100597	New	7.8	HIGH				OpenClaw (npm package 'openclaw') before 2026.7.1 is vulnerable to a time-of-check time-of-use race condition in OpenShell local mirror filesystem mutation operations. The remove, mkdir, and rename operations could act on a different filesystem target after OpenClaw completed its sandbox path-safety check, if the path is changed concurrently. An attacker able to win the race...
CVE-2026-79153	New	7.8	HIGH				Seclore FileSecure Desktop Client before 3.25.1.0 contains improper access control vulnerability in the kernel-mode driver component that allows an authenticated local user to gain elevated privileges to NT AUTHORITY\SYSTEM on affected systems.
CVE-2026-91837	New	7.8	HIGH				A flaw was found in NetworkManager-iodine, the iodine VPN plugin for NetworkManager. A local unprivileged user can exploit a vulnerability in how the 'nameserver' setting is processed when establishing an iodine VPN connection. By embedding shell metacharacters (special characters that can execute commands) in the 'nameserver' value, an attacker can inject and execute arbitr...
CVE-2026-91838	New	7.8	HIGH				A flaw was found in NetworkManager-sstp, the SSTP VPN plugin for NetworkManager. A local unprivileged user can exploit this vulnerability by embedding special characters, known as shell metacharacters, into VPN connection profile fields such as CA certificate or proxy settings. These unescaped characters are then processed by the 'pppd' daemon, which runs with root privilege...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91839	New	7.8	HIGH				A flaw was found in NetworkManager-fortisslvpn, the FortiSSLVPN plugin for NetworkManager. The nm-fortisslvpn-service improperly handles carriage-return/line-feed (CR/LF) characters in VPN connection profile credentials. A local unprivileged user can exploit this by crafting a malicious VPN profile to inject additional configuration directives. This can lead to arbitrary cod...
CVE-2026-91840	New	7.8	HIGH				A flaw was found in NetworkManager-vpnc. This vulnerability allows a local unprivileged user to escalate privileges to root. By injecting a newline character into the VPN username field, an attacker can manipulate the vpnc configuration to execute an arbitrary program with root privileges when the malicious VPN connection is activated.
CVE-2026-91841	New	7.8	HIGH				A flaw was found in NetworkManager-vpnc, a VPN plugin for NetworkManager. A local unprivileged user can exploit this vulnerability by injecting a newline character into the CA-File path. This manipulation allows the user to execute arbitrary commands as the root user, leading to local privilege escalation.
CVE-2026-97548	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: xfs: fix the rtrmap and rtrefcount _maxlevels_ondisk functions The _maxlevels_ondisk functions are used to compute the size of in-memory btree cursors for each btree type. Unfortunately, LOLLM noticed that the rtrmap and rtrefcount versions of these functions forget to account for the inode root, which me...
CVE-2026-97575	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: v4l2-ctrls: validate AV1 tile counts The stateless AV1 decoders use tile_info.tile_cols and tile_rows as loop bounds and as indices into the mi_*_starts[] and *_in_sbs_minus_1[] arrays, as the divisor for context_update_tile_id, and their product bounds the per-tile descriptor buffers, but std_valid...
CVE-2026-97576	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: v4l2-ctrls: validate HEVC tile counts The stateless HEVC decoders read num_tile_columns_minus1 + 1 entries from column_width_minus1[] and num_tile_rows_minus1 + 1 from row_height_minus1[] and use them as tile-loop bounds, but std_validate_compound() does not bound these u8 counts. Reject a V4L2_CTRL...
CVE-2026-97577	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: verisilicon: rockchip: reject AV1 frames exceeding the tile capacity rockchip_vpu981_av1_dec_set_tile_info() indexes the tile group entry array by tile1 * tile_cols + tile0, reading up to tile_cols * tile_rows entries, lays out one descriptor per tile in the AV1_MAX_TILES tile_info buffer, and progr...
CVE-2026-97578	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: verisilicon: rockchip: guard VPU981 AV1 divisor and tile buffer rockchip_vpu981_av1_dec_set_tile_info() divides context_update_tile_id by tile_info->tile_cols and writes one descriptor per tile into the tile_info DMA buffer, which holds AV1_MAX_TILES entries; tile_cols and tile_rows come from the bi...
CVE-2026-97579	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: mediatek: vcodec: bound AV1 tile-start copy to the array capacity vdec_av1_slice_setup_tile() copies tile_cols + 1 / tile_rows + 1 entries into mi_col_starts[] / mi_row_starts[] from the bitstream tile_info. Bound the copy to the array capacity.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97580	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: media: rkvdcc: bound HEVC tile loops and PPS id to the array capacity compute_tiles_uniform() and compute_tiles_non_uniform() loop over num_tile_columns_minus1 + 1 / num_tile_rows_minus1 + 1 entries, and assemble_hw_pps() writes one COLUMN_WIDTH / ROW_HEIGHT register per tile and indexes priv_tbl->param_se...
CVE-2026-97584	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: afs: Fix incorrect free in candidate cleanup in afs_lookup_server() Fix afs_lookup_server() to not free an existing server's endpoint state when cleaning up a candidate server. The candidate record doesn't have an endpoint state yet at this point, so the free for that can just be removed.
CVE-2026-97594	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: landlock: Fix use-after-free of the source's parent directory current_check_refer_path() reads old_dentry->d_parent without holding a reference nor a lock on it, and then dereferences it in collect_domain_accesses() and in the audit record. A reference on a child does not pin its parent: __d_move() reassi...
CVE-2026-97602	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: inet: frags: invalidate queues before flushing them fqdir_pre_exit() flushes the skbs from incomplete queues without changing their completion state. A fragment which found a queue before high_thresh was cleared can then acquire the queue lock and reuse stale reassembly metadata. A queue concurrently kille...
CVE-2026-97611	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: net: openvswitch: fix use-after-free of the flow table mask array tbl_mask_array_realloc() retires the old mask_array before it stops being reachable: old = ovsl_dereference(tbl->mask_array); if (old) { ... call_rcu(&old->rcu, mask_array_rcu_cb); } rcu_assign_pointer(tbl->mask_array, new); call_...
CVE-2026-97612	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: net: mpls: clear inner_protocol when the last label is popped skb_mpls_push() records the pre-encapsulation network header once, gated on !skb->inner_protocol. skb_mpls_pop() never clears that record, so it outlives the encapsulation it describes. Open vSwitch can then re-push MPLS onto a packet whose inn...
CVE-2026-97903	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: exit: hold a reference to thread_pid across proc_flush_pid Commit 0a36bad01731 ("release_task: kill the no longer needed get/put_pid(thread_pid)") removed the reference around proc_flush_pid(). It assumed that free_pids(post.pids) at the end of release_task() would keep thread_pid alive until then. That a...
CVE-2026-97910	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: ASoC: sprd: validate compress buffer sizes against fixed allocations sprd_platform_compr_open() allocates the stage 0 IRAM buffer (32K data area) and the stage 1 DDR buffer (2M data area) with fixed sizes, but sprd_platform_compr_copy() derives all copy lengths from the user controlled runtime->fragment_si...
CVE-2026-97911	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: accel: ethosu: Ensure SRAM region size matches job It is possible for userspace to set the job SRAM size to 0, but then still have SRAM accesses in the command stream. When the job SRAM size is 0, setting the region base register is skipped and a stale base address from a prior job is used. Check the regi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97937	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: ftrace: fork: Initialize function graph state before copy_exec_state() dup_task_struct() copies the parent's task_struct, including ret_stack. ftrace_graph_init_task() clears the copied function graph state, but it currently runs after copy_exec_state(). For non-CLONE_VM forks, copy_exec_state() allocates...
CVE-2026-97940	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: ipv6: fix fib6 walker UAF on seq stop ipv6_route_iter_active() treats a walker in FWS_U at the table root as already unlinked. fib6_del_route() can move a still-linked walker into that same state when the current leaf is the last route at the root, so ipv6_route_native_seq_stop() skips fib6_walker_unlink()...
CVE-2026-97941	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: mm/slab: take n->list_lock in __slab_try_return_freelist() to avoid race Commit ba7425312607 ("mm, slab: add an optimistic __slab_try_return_freelist()") incorrectly assumed that nobody has freed an object to the slab as long as slab->freelist is NULL and cmpxchg succeeds. However, as reported by Hyunwoo ...
CVE-2026-97971	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: nstree: check listing permission before taking a namespace reference legitimize_ns() takes a reference on the candidate namespace before may_list_ns() has decided whether the caller may see it. The __free(ns_put) cleanup on the denied path can drop the last reference to a mount namespace while we still hol...
CVE-2026-97991	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: vdpa_sim_blk: reject out-of-range sector starts vdpasim_blk_check_range() logs an invalid start sector but continues validating the request. The subsequent unsigned capacity subtraction can underflow and let an out-of-range buffer offset reach the data path. The invalid offset is used by three request pa...
CVE-2026-98002	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: iommu/amd: Fix ineffective error check in nested domain allocation amd_iommu_pdom_id_alloc() returns an int: a domain ID on success, or the negative errno from ida_alloc_range() when the ID space is exhausted or memory is short. amd_iommu_alloc_domain_nested() stores that return value in gdom_info->hdom_i...
CVE-2026-98017	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: net/sched: defer qdisc freeing after failed creation An RTM_NEWQDISC request can make clsact bind a populated shared ingress block during ->init(), publishing an embedded mini_Qdisc to lockless readers. If the same request has an invalid TCA_RATE, estimator setup fails after ->init(); the unwind removes t...
CVE-2026-98023	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: vxlan: reject dynamic fdb entries that reference a nexthop id The commit cited in the Fixes tag allowed VXLAN FDB entries to point to FDB nexthops so that overlay traffic could be load balanced across multiple VTEPs. Such entries can only be configured from user space, cannot be learned and cannot roam. Th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98052	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: net: bcmasp: clear txc->last before writing each descriptor bcmasp_xmit() only wrote txc->last = true for the final fragment of an SKB; non-final fragments left the field untouched. If a descriptor slot was reused while it still held a stale true from a previous SKB (possible when tx_spb_ring_full() und...
CVE-2026-98073	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: net: Remove conflicting altnames for dying netns in __dev_change_net_namespace(). syzbot reported the warning in cfg80211_pernet_exit(). [0] The repro does the following: 1. create two device in root netns and non-root netns 2. assign the same altname for the two devices 3. remove the non-root netn...
CVE-2026-98112	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: ksmbd: fix listener task lifetime on netdev events The listener thread exits when its listening socket is shutdown. The netdevice notifier shuts down the socket before calling kthread_stop(), so the task_struct can be freed before kthread_stop() gets its reference. Create the listener in a stopped state a...
CVE-2026-98116	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: ALSA: pcm: Serialize PCM mmap with buffer reallocation to fix page UAF snd_pcm_hw_params() and snd_pcm_hw_free() guard buffer reallocation with an mmap_count check performed under the PCM stream lock, but the lock is released long before the buffer is actually freed: snd_pcm_sync_stop(), constraint refinem...
CVE-2026-98122	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: vxlan: mdb: Fix use-after-free in vxlan_mdb_remote_src_del() vxlan_mdb_is_valid_source(), which validates MDBE_ATTR_SOURCE and every MDBE_ATTR_SRC_LIST member, accepts the all-zeros address. A source list is only accepted on a (*, G) entry, whose source is the all-zeros address, and for each member of the...
CVE-2026-98143	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: accel: ethosu: Don't read the U65 rounding mode as a storage mode Bits 15:14 of NPU_SET_{IFM,OFM}_PRECISION select the activation storage mode on U85 only. On U65 the same field holds the rounding mode, and the command stream parser has read it as a storage mode since the driver was added. That went unnot...
CVE-2026-98156	New	7.8	HIGH				In the Linux kernel, the following vulnerability has been resolved: drm/virtio: use the DMA API for resource backing on Xen On a Xen PV domain page addresses bear no relation to the real machine addresses the host would have to use to reach it. virtio_ring.c handles this correctly, vring_use_map_api() returns true for any xen_domain() regardless of VIRTIO_F_ACCESS_PLATFORM...
CVE-2026-49470	New	7.7	HIGH				GLPI is a free asset and IT management software package. From 11.0.0 until 11.0.8, the time-based one-time password verification endpoint does not limit failed submissions per user. An attacker who has obtained a user's primary authentication credentials can repeatedly submit TOTP values against the MFA verification flow, making brute-force compromise of the second factor an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89032	New	7.7	HIGH				BerriAI LiteLLM before 1.101.0-rc.1 contains a tenant isolation bypass vulnerability in the semantic cache layer that allows authenticated users to read other tenants' cached responses by exploiting a metadata key mismatch between <code>_get_semantic_cache_tenant_scope()</code> and <code>_get_metadata_variable_name()</code> . Attackers holding a valid virtual key can submit semantically similar prompt...
CVE-2026-100578	New	7.6	HIGH				OpenClaw (npm package `openclaw`) before 2026.7.1 fails to restrict owner-only infrastructure tools exposed through the chat.send endpoint. In Gateway deployments using authentication modes that honor caller identity and narrower operator scopes, a write-scoped non-owner caller can start a chat turn whose tool inventory includes the `gateway` and `cron` tools, causing the ag...
CVE-2026-100579	New	7.6	HIGH				OpenClaw (npm package 'openclaw') before 2026.7.1 incorrectly trusts requester provenance in message.action. In identity-bearing Gateway deployments (authentication modes that honor caller identity and narrower operator scopes), a write-scoped caller can supply another sender's identifier to the channel authorization checks and invoke a channel action under that spoofed requ...
CVE-2026-67239	New	7.6	HIGH				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.18 and 4.0.23 and 4.1.14 and 4.2.9 and 4.3.3, Stored XSS via TLS peer-certificate DN in stream-management UI (sibling of V-11). lines 102/106/110 render peercertsubject / peercertissuer with raw <%= %> and no fmtstring(). RFC4514 backslash-escaping of </> is HTML-inert and bypassable (). Require...
CVE-2026-84893	New	7.6	HIGH				IBM Guardium Data Protection 12.2 is vulnerable to SQL injection in the PESI service. An authenticated attacker could exploit this vulnerability to access sensitive information in the internal database.
CVE-2026-100208	New	7.5	HIGH				Integer overflow or wraparound in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-100535	New	7.5	HIGH				OpenClaw (npm package 'openclaw') versions >= 2026.4.5 and < 2026.8.1 can lose the originating requester's restrictions and untrusted provenance when session-derived text is persisted to session memory. In deployments where session-memory capture and dreaming are enabled, a restricted external sender whose messages are admitted with limited tools can persist instructions tha...
CVE-2026-100541	New	7.5	HIGH				OpenClaw's Matrix integration (npm package @openclaw/matrix) versions >= 2026.2.2 and < 2026.8.1 lowercase complete Matrix user IDs — including historical localparts and the case-sensitive server-name portion — when deriving the OpenClaw authorization identity. As a result, distinct authenticated Matrix accounts can normalize to the same authorization identity. A Matrix part...
CVE-2026-100543	New	7.5	HIGH				OpenClaw (npm package openclaw) before 2026.8.1 could include deterministic hashes computed over the original, unredacted configuration in redacted configuration responses. When the Gateway password had low entropy and the remaining configuration values were reconstructable, these hashes acted as offline password verifiers: a caller able to obtain the redacted configuration ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100558	New	7.5	HIGH				OpenClaw versions before 2026.8.1 contain a resource exhaustion vulnerability in the Gateway listener that allows unauthenticated clients to retain response sockets by sending WebSocket upgrade requests without matching connection semantics. Attackers can repeatedly send malformed upgrade requests to exhaust listener resources and cause denial of service without consuming th...
CVE-2026-100560	New	7.5	HIGH				OpenClaw versions before 2026.8.1 contain an authorization bypass vulnerability where Allow Always approvals for exact commands persist as path-only grants on macOS and Linux. Attackers can reuse the same executable with different arguments to execute commands without triggering new approval prompts, potentially accessing files or internal services.
CVE-2026-10758	New	7.5	HIGH				Esri LERC is an open-source image or raster format which supports rapid encoding and decoding for any pixel type. A Heap based Out-of-Bounds Write via Integer Overflow in LERC versions 4.1.0 and earlier may allow a remote, unauthenticated attacker who can pass specifically crafted attacker controlled imagery to an application that uses LERC to crash the application, leading ...
CVE-2026-13456	New	7.5	HIGH		0.007		The WP Maps – Google Maps,OpenStreetMap,Mapbox,Store Locator,Listing,Directory & Filters plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 4.9.8 via the 'page' parameter parameter. This makes it possible for authenticated attackers, with subscriber-level access and above, to include and execute arbitrary .php files on the server...
CVE-2026-49850	New	7.5	HIGH				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane exposes Invoices::delete() and Invoices::delete_invoice_tax() as state-changing routes without requiring POST and validating a CSRF token. When an authenticated administrator loads attacker-controlled content that requests an affected route, the ap...
CVE-2026-50547	New	7.5	HIGH				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane's Invoices::generate_xml() method appends a database-derived xml_id to the XMLconfigs helper directory and includes the resulting PHP path without validating the identifier. A low-privileged attacker who can influence the e-invoice configuration ca...
CVE-2026-52622	New	7.5	HIGH				An issue in Wellav Technologies Co., Ltd Wellav WES Emergency Broadcast Terminal WES100, WES270, WES280, and WES290 before 08-08-2023 allows a remote attacker to obtain sensitive information via the global API request wrapper function
CVE-2026-5267	New	7.5	HIGH				Ciena Navigator Network Control Suite (NCS) contains an information exposure vulnerability in an event-streaming API that does not properly enforce authentication. An unauthenticated attacker with network access to the affected service could access the event stream and potentially obtain sensitive information.
CVE-2026-53610	New	7.5	HIGH				GLPI is a free asset and IT management software package. From 11.0.0 until 11.0.8, an attacker can craft a URL for a dashboard that reflects attacker-controlled markup without sufficient output encoding. A user who opens the crafted URL triggers reflected cross-site scripting in the dashboard. This issue is fixed in version 11.0.8.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-53625	New	7.5	HIGH				GLPI is a free asset and IT management software package. From 0.70 until 10.0.26 and 11.0.8, a technician can manipulate the authtype value through the API to change another user's authentication method. Under configurations using the legacy API REST interface or SSO logins, this can change a super-administrator's authentication method and enable account takeover. This issue...
CVE-2026-57443	New	7.5	HIGH			pip:scbe-aethermoore	SCBE-AETHERMOORE is a geometric AI governance and evaluation framework. Starting in version 4.0.2 and prior to version 4.2.1, the AetherBrowser API server (`scripts/aetherbrowser/api_server.py`) exposes the `POST /api/ops/check-email` endpoint without any authentication. Any remote attacker can call this endpoint and trigger execution of the `email_reader.py` subprocess, whi...
CVE-2026-67237	New	7.5	HIGH				RabbitMQ is a messaging and streaming broker. From 4.2.0 until 4.2.8 and 4.3.2, set_token_auth/2 inserted a bearer token from the Authorization header or access_token cookie into OAuth bootstrap JavaScript without escaping, allowing attacker-controlled token content to execute JavaScript in the management UI origin. The endpoint is exposed before authentication only when man...
CVE-2026-84882	New	7.5	HIGH				IBM Guardium Data Protection 12.2 is vulnerable to path traversal in the Universal Connector Oracle Wallet upload component. An authenticated remote attacker could exploit this vulnerability to write arbitrary files to the system.
CVE-2026-84884	New	7.5	HIGH				IBM Guardium Data Protection 12.2 stores internal REST service-account passwords in a reversible plaintext-equivalent format. An authenticated attacker who gains access to the stored credential could recover the password and obtain an administrative REST access token.
CVE-2026-85029	New	7.5	HIGH				IBM Guardium Data Protection 12.2 could allow a remote attacker to obtain sensitive information, delete arbitrary files, or execute arbitrary code due to improper limitation of a pathname to a restricted directory.
CVE-2026-88003	New	7.5	HIGH				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane fails to revoke administrative privileges after a role downgrade because Admin_Controller trusts the user_type snapshot stored in an existing session instead of revalidating ip_users.user_type. When one administrator downgrades another account, the...
CVE-2026-88421	New	7.5	HIGH				Incorrect access control in the BlogPage.get_entries() component of APSL puput v1.2.1 through v2.2.0 allows unauthenticated attackers to view restricted blog entries via the blog index, the tag, category, author and date archives, the sidebar widgets, or the RSS feed.
CVE-2026-89406	New	7.5	HIGH		0.004		The Modula Image Gallery – Photo Grid & Video Gallery plugin for WordPress is vulnerable to unauthorized disclosure of private gallery contents in versions up to, and including, 3.0.1. This is due to the Modula_Meta::add metas() function being hooked to wp_head on every frontend request and looking up any post via get_post(\$ _GET['modula_gallery_id']) without verifying the ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91765	New	7.5	HIGH				cleanup_xml_node() in the SOAP XML parser recurses once per XML nesting level with no depth limit. An unauthenticated attacker can post a SOAP request containing tens of thousands of nested elements to any SoapServer endpoint, exhaust the stack and crash the process. The same unbounded recursion exists in the SOAP value decoder and in the WSDL node search helper.
CVE-2026-92550	New	7.5	HIGH		0.002		A pre-authentication attacker could leverage type size/count handling to cause excessive allocation leading to potential denial of service. This issue affects Apache Qpid Broker-J: through 10.1.0. Users are recommended to upgrade to version 10.1.1, which fixes the issue.
CVE-2026-92560	New	7.5	HIGH		0.002		A pre-authentication attacker could leverage type size/count handling to cause excessive allocation leading to potential denial of service. This issue affects Apache Qpid Broker-J: through 10.1.0. Users are recommended to upgrade to version 10.1.1, which fixes the issue.
CVE-2026-92608	New	7.5	HIGH		0.002		Improper handling of property-encoding exceptions in AMQP 1.0-to-AMQP 0-10 message conversion allows authenticated message producers to disrupt delivery to AMQP 0-10 consumers via message properties that the target encoder does not handle correctly. This issue affects Apache Qpid Broker-J: through 10.1.0. Users are recommended to upgrade to version 10.1.1, which fixes the ...
CVE-2026-97523	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: mptcp: close race between scheduler and state change The mptcp scheduler may race with subflow sockets state change: data transmission on the selected socket may fail and a later release could try to use mss_now reset to 0 for a divide operation. Address the issue by explicitly checking for the critical s...
CVE-2026-97524	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: mptcp: avoid unneeded actions on subflow reset Once in a blue moon, the mptcp receive path can recursively call mptcp_data_ready() via state change under unlucky error conditions, and then try to hold the data lock again. Break the recursion loop explicitly checking for the exceptional condition. Add a n...
CVE-2026-97531	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Skip vport under deletion in report ID acquisition qla24xx_report_id_acquisition() format-1 handling walks ha->vp_list under vport_slock, takes a vref_count on the matching vport and calls qla_update_host_map() to register its port id. A vport teardown via qla24xx_vport_delete() sets VPORT_...
CVE-2026-97536	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix use-after-free of qpair work on queue teardown The response queue MSI-X handler qla2xxx_msix_rsp_q() schedules qla_do_work() via queue_work(ha->wq, &qpair->q_work). qla_do_work() dereferences the qpair (vha, rsp) and takes qpair->qp_lock. During teardown, qla2xxx_delete_qpair() deletes ...
CVE-2026-97557	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: smb: client: avoid leaking refcount in cifs_queue_oplock_break() cifs_queue_oplock_break() unconditionally takes a reference on the target file before queueing cifs_oplock_break(). Only that work item decreases the reference counter again. If another oplock break arrives while that work is still queued, q...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97562	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: smb: client: pin DFS superblock in iterator callback tcon_super_cb() stores a raw superblock pointer, but __cifs_get_super() takes its active reference only after iterate_supers_type() has dropped s_umount and its passive reference. Concurrent DFS automount expiry can therefore free the superblock before c...
CVE-2026-97583	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: afs: Clear stale peer app data after address list changes afs_fs_probe_fileserver() fetches the current endpoint state under server->fs_lock, but leaves old_alist as NULL. Consequently, afs_set_peer_appdata() treats every address list replacement as initial setup and only binds the new peers; it never unb...
CVE-2026-97595	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: mac802154: fix use-after-free of sdata via queued RX frames The RX softirq producer ieee802154_subif_frame() queues received beacon and MAC-command frames onto local->rx_beacon_list / rx_mac_cmd_list and schedules a process-context worker, storing a raw mac_pkt->sdata (and skb->dev == sdata->dev) with neit...
CVE-2026-97990	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: vdpa_sim_net: check TX pull result before RX copy vringh_iov_pull_iotlb() returns a signed byte count. A failed TX pull is currently added to the unsigned byte counter and then passed as a size_t length to receive_filter() and vringh_iov_push_iotlb(). A negative error can therefore become a large length ...
CVE-2026-98050	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: mlxsw: spectrum_ptp: Fix napi_gro_receive() call from GC workqueue context Currently mlxsw_sp1_ptp_ht_gc_collect() is run from the PTP garbage-collection workqueue, rather than the NAPI poll context. For any unmatched PTP entries carrying an SKB, it calls mlxsw_sp1_ptp_unmatched_finish() -> mlxsw_sp1_ptp_p...
CVE-2026-98056	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: nvme: remove stale namespaces by NSID range during scan nvme_scan_ns_list() drops the stale namespaces in each gap in the reported NSID list one NSID at a time. Every iteration calls nvme_find_get_ns() to look the namespace up and removes it if it is present. The loop runs once per NSID in the gap rather t...
CVE-2026-98108	New	7.5	HIGH				In the Linux kernel, the following vulnerability has been resolved: Bluetooth: L2CAP: fix chan mode for LE_CONN_REQ + EXT_FLOWCTL pchan l2cap_new_connection() sets default value of channel mode to match the parent channel. l2cap_le_connect_req() left this at the default, and created L2CAP_MODE_EXT_FLOWCTL channels if listening pchan has that mode. This causes FLAG_DEFER_...
CVE-2026-100390	New	7.4	HIGH				Zoraxy versions 3.2.3 through 3.3.4 fail to properly parse IPv6 addresses in the RemoteAddr field when setting forwarded headers. Unauthenticated attackers connecting over IPv6 can supply arbitrary X-Forwarded-For values to spoof their source IP and bypass authorization provider IP-based access controls.
CVE-2026-98096	New	7.4	HIGH				In the Linux kernel, the following vulnerability has been resolved: ipv6: sr: restore network header before routing and forwarding ipv6_srh_rcv() runs with skb->data at the Segment Routing Header (SRH) while skb_network_header() points at the IPv6 header. When segments_left > 0, ipv6_srh_rcv() previously restored the skb->data position by pushing sizeof(struct ipv6hdr), a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100310	New	7.3	HIGH				GNU libextractor before 1.16 loads plugins from an untrusted search path specified by the LIBEXTRACTOR_PREFIX environment variable without proper privilege checks. A local attacker can exploit this by setting LIBEXTRACTOR_PREFIX to a directory containing a malicious plugin that executes arbitrary code with elevated privileges when loaded by a setuid or setgid program.
CVE-2026-100530	New	7.3	HIGH				OpenClaw versions before 2026.8.1 fail to bind working directory context to reusable exec approvals, allowing approved commands to execute in different directories. Attackers with an allow-always approval can reuse it to run the same command against unreviewed files or repositories with materially different effects.
CVE-2026-93901	New	7.3	HIGH		0.003		The Optima Express IDX plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 8.7.5. This is due to the <code>`provisionBlogCredentials()`</code> function in <code>`iHomefinderAdmin.php`</code> being reachable via the <code>`wp_ajax_nopriv_ihf_clear_cache`</code> AJAX action — through the call chain <code>`iHomefinderAjaxHandler::clearCache()`</code> → <code>`activateAuthenticationToken()`</code> ...
CVE-2026-97865	New	7.3	HIGH				A security flaw has been discovered in Open-Web-Analytics up to 1.8.1. Affected is the function <code>Event::loadFromArray</code> of the file <code>queue.php</code> of the component Remote Event Queue Endpoint. Performing a manipulation results in deserialization. The attack can be initiated remotely. Upgrading to version 1.8.2 is able to address this issue. The patch is named 78c1222ec0e2119d8468403...
CVE-2026-97871	New	7.3	HIGH				A vulnerability has been found in Zhonglun CloudPos up to 3.0.1.76. This issue affects the function <code>OpenLocalBrowser</code> of the file <code>ZIPos/ZIPos/Bizlogic/JSBridge.cs</code> of the component JSBridge. Such manipulation of the argument <code>url</code> leads to code injection. The attack can be executed remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted e...
CVE-2026-97882	New	7.3	HIGH				A weakness has been identified in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. The impacted element is an unknown function of the file <code>loginlinkfaculty.php</code> of the component Faculty Authentication. Executing a manipulation of the argument <code>fid/pass</code> can lead to sql injection. It is possible to launch the attack remotely. The exploit ha...
CVE-2026-97883	New	7.3	HIGH				A security vulnerability has been detected in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. This affects an unknown function of the file <code>updatequery.php</code> . The manipulation of the argument <code>gid</code> leads to sql injection. The attack can be initiated remotely. The exploit has been disclosed publicly and may be used. Continuous delivery with ...
CVE-2026-97885	New	7.3	HIGH				A flaw has been found in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. Affected is an unknown function of the file <code>updatefaculty.php</code> . This manipulation of the argument <code>fid</code> causes sql injection. The attack may be initiated remotely. The exploit has been published and may be used. This product uses a rolling release model to deliver co...
CVE-2026-100372	New	7.2	HIGH				ClipBucket v5 before 5.5.3-#197 contains a path traversal vulnerability in the admin template editor that allows authenticated administrators to overwrite PHP files by supplying directory traversal sequences in the folder parameter. Attackers with <code>manage_template_access</code> permission can traverse outside the layout directory to modify executable PHP files and achieve remote cod...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-33639	New	7.2	HIGH				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane interpolates the administrator-controlled <code>tax_rate_decimal_places</code> setting into an ALTER TABLE statement for <code>ip_tax_rates</code> in <code>Settings::index()</code> without strict integer validation. A crafted setting value can add clauses to the schema-changing statemen...
CVE-2026-42323	New	7.2	HIGH				Piwigo is a full featured open source photo gallery application for the web. Prior to 16.4.0, <code>admin/batch_manager.php</code> accepts administrator-controlled dimension width, height, and ratio values and filesize values from the Batch Manager filter URL without numeric validation. The URL filter parser stores those values in the <code>bulk_manager_filter</code> session state, and later query co...
CVE-2026-42324	New	7.2	HIGH				Piwigo is a full featured open source photo gallery application for the web. Prior to 16.4.0, <code>admin/element_set_ranks.php</code> stores administrator-controlled <code>image_order[]</code> values without enforcing the existing sort-field whitelist. The stored album <code>image_order</code> expression is later concatenated into ORDER BY clauses by <code>admin/batch_manager_global.php</code> , <code>admin/batch_manager_unit.php</code> , ...
CVE-2026-83591	New	7.2	HIGH		0.002		The AMP for WP – Accelerated Mobile Pages plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment Content via Regex Transformation in all versions up to, and including, 1.1.16 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever...
CVE-2026-84279	New	7.2	HIGH		0.002		The Fancy Product Designer plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'output_format' parameter in all versions up to, and including, 6.5.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an inject...
CVE-2026-84280	New	7.2	HIGH		0.003		The Fancy Product Designer plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Shortcode Order 'elements[].title' Parameter in all versions up to, and including, 6.5.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user acc...
CVE-2026-84281	New	7.2	HIGH		0.002		The Fancy Product Designer plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'productTitle' in '_fpd_data' Order Item Meta in all versions up to, and including, 6.5.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user ac...
CVE-2026-84862	New	7.2	HIGH				IBM Guardium Data Protection 12.2 is vulnerable to insecure deserialization in the Quartz JDBC job store. An authenticated attacker could exploit this vulnerability to execute arbitrary code on the affected system.
CVE-2026-85750	New	7.2	HIGH				Piwigo before v16.4.0 is vulnerable to arbitrary file read and remote code execution in image upload handling when using the Imagick library due to insufficient validation and unsafe processing of user-supplied image files. By abusing format confusion (e.g., disguising SVG content as PNG), an attacker can trigger unintended interpretation of embedded SVG elements that refere...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93303	New	7.2	HIGH		0.002		The HT Contact Form – Drag & Drop Form Builder for WordPress plugin for WordPress is vulnerable to Stored DOM-Based Cross-Site Scripting via 'form_data' Rich Text Field via Draft Save/Resume in all versions up to, and including, 2.10.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scri...
CVE-2026-93654	New	7.2	HIGH		0.002		The Premium Packages – Sell Digital Products Securely plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'cart_items[product_name]' Parameter in all versions up to, and including, 7.2.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execut...
CVE-2026-94573	New	7.2	HIGH		0.002		The Repeater Fields for Elementor Forms plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Repeater Field Value in all versions up to, and including, 2.2.7 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an in...
CVE-2026-95864	New	7.2	HIGH		0.003		The Themify Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'css[fonts]' Parameter in all versions up to, and including, 7.8.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. The n...
CVE-2026-95866	New	7.2	HIGH		0.003		The User Profile Builder – Beautiful User Registration Forms, User Profiles & User Role Editor plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Avatar Field in all versions up to, and including, 4.0.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages t...
CVE-2026-96039	New	7.2	HIGH		0.002		The BA Book Everything plugin for WordPress is vulnerable to Stored Cross-Site Scripting via first_name Parameter in all versions up to, and including, 1.8.27 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. An ...
CVE-2026-96568	New	7.2	HIGH		0.002		The Restaurant Menu and Food Ordering plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'phone_number' parameter in all versions up to, and including, 2.4.14 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesse...
CVE-2026-96752	New	7.2	HIGH		0.002		The Zero Spam for WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Nested POST Array Keys via Contact Form 7 Integration in all versions up to, and including, 5.7.10 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97060	New	7.2	HIGH				X-SpringBoot through 6.0 lacks object-level authorization in user management endpoints, allowing sub-administrators to modify or delete users without ownership verification. Attackers with user-management permissions can reset passwords for any account including the super administrator, rebind roles, or delete users via POST /sys/user/update and POST /sys/user/delete endpoints.
CVE-2026-100555	New	7.1	HIGH				OpenClaw is an npm-distributed gateway application. In versions >= 2026.7.1 and < 2026.8.1, Synology Chat attachment delivery could lose DNS pinning: the Gateway validated a single DNS result for a supplied file URL but then passed the original hostname to the Synology NAS, where it could resolve to a different destination. When attachment delivery accepted a remotely influe...
CVE-2026-100598	New	7.1	HIGH				OpenClaw (npm package openclaw) before 2026.7.1 incorrectly binds Signal approval reactions. In affected versions, a reaction intended to resolve a structured approval request could instead attach to ordinary outbound text when unrelated outbound messages and a pending approval are present in the same conversation. As a result, an approver's reaction to unrelated text could ...
CVE-2026-53626	New	7.1	HIGH				GLPI is a free asset and IT management software package. From 11.0.5 until 11.0.8, under certain conditions, permission logic can grant access to a document without confirming that the document is linked to the targeted item. A user can use an unrelated item that the user is permitted to view to read a document linked to an inaccessible item. This issue is fixed in version 1...
CVE-2026-53629	New	7.1	HIGH				GLPI is a free asset and IT management software package. From 9.4.0 until 10.0.26 and 11.0.8, an attacker with the READ right on logs can craft a URL for the history tab that injects attacker-controlled values into a database query. This permits SQL injection through the history tab endpoint. This issue is fixed in versions 11.0.8 and 10.0.26.
CVE-2026-56723	New	7.1	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, a customer who can view a ticket cannot see internal ticket articles through the article listing API. However, the same customer can directly request an attachment belonging to an internal article via the attachment download endpoint, bypassing article-level authorization. This results in an ...
CVE-2026-56724	New	7.1	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, summary An issue with permission checks in the knowledge base management area has been identified. Under certain conditions, data validation for linked items was not fully enforced. This could have allowed users with limited read permissions to interact with items outside their assigned acces...
CVE-2026-56727	New	7.1	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, summary In Zammad's inbound PGP email processing, the return value of the gpg verification call was silently discarded. Regardless of whether gpg reported a valid, invalid, or missing signature, the handler unconditionally wrote sign: { success: true, comment: "Good signature" } to the articl...
CVE-2026-57449	New	7.1	HIGH				Actual is a local-first personal finance tool. Prior to 26.7.0, Actual Sync Server's CORS proxy is intended to let authenticated users fetch resources only from repositories listed in the official plugin allowlist. When `ACTUAL_GITHUB_TOKEN` is configured, the proxy automatically attaches the server's GitHub token to GitHub requests. The GitHub API allowlist check uses a raw...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67408	New	7.1	HIGH				RabbitMQ is a messaging and streaming broker. From 4.1.0 until 4.3.3, 4.2.9, and 4.1.11, Stream Management Super-Stream Binding Keys Allocation Allows Low-Privilege Node Denial of Service. rabbitMQ 4.3.1 with rabbitmqstreammanagement enabled accepts PUT /api/stream/super-streams/{vhost}/{name} requests from an authenticated management user that can access the target vhost. W...
CVE-2026-67419	New	7.1	HIGH				RabbitMQ is a messaging and streaming broker. Prior to 4.3.5, an authenticated user who can bind a queue to a topic exchange and publish to it can use consecutive # segments in a binding key to make both topic matchers revisit the same trie-node and routing-key-suffix states without memoization. The matcher materializes duplicate destinations before deduplication, causing co...
CVE-2026-84464	New	7.1	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, zammad's External Data Source feature, used to look up records from an external system, did not properly verify whether a user was allowed to see a specific ticket, user, group, or organization before including its details in a request to that external system. An authenticated user, including...
CVE-2026-84465	New	7.1	HIGH				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, when Zammad checks the digital signature on an incoming S/MIME-signed email, it does not verify that the signing certificate is genuinely trusted, it only checks whether a certificate with a matching name is already stored in the system. An attacker can create their own certificate using the ...
CVE-2026-93306	New	7.1	HIGH				IBM Server Firmware FW1120.00 through FW1120.01, FW1110.00 through FW1110.31, FW1060.00 through FW1060.81, and FW950.00 through FW950.H3 is affected by a vulnerability in the ASMI web interface. An unauthenticated attacker on the management network can send a malformed HTTPS request to ASMI, causing the web server to crash with possible memory corruption and generate an erro...
CVE-2026-93365	New	7.1	HIGH				Bludit CMS through 3.22.0 contains a missing authorization vulnerability that allows authenticated users holding the Author or Editor role to read the full content of private drafts and scheduled posts belonging to any other user, including administrators, by exploiting the content-get-list AJAX endpoint in bl-kernel/ajax/content-get-list.php. Attackers can send an authentic...
CVE-2026-100419	New	7.0	HIGH				gitoxide gix-fs before 0.23.0 contains a path validation bypass vulnerability in the worktree checkout mechanism that allows attackers to escape the worktree directory via symlink manipulation. During forced checkout with overwrite_existing enabled, attackers can craft malicious repository trees where symlink entries replace validated directories, causing subsequent files to...
CVE-2026-100504	New	7.0	HIGH				Ghidra versions through 12.1.4 contain a stack-based out-of-bounds write vulnerability in the decompiler's leftshift128 function when processing negative shift amounts from p-code. Attackers can craft malicious binaries with specific instruction sequences that trigger the overflow when decompiled, corrupting memory and potentially achieving code execution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97589	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: s390/crypto: Fix wrong return code to engine in asynch callbacks When crypto_finalize_hash_request() or crypto_finalize_skcipher_request() explicitly completes a request, the do_one_request callback must return 0 to indicate successful handling. Returning a negative error code causes the crypto engine to a...
CVE-2026-97608	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_log: unregister loggers before per-net teardown nf_log_syslog and nfnetlink_log unregister their per-network namespace operations before unregistering their global logger backends. This leaves a window where a sysctl or netlink writer can rebind the still-registered logger after the per-net ...
CVE-2026-97609	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: netfilter: cttimeout: prevent UAF during module unload nf_ct_set_timeout() protects the timeout hook dereference and policy lookup with rcu_read_lock(). cttimeout_exit(), however, unregisters the per-net operations before it clears the hook. This allows the following interleaving: CPU 0 ...
CVE-2026-97926	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: ufs: validate cylinder group metadata before caching it ufs_read_cylinder() copies the cylinder group index and the rotor positions straight from the on-disk group and caches them without any check: ucpi->c_cgx = fs32_to_cpu(sb, ucg->cg_cgx); ucpi->c_rotor = fs32_to_cpu(sb, ucg->cg_rotor); ucpi->c_...
CVE-2026-97931	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: ALSA: us122l: Prevent write upgrades for read mappings The hwdep mmap callback rejects read-buffer mappings that are initially writable, but leaves VM_MAYWRITE set on mappings created with PROT_READ. A process that can open the hwdep node O_RDWR can later use mprotect() to make the mapping writable. The r...
CVE-2026-97953	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: net: stmmac: fix TX descriptor availability check for TSO traffic stmmac_tso_xmit() estimates the number of free TX descriptors required by a TSO skb as: (skb->len - proto_hdr_len) / TSO_MAX_BUFF_SIZE + 1 which assumes the payload is split into TSO_MAX_BUFF_SIZE chunks. This underestimates the descripto...
CVE-2026-98027	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: net: dsa: mv88e6xxx: bound the policy rule dump by the caller's buffer size mv88e6xxx_get_rxnfc() uses rxnfc->rule_cnt as the write index while dumping the policy IDR, clobbering the input value before it has been looked at. That input is the number of entries the caller had room for. ETHTOOL_GRXCLSRLALL ...
CVE-2026-98029	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: eth: nfp: bound the ntuple rule dump by the caller's buffer size nfp_net_get_fs_loc() dumps every entry of nn->fs.list into rule_locs[] without consulting cmd->rule_cnt, which is how many entries the caller had room for. ETHTOOL_GRXCLSRLALL requires no CAP_NET_ADMIN and the ioctl sizes the buffer from the...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98030	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: net: dsa: bcm_sf2: bound the CFP rule dump by the caller's buffer size bcm_sf2_cfp_rule_get_all() walks the whole cfp.unique bitmap into rule_locs[] without consulting nfc->rule_cnt, which is how many entries the caller had room for. ETHTOOL_GRXCLSRLALL requires no CAP_NET_ADMIN and the ioctl sizes the bu...
CVE-2026-98041	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: bpf: Don't predict JMP32 pointer vs zero comparisons Consider the following program: r1 = map_value; /* low 32 bits are zero at runtime */ r6 = 0xdead000000000000; if w1 != 0 goto l1; l0: r1 += r6; r2 = *(u64 *) (r1 + 0); exit; l1: r6 = 0; goto l...
CVE-2026-98083	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: btrfs: fix transaction use-after-free in raid stripe insertion If allocation of a RAID stripe extent fails, btrfs_insert_one_raid_extent() aborts and ends the transaction before returning -ENOMEM. btrfs_finish_one_ordered(), the production caller through btrfs_insert_raid_extent(), still owns the transact...
CVE-2026-98150	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: bpf: Fix BPF_F_CPU validation for sparse CPU IDs BPF_F_CPU stores the target CPU ID in the upper 32 bits of the map operation flags. bpf_map_check_op_flags() currently compares that ID with num_possible_cpus(), which is the number of possible CPUs rather than a bound on CPU IDs. On an arm64 QEMU guest wit...
CVE-2026-98154	New	7.0	HIGH				In the Linux kernel, the following vulnerability has been resolved: nvme-rdma: fix -EIO cleanup order in queue_rq On -EIO, the RDMA queue_rq path reports a host path error and then still cleans up the command and unmaps the SQE DMA. The path error helper completes the request, so that is double cleanup and DMA unmap after the request is already complete. Unmap the SQE fir...
CVE-2026-100187	New	6.9	MEDI				The Onion module in AIL Framework contained a performance shortcut in its URL extraction logic that accepted URLs as valid .onion targets based solely on a length check (exactly 69 characters) and a suffix check (ending in ".onion"), without performing proper hostname parsing or onion-domain validation. An unauthenticated attacker who could publish or control web content cra...
CVE-2026-100377	New	6.9	MEDI				Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Wikimedia Foundation Mediawiki - WikiLambda Extension allows Excavation. This issue affects Mediawiki - WikiLambda Extension: 1.47.0-alpha. The issue has been remediated on the `master` branch.
CVE-2026-17545	New	6.9	MEDI				On Windows, PHP's filesystem and stream APIs do not reject reserved device names such as CON, PRN, AUX, NUL, COM1 to COM9, LPT1 to LPT9, CONIN\$ and CONOUT\$ when they appear as a component of a path. An attacker-controlled filename therefore reaches CreateFileW() and opens a device instead of the regular file the application expected, which can block or hang the request and e...
CVE-2026-63207	New	6.9	MEDI				Zammad is a web based open source helpdesk/customer support system. In 7.0.3 and 7.1.1, an authenticated administrator can obtain stored integration credentials in cleartext through the integration administration API. Certain responses do not consistently mask sensitive fields, so configured secrets can be returned in plain text instead of the expected masked placeholder. Bo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67226	New	6.9	MEDI				RabbitMQ is a messaging and streaming broker. From 4.0.0 until 4.0.22 and 4.1.14 and 4.2.7, Admin-only atom exhaustion: PUT /api/users tags list. settags/2 maps rabbitdatacoercion:toatom/1 over the user's tags list. The 20 MB management body limit fits ~3-4M short tag strings. An administrator can crash the node in a single request by creating a user (or importing definition...
CVE-2026-84461	New	6.9	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, the two-factor login step let an attacker try unlimited password guesses for any account without triggering Zammad's normal lockout or rate limiting. The response also revealed whether a guess was correct, even before two-factor authentication was checked. This made it possible to brute-force...
CVE-2026-96875	New	6.9	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Mediawiki - Cargo extension allows Stored XSS. This issue affects Mediawiki - Cargo extension: through 3.9.4.
CVE-2026-96876	New	6.9	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Mediawiki - Cargo extension allows Reflected XSS. This issue affects Mediawiki - Cargo extension: through 3.9.4.
CVE-2026-96877	New	6.9	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Mediawiki - Cargo extension allows Reflected XSS. This issue affects Mediawiki - Cargo extension: through 3.9.4.
CVE-2026-96878	New	6.9	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Mediawiki - Cargo extension allows Reflected XSS. This issue affects Mediawiki - Cargo extension: through 3.9.4.
CVE-2026-96879	New	6.9	MEDI				Improper removal of sensitive information before storage or transfer vulnerability in Wikimedia Foundation's Mediawiki - FlaggedRevs extension through 1.46.0.
CVE-2026-100540	New	6.8	MEDI				OpenClaw Feishu before 2026.8.1 fails to validate whether a configured default account is disabled before selecting it for model tool operations. Attackers can exploit multi-account setups where a disabled default account retains credentials to read or modify Feishu resources through a revoked identity.
CVE-2026-80431	New	6.8	MEDI				Out-of-bounds Write in the natural width branch of the text sizing protocol in kitty from 0.40.0 before 0.49.0 allows a program writing to the terminal to write past the end of a fixed-size buffer, because screen_handle_multicell_command() in kitty/screen.c appends each codepoint of a grapheme cluster with lc.chars[lc.count++] = ch without any capacity check, while lc is dec...
CVE-2026-97846	New	6.8	MEDI		0.001		Keycloak provides a feature called mTLS holder-of-key binding which ensures that a token can only be used by the client that originally requested it by binding it to their digital certificate. A flaw was discovered where the new Standard Token Exchange V2 feature does not check for this certificate. This allows an attacker with stolen client credentials to obtain a standard,...
CVE-2026-100584	New	6.7	MEDI				OpenClaw is an npm-distributed agent runtime. In versions >= 2026.2.26 and < 2026.7.1, PowerShell command analysis on Windows hosts running in exec allowlist mode could approve an exact executable resolved from PATH but subsequently execute a same-named executable located in the workspace directory. If lower-trust content can place an executable with an approved basename int...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96448	New	6.6	MEDI		0.002		A flaw was found in the Fine-Grained Admin Permissions (FGAP v2) feature of Keycloak, an identity and access management solution. The issue occurs when the system checks if a delegated administrator has permission to assign a specific role to a user. Because the check does not look inside composite roles to see what other permissions they contain, an administrator with limit...
CVE-2025-14181	New	6.5	MEDI				The SOAP HTTP client guards its response buffer growth with a check that relies on signed integer overflow, which is undefined behaviour and is not guaranteed to trigger. When the check is optimised away, a malicious SOAP server can make the client allocate a buffer far smaller than the data it then writes into it, producing a heap buffer overflow.
CVE-2026-100192	New	6.5	MEDI				X-SpringBoot through 6.0 exposes appKey and appSecret credentials in the GET /application/manager/select endpoint without authentication or field filtering. Unauthenticated attackers can retrieve these credentials and use them to send arbitrary SMS messages through any tenant's SMS provider, enabling SMS bombing and impersonation attacks.
CVE-2026-100501	New	6.5	MEDI				Flame through 2.4.0 contains an improper restriction of excessive authentication attempts vulnerability in the POST /api/auth login endpoint that allows unauthenticated attackers to brute-force the admin password. Attackers can submit unlimited password guesses without rate limiting, attempt counters, lockouts, or delays to gain full administrator access and modify applicati...
CVE-2026-100531	New	6.5	MEDI				The @openclaw/slack npm package before 2026.8.1 contains an authorization flaw in its Slack download-file handler: when a file lacks the share metadata used to prove it belongs to the requested conversation, the conversation-authorization check fails open. An authenticated caller restricted to a single conversation who knows or obtains a file identifier can therefore downloa...
CVE-2026-100536	New	6.5	MEDI				OpenClaw versions before 2026.8.1 fail to validate all source fields in structured message attachments, allowing attackers to hide unvalidated host paths behind allowed attachment sources. Attackers can exploit this by providing multiple source fields to bypass sandbox path validation and cause Telegram delivery to read and send known host files that would otherwise be rejec...
CVE-2026-100538	New	6.5	MEDI				OpenClaw (npm package 'openclaw') before 2026.8.1 does not apply the originating sender's global or per-agent toolsBySender policy when handling outbound attachments. A sender that has been explicitly denied filesystem read tools can still cause a known local file to be read and returned via a final-response media directive or a message attachment, disclosing local file cont...
CVE-2026-100566	New	6.5	MEDI				OpenClaw LINE versions before 2026.8.1 contain an access control vulnerability where group allowlist mode silently inherits DM allowFrom values when groupAllowFrom is not explicitly configured. Attackers with group participation can trigger the agent despite configured group allowlist restrictions when DM access is broader than intended group access.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100582	New	6.5	MEDI				OpenClaw channel plugins (@openclaw/msteams, @openclaw/feishu, @openclaw/matrix, and @openclaw/googlechat) before 2026.8.1 do not enforce the configured channel read allowlist for caller-supplied explicit read targets in message, reaction, pin, member, and related metadata read actions. A lower-trust sender or a steered agent with access to a channel read action can therefor...
CVE-2026-100594	New	6.5	MEDI				OpenClaw versions before 2026.7.1 contain an authorization bypass vulnerability in the /export-trajectory endpoint that allows non-owner senders to request and receive owner-only trajectory bundles. Attackers can access prompts, model messages, tool schemas, runtime events, and local path metadata from affected sessions by exploiting insufficient authorization checks.
CVE-2026-100595	New	6.5	MEDI				OpenClaw versions before 2026.7.1 contain an authorization bypass vulnerability in the diagnostics export command that allows non-owner channel senders to access owner-only host diagnostic bundles. Attackers can request and receive diagnostic details about the host, configuration, runtime, and connected services intended only for owners.
CVE-2026-63431	New	6.5	MEDI				Horilla is an HR and CRM software. In 1.5.0-85 and earlier, payroll/views/component_views.py does not consistently authorize access in allowances_deductions_tab, view_single_allowance, and view_single_deduction before loading records selected by emp_id, allowance_id, or deduction_id. An authenticated employee can substitute those identifiers to read another employee's salary...
CVE-2026-63432	New	6.5	MEDI				Horilla is an HR and CRM software. From 1.0.0 until 1.6.0 and 2.0.0, the get_mail_preview handlers in recruitment/views/actions.py and employee/not_in_out_dashboard.py render a user-controlled body at /recruitment/get-mail-preview/ and /employee/get-employee-mail-preview with the full request object in the Django template context. An authenticated user with a valid CSRF toke...
CVE-2026-85274	New	6.5	MEDI				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane exposes Recurring::stop() as a state-changing GET route without CSRF token validation. When an authenticated administrator loads attacker-controlled content that requests /invoices/recurring/stop/{id}, the application stops the selected recurring i...
CVE-2026-85289	New	6.5	MEDI				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane omits ensure_valid_post_request() from delete methods including Payments::delete(), Recurring::delete(), and User_clients::delete(). Although the routes require POST, they do not validate the request's CSRF token. An attacker can submit a cross-ori...
CVE-2026-85291	New	6.5	MEDI				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane's Users::change_password() method accepts a user_id from the URL and updates that account's password without an object-level authorization check. An authenticated secondary administrator can target the primary administrator account and replace its ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91767	New	6.5	MEDI				php_openssl_matches_wildcard_name() in ext/openssl/xp_ssl.c underflows the length argument passed to memchr() when a TLS server certificate presents a wildcard name whose literal characters are together longer than the hostname being verified. A malicious server presenting such a certificate makes the PHP client read up to SIZE_MAX bytes past the end of a heap allocation. Th...
CVE-2026-91768	New	6.5	MEDI				The IPv6 branch of the FastCGI client access check compares only the first 12 bytes of a 16-byte IPv6 address, so listen.allowed_clients matches on a /96 prefix instead of the exact address. An attacker who can source an address sharing the first 96 bits with an allowed one passes the check and reaches the FastCGI endpoint.
CVE-2026-92573	New	6.5	MEDI		0.002		Improper handling of compressed data in the shared GZIP decompressor used for AMQP 0-8/0-9/0-9-1 and AMQP 0-10 message delivery, message conversion and HTTP management JSON rendering allows authenticated message producers to exhaust memory and disrupt broker availability via processing without a decompressed-output limit. This issue affects Apache Qpid Broker-J: through 10....
CVE-2026-93030	New	6.5	MEDI				FTM 4.x ALL could allow a remote authenticated attacker to obtain sensitive information due to an XML external entity injection flaw.
CVE-2026-93899	New	6.5	MEDI		0.003		The Better Messages – Chat Rooms, Group Chat, Private Messages & AI Chat Bots plugin for WordPress is vulnerable to generic SQL Injection via 'group_id' Message Meta Parameter in all versions up to, and including, 3.0.4 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenti...
CVE-2026-100529	New	6.4	MEDI				OpenClaw versions before 2026.8.1 contain an authorization scope widening vulnerability in file-transfer allow-always approvals that allows attackers to reuse standing grants for unreviewed paths. Attackers can exploit glob metacharacter interpretation and node display name reuse to access sibling paths or different nodes beyond the operator's original approval scope.
CVE-2026-100546	New	6.4	MEDI				OpenClaw (npm package `openclaw`) versions >= 2026.7.2 and < 2026.9.2 contain a race condition in the Discord realtime voice transcript path. Concurrent control-classified voice transcripts could consume speaker context belonging to another participant after an asynchronous control check, causing a transcript to inherit another speaker's owner status. In Discord agent-proxy ...
CVE-2026-13179	New	6.4	MEDI		0.003		The WP Maps – Google Maps,OpenStreetMap,Mapbox,Store Locator,Listing,Directory & Filters plugin for WordPress is vulnerable to Stored Cross-Site Scripting via shapes_values Parameter in all versions up to, and including, 4.9.8 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above...
CVE-2026-15273	New	6.4	MEDI				The Automatic.css plugin for WordPress is vulnerable to Stored Cross-Site Scripting via REQUEST_URI in all version 4.0.0 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts that will execute whenever an administrator accesses the Activity Log settings page.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92746	New	6.4	MEDI		0.002		The Gutenverse – WordPress Blocks, Page Builder & Site Editor plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Post Comment Block 'suffixMain' Attribute in all versions up to, and including, 4.0.8 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, to inj...
CVE-2026-93656	New	6.4	MEDI		0.002		The User Profile Builder – Beautiful User Registration Forms, User Profiles & User Role Editor plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Avatar Field in all versions up to, and including, 4.0.2 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to ...
CVE-2026-93747	New	6.4	MEDI		0.002		The wpForo Forum plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'telegram' profile field in versions up to, and including, 3.1.6. This is due to insufficient input sanitization and output escaping in the profile_update action — the raw \$_POST['data'] array is copied into a \$custom_fields variable before validate() and sanitize() run, both of which ...
CVE-2026-93897	New	6.4	MEDI		0.002		The GeoDirectory – WP Business Directory Plugin and Classified Listings Directory plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Text-type Custom Field (e.g., 'phone') in all versions up to, and including, 2.8.181 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access...
CVE-2026-94376	New	6.4	MEDI		0.002		The Better Messages – Chat Rooms, Group Chat, Private Messages & AI Chat Bots plugin for WordPress is vulnerable to Stored DOM-Based Cross-Site Scripting via User Display Name in all versions up to, and including, 3.0.4 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to in...
CVE-2026-96766	New	6.4	MEDI		0.002		The GeoDirectory – WP Business Directory Plugin and Classified Listings Directory plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'business_hours' parameter in all versions up to, and including, 2.8.183 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and abo...
CVE-2026-100177	New	6.3	MEDI				The AIL Framework crawler task creation API (api_add_crawler_task) contained an insufficient authorization check when a user supplied a cookiejar UUID to attach to a one-shot or scheduled crawler task. The original code only verified that the cookiejar existed and, if its access level was 0, compared the cookiejar's owning user ID to the requesting user ID. It did not valida...
CVE-2026-100190	New	6.3	MEDI				The AIL Framework crawler splash domain page (showDomain.html) is vulnerable to stored cross-site script injection (XSS). User-supplied data originating from imported crawler captures—specifically item IDs, URLs, and screenshot file paths—was interpolated directly into inline JavaScript contexts within the HTML template. This included an onclick attribute that embedded raw s...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100556	New	6.3	MEDI				OpenClaw (npm package openclaw) versions >= 2026.5.2 and < 2026.8.1 contain an incorrect authorization vulnerability in WhatsApp group handling. A group sender who is admitted for ordinary messages but denied by commands.allowFrom or owner command authorization can issue the /new <model> command to reset the shared group session and persist a provider and model override. Thi...
CVE-2026-100577	New	6.3	MEDI				OpenClaw versions before 2026.8.1 fail to validate video asset URLs returned by providers, allowing server-side requests to private destinations. A malicious or compromised provider can return private or loopback URLs to cause the CLI to make requests to internal services accessible from the OpenClaw host.
CVE-2026-100591	New	6.3	MEDI				OpenClaw is an npm-distributed agent gateway. In versions before 2026.7.1, the global Active Memory toggle mutations could omit owner checks. An authorized non-owner external-channel sender could therefore persistently enable or disable Active Memory for the Gateway, disabling memory recall for future sessions or re-enabling global recall where the owner expected it to remai...
CVE-2026-100592	New	6.3	MEDI				OpenClaw is an agent gateway distributed via npm. In versions >= 2026.4.10 and < 2026.7.1, persistent memory dreaming mutations omit owner permission checks. An authorized but non-owner external-channel sender can issue the persistent '/dreaming on' and '/dreaming off' commands to enable or disable the Gateway's Memory Core dreaming behavior, disabling background memory proc...
CVE-2026-61837	New	6.3	MEDI				RabbitMQ is a messaging and streaming broker. From 4.0.0 until 4.3.3, 4.2.9, 4.1.14, and 4.0.23, AMQP 1.0 management GET /bindings exposes full binding topology to any authenticated AMQP user without resource/management permission checks. the AMQP 1.0 HTTP-over-AMQP management endpoint GET /bindings (the rabbitmqmanagement handler) enumerates bindings between an arbitrary ...
CVE-2026-67223	New	6.3	MEDI				RabbitMQ is a messaging and streaming broker. The advisory establishes affected 3.13, 4.0, 4.1, 4.2, and 4.3 maintenance lines but contains conflicting first-fixed versions for the 3.13, 4.0, and 4.1 lines. fill/2 substitutes \${username} into user_dn_pattern without RFC 4514 DN escaping, allowing a crafted username to alter the LDAP bind DN and potentially select a different...
CVE-2026-67225	New	6.3	MEDI				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.15, 4.0.20, 4.1.11, and 4.2.6, the stream protocol stored the FrameMax value negotiated during the Tune handshake but did not compare it with an inbound frame's declared length before buffering the frame. With the stream plugin enabled, a remote client could therefore cause excessive memory pressure and den...
CVE-2026-67230	New	6.3	MEDI				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.15, 4.0.20, 4.1.11, and 4.2.6, the Web STOMP WebSocket handler enforced neither max_frame_size nor login_timeout before authentication, allowing an unauthenticated client to keep a connection alive with a slow stream of small frames and accumulate unbounded pre-authentication state. The rabbitmq_web_stomp p...
CVE-2026-67242	New	6.3	MEDI				RabbitMQ is a messaging and streaming broker. From 4.2.0 until 4.2.9 and 4.3.3, OAuth2 isinteger(Exp) guard skips token-expiry checks for float exp. validateTokenexpiry/1 (lines 208-214) and expirytimestamp/1 (138-144) both guard with 'when isinteger(Exp)' and fall through to ok/never for float values. josejwt.verify validates only the signature, not exp. With float exp, no ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84463	New	6.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, a user with Knowledge Base editing rights for a category can embed a video widget in a published answer with a specially crafted value. When the answer is rendered, that value is inserted into the page's HTML without being escaped for its attribute context, allowing it to break out and inject...
CVE-2026-97863	New	6.3	MEDI		0.003		The cisco_firesight_manager_ACL_rule_export module in misp-modules generates a shell script (.sh) that authenticates to and calls the Cisco fireSIGHT Manager API. The module interpolates configuration values (IP address, login, password, domain ID, policy ID) and MISP attribute values (destination IPs, URLs, event info comments) directly into single-quoted shell string assign...
CVE-2026-97886	New	6.3	MEDI				A vulnerability has been found in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. Affected by this vulnerability is an unknown functionality of the file managevideos2.php. Such manipulation of the argument editassid leads to sql injection. The attack may be launched remotely. The exploit has been disclosed to the public and may be used...
CVE-2026-97895	New	6.3	MEDI				A vulnerability was determined in krayin laravel-crm up to 2.2.5. This affects an unknown part of the file packages/Webkul/Admin/src/Http/Controllers/Settings/UserController.php of the component User Management. Executing a manipulation of the argument role_id can lead to improper privilege management. The attack can be executed remotely. The exploit has been publicly disclo...
CVE-2026-100237	New	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - Thanks Extension allows Stored XSS. This issue affects Mediawiki - Thanks Extension: from * before 1.43.10/1.45.5/1.46.1.
CVE-2026-100521	New	6.1	MEDI				Cotonti through 1.0.0 contains a reflected cross-site scripting vulnerability in the search plugin highlight parameter that performs no HTML or JavaScript escaping. Attackers can craft malicious links with injected JavaScript in the highlight parameter that executes in the browser of any visitor who opens the link, including administrators.
CVE-2026-100522	New	6.1	MEDI				Cotonti through 1.0.0 contains a reflected cross-site scripting vulnerability in message.php where the lng parameter is not properly escaped before output in the confirmation dialog. Unauthenticated attackers can craft malicious links with script payloads in the lng parameter to execute arbitrary JavaScript in victim browser sessions.
CVE-2026-100523	New	6.1	MEDI				Cotonti through 1.0.0 contains an open redirect vulnerability in message.php that base64-decodes the redirect parameter without domain validation. Unauthenticated attackers can craft malicious links with encoded external URLs to redirect users to arbitrary sites via meta refresh tags for phishing attacks.
CVE-2026-17577	New	6.1	MEDI		0.003		The SSL Zen plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the 'uri' (and 'host') parameters in versions up to, and including, 4.7.42. The ssl_zen_messages::getMessages() function builds the 'token_mismatch' message using base64_decode(sanitize_text_field(\$_REQUEST['uri'])) and (optionally) base64_decode(sanitize_text_field(\$_REQUEST['host'])). san...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-18311	New	6.1	MEDI				Readwise Reader for Android contains a cross-site scripting vulnerability due to missing HTML sanitization in its processing of imported document metadata. Attacker-controlled fields such as the author meta tag are inserted into a WebView via innerHTML, enabling stored XSS that executes on synced devices when the malicious document is opened.
CVE-2026-18312	New	6.1	MEDI				Readwise Reader for Android constructs URLs in its WebView using attacker-controlled metadata without proper encoding or escaping. The application interpolates untrusted values directly into URL strings and inserts them into the DOM via innerHTML. Because the interpolation occurs without HTML or JavaScript context encoding, a crafted metadata value can break out of the inten...
CVE-2026-18320	New	6.1	MEDI				Readwise Reader for Android uses a sanitize-html configuration that permits all attributes on SVG and PATH elements due to a wildcard attribute rule. This configuration fails to remove script-capable attributes such as event handlers (e.g., 'onload', 'onerror'). An attacker could supply a document containing malicious SVG content that survives sanitization and executes scrip...
CVE-2026-78393	New	6.1	MEDI		0.002		The Link Library WordPress plugin before 7.9.6 does not properly escape some parameters before outputting them in the addresses of links it generates on its front-end directory pages, leading to Reflected Cross-Site Scripting which could be used against any visitor, including logged-in administrators.
CVE-2026-78902	New	6.1	MEDI				Cross Site Scripting vulnerability in Netgate pfSense 26.03.1-RELEASE allows an attacker to execute arbitrary code via the pfBlockerNG package
CVE-2026-88996	New	6.1	MEDI		0.003		The WPForms – AI Form Builder for WordPress – Contact Forms, Payment Forms, Survey Form, Quiz & More plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via 'page_title' POST Parameter via {page_title} Smart Tag in all versions up to, and including, 2.0.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated a...
CVE-2026-92212	New	6.1	MEDI		0.002		The JetFormBuilder — Dynamic Blocks Form Builder plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via 'jfb_xss' (URL Query Variable) Parameter via Calculated Field in all versions up to, and including, 3.6.5.3 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in...
CVE-2026-53627	New	6.0	MEDI				GLPI is a free asset and IT management software package. From 11.0.0 until 11.0.8, a low-privileged authenticated user can use the new API (v2) to perform update operations that the same user is normally forbidden to perform through the user interface. The API update flow does not consistently enforce the applicable authorization checks. This issue is fixed in version 11.0.8.
CVE-2026-54790	New	6.0	MEDI				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane stores an administrator-controlled custom_field_table value without validating it against the allowed custom-field table names. Mdl_custom_fields::used() later concatenates that stored value into the FROM table and WHERE column identifier positions...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-66071	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.15 and 4.0.22 and 4.1.11 and 4.2.6 and 4.3.1, Atom exhaustion: OAuth2 JWT tag: scope values. extractscopes/1 parses scopes of the form .tag: and calls rabbitdatacoercion:toatom() to convert to a tag atom. The token signature is verified first, so the attacker cannot forge scopes , but in IdP configurations ...
CVE-2026-66073	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.15 and 4.0.20 and 4.1.11 and 4.2.6, Atom table exhaustion via management API node field. pUT /api/queues/:vhost/:name (and the exchanges and bindings endpoints) accepts a node JSON field. The value goes through rabbitnodes:make → listtoatom with no cluster membership check first. Each unique value permanent...
CVE-2026-67411	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.18, 4.0.23, 4.1.14, 4.2.9, and 4.3.3, native MQTT and MQTT over WebSocket behind a trusted PROXY Protocol frontend could lose the proxy-derived client address before the MQTT authentication path checked loopback_users, causing the frontend-to-broker address to be treated as loopback. An attacker who can rea...
CVE-2026-67412	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 4.3.3, 4.2.9 , 4.1.14, 4.0.24, and 3.13.18, Federation upstream in RabbitMQ skips vhost authorization allowing cross-vhost message access. what the bug lets you do. A policymaker on one vhost reads and drains messages out of another vhost it has no permission on. With the default ack-mode the source messages are...
CVE-2026-67413	New	6.0	MEDI				RabbitMQ is a messaging and streaming broker. From 4.0.0 until 4.0.23, 4.1.14, 4.2.9, and 4.3.3, the optional rabbitmq_jms_topic_exchange plugin's x-jms-topic exchange accepted a client-controlled rjms_erlang_selector binding expression whose LIKE evaluator expanded percent and underscore wildcards into overlapping PCRE fragments. It executed those fragments with raw re:run/...
CVE-2026-80432	New	6.0	MEDI				Missing Authorization in the drop handling path of the drag and drop protocol in kitty from 0.47.0 before 0.49.0 allows a program writing to the terminal to obtain the contents of files dragged over the window even when the user never completes the drop, because drop_enqueue_request() in kitty/dnd.c serves a drag data request without first checking the drop state of the wind...
CVE-2026-100574	New	5.9	MEDI				OpenClaw (npm package 'openclaw') before 2026.8.1 contains a server-side request forgery vulnerability in its trusted-host DNS checks. For fetches that use the trusted-host DNS recheck, a trusted hostname that resolves to an unspecified address (0.0.0.0 or ::) bypasses the SSRF destination validation. An attacker who can influence DNS for an allowed hostname can therefore ca...
CVE-2026-53628	New	5.9	MEDI				GLPI is a free asset and IT management software package. From 0.84 until 10.0.26 and 11.0.8, an administrator holding the Update auth and sync or Update auth, sync and 2FA right can change the authentication method and disable two-factor authentication for user accounts outside the administrator's entity scope. The affected user-account administration flow did not consistent...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67222	New	5.9	MEDI				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.15, 4.0.20, 4.1.11, and 4.2.6, mechanisms/1 applied list_to_atom/1 to every colon-delimited token in an attacker-controlled auth_mechanism value, permanently consuming Erlang VM atoms and allowing the node to be crashed with a large request. Exploitation requires the Shovel or Federation plugin to be in use...
CVE-2026-67227	New	5.9	MEDI				RabbitMQ is a messaging and streaming broker. From 4.0.0 until 4.0.22 and 4.1.14 and 4.2.7 and 4.3.1, Atom exhaustion: toatom on global-parameter :name. resourceexists/2 (and the PUT/DELETE handlers) call rabbitdatacoercion:toatom/1 on the :name URL path segment. toatom/1 uses binarytoatom/2 (unsafe). The endpoint requires policymaker (not management, but below A user with t...
CVE-2026-67415	New	5.9	MEDI				RabbitMQ is a messaging and streaming broker. From 4.2.0 until 4.2.9 and 4.3.3, the Shovel parameter parser converted attacker-controlled runtime parameter values into non-garbage-collected Erlang atoms before bounding them or checking a fixed allowlist. Exploitation requires network access to the Management HTTP API, valid credentials with both the management and policymake...
CVE-2026-86066	New	5.9	MEDI				Horilla is an HR and CRM software. Prior to 2.0.0, approve_validate_attendance_request at /attendance/approve-validate-attendance-request/ changes attendance_validated, is_validate_request_approved, approved_by, and related pending-request state through an HTTP GET before calling attendance.save(), so Django does not require CSRF validation for the action. An unauthenticated...
CVE-2026-91766	New	5.9	MEDI				When the http:// stream wrapper follows a redirect it forwards the user-supplied Authorization, Cookie and Proxy-Authorization headers unchanged, even when the redirect target is a different host, a different port, or a downgrade from HTTPS to HTTP. A server that can steer a redirect therefore receives credentials that were only meant for the original origin. This is the sam...
CVE-2026-92842	New	5.9	MEDI				The convert.base64-encode, convert.quoted-printable-encode and convert.quoted-printable-decode stream filters accept a line-break-chars option whose length is tracked separately from the string itself. The filter constructors duplicate the value with pestrdup(), which stops at the first NUL byte, while keeping the original length. When the filter later emits a line break it ...
CVE-2026-93477	New	5.9	MEDI		0.002		Improperly Controlled Modification of Dynamically-Determined Object Attributes vulnerability in ash-project ash allows a user to set the value of a private action argument on the bulk destroy and bulk update paths. Action arguments declared with public?: false are meant to be set only by trusted server-side code (for example via Ash.Changeset.set_private_argument/3) and mus...
CVE-2026-93682	New	5.8	MEDI				When the HTTP stream wrapper follows a redirect and the response carries a Location header with an empty value, the redirect code reads one byte past the end of the heap buffer holding the location. The value of that out-of-bounds byte decides which redirect target is built, so a malicious server controls whether the client is sent to the host root or to the current directory.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95835	New	5.6	MEDI				Missing Authorization in the askpass escape code handler in kitty from 0.25.0 before 0.49.0 allows a local user other than the one running the terminal to obtain the text typed into a prompt that kitty itself displays, because handle_remote_askpass() in kitty/window.py opens the POSIX shared memory object named in the escape code, parses a prompt definition out of it, and wr...
CVE-2026-100547	New	5.5	MEDI				OpenClaw is a coding agent distributed as the npm package `openclaw`. In affected versions (2026.7.1 through 2026.7.2), alternate but valid `file:` URL spellings supplied over the Agent Client Protocol (ACP) were treated as relative paths and were incorrectly classified as reads scoped to the session working directory. When an operator connected `openclaw acp client` to an u...
CVE-2026-100569	New	5.5	MEDI				OpenClaw is an npm-distributed application. In versions >= 2026.4.25 and < 2026.8.1, the workspace environment-variable filter did not block variables ending in `_ENDPOINT`, so an untrusted workspace `.env` file could set AZURE_SPEECH_ENDPOINT. Azure Speech preferred that value over the configured region, so when a synthesis or voice-list request was made, the attacker-selec...
CVE-2026-100581	New	5.5	MEDI				OpenClaw for iOS before 2026.8.11 stores Gateway credentials as cleartext JSON in App Group UserDefaults instead of the device Keychain. Attackers with access to unencrypted device backups or extracted App Group containers can recover valid Gateway tokens and passwords to authenticate with operator authority.
CVE-2026-12037	New	5.5	MEDI		0.003		The Asset CleanUp: Page Speed Booster plugin for WordPress is vulnerable to Server-Side Request Forgery in all versions up to, and including, 1.4.0.5 via the 'page_url' parameter. This makes it possible for authenticated attackers, with administrator-level access and above, to make web requests to arbitrary locations originating from the web application and can be used to qu...
CVE-2026-97222	New	5.5	MEDI				A heap use-after-free flaw was found in Gnumeric. When a user opens a crafted Gnumeric workbook containing a malformed SheetObjectComponent element, the XML parser can dereference a freed sheet-object component, causing Gnumeric to crash.
CVE-2026-97877	New	5.5	MEDI				A vulnerability was determined in zhistaredu StarTraining up to 3.8.1. This issue affects the function UserLoginService.createToken of the file application.yml of the component JWT Token Handler. This manipulation of the argument user_id/company_id causes use of hard-coded password. The attack is possible to be carried out remotely. The exploit has been publicly disclosed an...
CVE-2026-97878	New	5.5	MEDI				A vulnerability was identified in zhistaredu StarTraining up to 3.8.1. Impacted is the function anonymous of the file /druid/index.html of the component Druid Console. Such manipulation leads to missing authentication. The attack may be performed from remote. The exploit is publicly available and might be used. The vendor was contacted early about this disclosure but did not...
CVE-2026-97879	New	5.5	MEDI				A security flaw has been discovered in zhistaredu StarTraining up to 3.8.1. The affected element is an unknown function of the file SecurityConfig.java of the component api-docs Endpoint. Performing a manipulation results in missing authentication. It is possible to initiate the attack remotely. The exploit has been released to the public and may be used for attacks. The ven...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100303	New	5.4	MEDI				TDuck survey form through 6.0 lacks authorization checks on FormThemeController write endpoints for global form themes and categories. Authenticated non-admin users can add, modify, or delete themes and theme categories affecting forms owned by other users.
CVE-2026-100388	New	5.4	MEDI				RustDesk versions before 1.5.0 fail to properly validate file transfer permissions on incoming file clipboard messages in the Clipdr message handler on Linux and macOS. Authenticated remote peers with disabled file transfer permissions can place files onto the host clipboard and retrieve copied files and contents from the process-wide clipboard cache.
CVE-2026-100524	New	5.4	MEDI				Cotonti through 1.0.0 contains a cross-site request forgery vulnerability in the extensions manager that allows attackers to perform state-changing actions without anti-CSRF token validation. Attackers can craft links or embed images to force administrators to install, update, pause, or unpause extensions by tricking them into visiting a malicious page while authenticated.
CVE-2026-100528	New	5.4	MEDI				OpenClaw (npm package 'openclaw') before 2026.8.1 could send third-party provider credentials to the wrong endpoint. In affected versions, when a third-party provider uses an OpenAI-compatible API and the resolved model metadata lacks a concrete base URL, a pinned session that continues after a model configuration hot reload retains that provider's credential while the OpenA...
CVE-2026-100549	New	5.4	MEDI				OpenClaw versions before 2026.8.1 contain a path traversal vulnerability in QQBot voice attachment handling where filenames are decoded twice, allowing encoded traversal segments to reappear after sanitization. Attackers can supply crafted voice attachments that write files outside the intended staging directory to other process-writable locations.
CVE-2026-100550	New	5.4	MEDI				OpenClaw (npm package 'openclaw') before 2026.8.1 contains an access-control bypass in the Microsoft Teams integration. When groupPolicy is set to allowlist, a missing or unsupported configured access group produces a denied group-resolution result that is not rejected by the final message-admission check, so a Teams member who is not on the allowlist can still trigger the c...
CVE-2026-100562	New	5.4	MEDI				OpenClaw versions before 2026.8.1 contain an authorization bypass vulnerability in the sessions.create endpoint that allows operator.write callers to modify session configurations reserved for operator.admin scope. Attackers with write-scoped credentials can change existing session model, provider, thinking level, and auth-profile settings to redirect traffic and bypass admi...
CVE-2026-100563	New	5.4	MEDI				OpenClaw (npm package 'openclaw') before 2026.8.1 does not neutralize leading characters that spreadsheet applications interpret as formulas when the Control UI exports session data to CSV. Although session labels were quoted as CSV text, a lower-trust participant who can influence a session label or the first user message can place a formula-like cell in the Usage export; i...
CVE-2026-100564	New	5.4	MEDI				OpenClaw versions before 2026.8.1 fail to neutralize spreadsheet formula characters in participant display names within attendance CSV exports. Attackers can inject formula-like cells that execute with spreadsheet user permissions when the export is opened in formula-enabled applications.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100576	New	5.4	MEDI				OpenClaw versions before 2026.8.1 contain a server-side request forgery vulnerability in browser wait predicates that allows attackers to bypass SSRF protections by reaching blocked destinations. Attackers can use the wait --fn function against an existing browser session to request loopback or private destinations without navigation checks applied to other browser actions.
CVE-2026-100593	New	5.4	MEDI				OpenClaw (npm package `openclaw`) before 2026.7.1 does not enforce the documented owner-only requirement for persistent `/activation` policy changes in group channels. An authorized non-owner channel sender can change whether the agent requires mention-based activation, causing the agent to respond more broadly in the group (exposing its responses to additional group traffic...
CVE-2026-93366	New	5.4	MEDI				Bludit CMS through 3.22.0 contains an authorization bypass vulnerability that allows authenticated users with the Author role to enumerate and delete media files belonging to pages owned by other users, including administrators, by supplying arbitrary uuid parameters to unprotected AJAX endpoints. Attackers can retrieve page UUIDs for all users via the content-get-list endpo...
CVE-2026-100230	New	5.3	MEDI				Input Leap (aka input-leap) through 3.0.3, when the non-default --enable-drag-drop option is used on Windows or macOS, mishandles the / versus \ distinction and allows directory traversal, with resultant code execution if a file is written to a startup directory. This occurs via a DDRG message.
CVE-2026-100304	New	5.3	MEDI				TDuck survey form 6.0 contains an information disclosure vulnerability in FormAuthUtils.hasPermission that fails open when a form does not exist, allowing authenticated users to access deleted form submissions. Attackers can read orphaned submission data including personal information by providing a known dataId to the GET /user/form/data/details endpoint after the form has ...
CVE-2026-100306	New	5.3	MEDI				TDuck survey form through 6.0 fails to validate write passwords on submission endpoints, enforcing the check only on the front end. Remote unauthenticated attackers can submit form entries directly to public submission APIs without providing the password by using the form key from share links.
CVE-2026-100378	New	5.3	MEDI				Missing Authorization vulnerability in Wikimedia Foundation Mediawiki - Translate Extension allows Accessing Functionality Not Properly Constrained by ACLs. This issue affects Mediawiki - Translate Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100379	New	5.3	MEDI				Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Wikimedia Foundation Wikipedia Android App allows Accessing/Intercepting/Modifying HTTP Cookies. This issue affects Wikipedia Android App: main.
CVE-2026-100380	New	5.3	MEDI				Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - Wikibase Extension allows Cross-Site Scripting (XSS). This issue affects Mediawiki - Wikibase Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100381	New	5.3	MEDI				Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - UploadWizard Extension allows Cross-Site Scripting (XSS). This issue affects Mediawiki - UploadWizard Extension: from * before 1.46.1, 1.45.5, 1.43.10.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100418	New	5.3	MEDI				Flame through 2.4.0 contains an information exposure vulnerability in the unauthenticated GET /api/config endpoint that returns the entire configuration object without field redaction. Attackers can retrieve the stored weather API key and internal operational settings by sending a single unauthenticated request to consume provider quota or access sensitive configuration data.
CVE-2026-100526	New	5.3	MEDI				OpenClaw's Discord integration (npm package @openclaw/discord) before version 2026.9.3 could lose the sender-scoped media policy in the emoji and sticker upload actions before loading a local file. A sender permitted to invoke those actions could cause OpenClaw to read a host path that the same sender's configured media roots would otherwise reject, placing bytes from an out...
CVE-2026-100527	New	5.3	MEDI				OpenClaw before 2026.8.2 contains a denial of service vulnerability in the Browser extension relay that allows unauthenticated network sources to exhaust pending-authentication capacity. Attackers can hold every pending slot by maintaining silent WebSocket upgrades, preventing paired extensions from completing Browser Relay Authentication v2.
CVE-2026-100533	New	5.3	MEDI				OpenClaw versions before 2026.8.1 contain a path traversal vulnerability in the tools.fs.workspaceOnly feature where Unicode filename fallback can normalize validated parent directory components. Admitted requesters can exploit canonically equivalent sibling directories to read files outside the configured workspace boundary.
CVE-2026-100545	New	5.3	MEDI				OpenClaw (npm package `openclaw`) before 2026.8.1 incorrectly enforces sender tool policies during session-memory filename generation. In affected versions, filename generation created an embedded helper that retained tools which the originating sender's policy had removed. When session-memory filename generation was enabled for an agent reachable by lower-trust senders, mod...
CVE-2026-100548	New	5.3	MEDI				OpenClaw (npm package 'openclaw') versions >= 2026.3.28 and < 2026.8.1 contain a credential exposure issue in memory embedding failover. When remote embedding fallback is configured and the primary embedding provider fails, the request can be sent to a different fallback provider while still reusing the primary provider's configured API key, causing that credential to be tra...
CVE-2026-100571	New	5.3	MEDI				OpenClaw (npm package 'openclaw') versions >= 2026.6.6 and < 2026.8.1 apply the SMS webhook invalid-request rate limit before Twilio signature verification and identify clients only by the raw proxy socket address. In deployments where the SMS/Twilio webhook sits behind a trusted reverse proxy or tunnel so that multiple external clients share one socket address, an unauthent...
CVE-2026-100572	New	5.3	MEDI				OpenClaw versions >= 2026.3.25 and < 2026.8.1 apply invalid-token rate limiting for Synology Chat webhooks before authentication and key the limit on the raw proxy socket address. In deployments where OpenClaw sits behind a trusted reverse proxy or tunnel and multiple external clients share a single socket address, an unauthenticated sender can exhaust the shared invalid-tok...
CVE-2026-45801	New	5.3	MEDI				GLPI is a free asset and IT management software package. From 0.72 until 10.0.26 and 11.0.8, an authenticated user without the required permission can enable debug mode. The affected user-setting update does not enforce the privilege boundary intended to restrict debug-mode activation. This issue is fixed in versions 11.0.8 and 10.0.26.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55217	New	5.3	MEDI				GLPI is a free asset and IT management software package. From 0.85 until 10.0.26 and 11.0.8, a low-privileged authenticated user can create, update, or delete knowledge base comments and translations without the required authorization for the affected content. This issue is fixed in versions 11.0.8 and 10.0.26.
CVE-2026-56728	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, a broken access control vulnerability exists in Zammad's GraphQL API. An authenticated user can access taskbar item data belonging to another user by crafting a request with the target user's taskbar identifier. The taskbar feature stores transient state for active user sessions, including au...
CVE-2026-56732	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, vulnerability in Zammad's HTML sanitization allows injection of specific HTML elements into ticket bodies. When another user views the crafted ticket, the injected element can trigger a logout request, terminating the viewer's session. This vulnerability is fixed in 7.0.2.
CVE-2026-56734	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, during federated authentication (OAuth/OIDC/SAML), a profile image URL from the external identity provider is fetched without verifying the target address. An actor who controls their profile at a connected provider may cause the server to connect to internal network locations. Response timin...
CVE-2026-56735	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2 and 7.1.0, zammad's HTML sanitizer (HtmlSanitizer::Strict) blocks external URLs in to prevent remote content loading, but the srcset attribute, also allowlisted for , is not subject to the same check. This oversight allows an attacker to embed arbitrary external URLs in the srcset attribute j...
CVE-2026-61855	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. In 7.0.3 and 7.1.1, under certain conditions, Zammad's verification of inbound PGP-signed email can mark a message as carrying a valid ("Good") PGP signature from a registered sender key, even though the displayed message content is not actually covered by that signature. As a result, the inbound article may...
CVE-2026-63006	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, attacker-controlled HTML in inbound emails or tickets could bypass the image URL sanitizer using path traversal sequences. When an authenticated agent views the content, the browser resolves the URL to a protected API endpoint and sends the request with the agent's session cookie, enabling si...
CVE-2026-63206	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, zammad's HTML sanitizer, which blocks remote images in ticket articles and email views, can be bypassed using a shortened URL format that omits the double slash after the scheme (for example a shortened HTTP URL instead of a shortened HTTP URL). Modern browsers treat both forms as equivalent ...
CVE-2026-63216	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, unsanitized option labels are rendered in the configuration dialogs of AI Agents within Zammad's admin UI. When rendering the list of selected options, the option label is output as raw HTML without escaping. An attacker who can control an option label, for example by setting a malicious stri...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-80514	New	5.3	MEDI		0.002		The wpForo Forum WordPress plugin from 3.0.0 before 3.1.6 does not verify the source of client-supplied IP address headers before using them to key its per-visitor rate limit on paid AI requests, allowing unauthenticated attackers to bypass the limit by spoofing the header and exhaust the site owner's metered AI credits.
CVE-2026-84460	New	5.3	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, any authenticated user can call the REST endpoint for getting a tag list and receive the tag names for the given ticket, regardless of whether they have access to that ticket. Tags are an internal categorization feature and may contain sensitive labels. Ticket IDs are sequential integers, mak...
CVE-2026-85290	New	5.3	MEDI				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane's Cron::recur() method writes an invalid cron key from the URL path directly to the application log without neutralizing CRLF characters. An unauthenticated requester can place forged log lines into the audit trail by supplying a crafted cron_key v...
CVE-2026-86837	New	5.3	MEDI		0.002		The Bookly WordPress plugin before 28.3 does not properly verify a customer's identity before updating their stored details, allowing unauthenticated attackers who know a customer's primary identifier to overwrite that customer's stored personal information such as name, email and address.
CVE-2026-92799	New	5.3	MEDI		0.003		The Online Scheduling and Appointment Booking System – Bookly plugin for WordPress is vulnerable to Authorization Bypass via PHP Type Juggling in all versions up to, and including, 28.2. This is due to the `postValidateCustomer()` function using a loose PHP inequality operator (`!=`) to compare the session-stored one-time verification code against the attacker-supplied `veri...
CVE-2026-93363	New	5.3	MEDI				The @payloadcms/storage-vercel-blob storage adapter for Payload contains an improper access control vulnerability that allows authenticated users to bypass collection-level permissions by accessing the client-upload route directly. Attackers can upload files through the client-upload endpoint without possessing the required collection access permissions, circumventing the in...
CVE-2026-93364	New	5.3	MEDI				Bludit CMS through 3.22.0 contains a mass assignment vulnerability that allows authenticated users with the Author role to modify privileged page fields reserved for administrators by injecting reserved parameters into a content save request. Attackers can submit reserved fields such as type and username through the Pages::edit() function in bl-kernel/pages.class.php, which ...
CVE-2026-97864	New	5.3	MEDI				A vulnerability has been found in GibbonEdu Gibbon up to 30.0.01. The affected element is the function makeBlock of the file modules/Planner/units_add_blockAjax.php of the component Unit Planner. The manipulation of the argument gibbonUnitBlockID/mode leads to missing authentication. The attack is possible to be carried out remotely. The exploit has been disclosed to the pub...
CVE-2026-100174	New	5.1	MEDI				The AIL Framework tag selector component (var/www/static/js/tags.js) is vulnerable to stored cross-site scripting (XSS). A user with the ability to create a custom tag could embed an HTML payload containing JavaScript event handlers (e.g., or <svg onload=...>) in the tag name. When another authenticated user opened a page containing the tag selec...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100373	New	5.1	MEDI				OpenMetadata through 2.0.2 contains a server-side request forgery vulnerability in the URLValidator.validateURL function that fails to properly resolve DNS hostnames and validate internal addresses. Users permitted to create or update EventSubscription can set webhook destinations to internal hosts, allowing the server to send requests to private networks and cloud metadata ...
CVE-2026-56726	New	5.1	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, this vulnerability breaks normal ticket isolation boundaries between agents. Any authenticated agent, even one with no active tickets assigned to them, can view the titles, status, labels, and URL links of GitHub/GitLab issues attached to any ticket in the system. This allows an internal user...
CVE-2026-6082	New	5.1	MEDI		0.002		Stored Cross-Site Scripting (XSS) vulnerability in StockAgile API and management panel. The vulnerability is present on the server side in REST endpoint '/inventory/configuration/payment-methods' that allow the injection and persistence of malicious JavaScript code through parameters such as 'code', 'name', and other text fields. The scripts that are entered are not filtered...
CVE-2026-6083	New	5.1	MEDI		0.002		Stored Cross-Site Scripting (XSS) vulnerability in StockAgile API and management panel. The vulnerability is present on the server side in REST endpoint '/inventory/configuration/pricing-tiers' that allow the injection and persistence of malicious JavaScript code through parameters such as 'code', 'name', and other text fields. The scripts that are entered are not filtered ...
CVE-2026-6084	New	5.1	MEDI		0.002		Stored Cross-Site Scripting (XSS) vulnerability in StockAgile API and management panel. The vulnerability is present on the server side in REST endpoint '/inventory/configuration/variants' that allow the injection and persistence of malicious JavaScript code through parameters such as 'code', 'name', and other text fields. The scripts that are entered are not filtered or val...
CVE-2026-6085	New	5.1	MEDI		0.002		Stored Cross-Site Scripting (XSS) vulnerability in StockAgile API and management panel. The vulnerability is present on the server side in REST endpoint '/inventory/configuration/serial-number-types' that allow the injection and persistence of malicious JavaScript code through parameters such as 'code', 'name', and other text fields. The scripts that are entered are not filt...
CVE-2026-6086	New	5.1	MEDI		0.002		Stored Cross-Site Scripting (XSS) vulnerability in StockAgile API and management panel. The vulnerability is present on the server side in REST endpoint '/inventory/configuration/serial-number-types' that allow the injection and persistence of malicious JavaScript code through parameters such as 'code', 'name', and other text fields. The scripts that are entered are not filt...
CVE-2026-6087	New	5.1	MEDI		0.002		Stored Cross-Site Scripting (XSS) vulnerability in StockAgile API and management panel. The vulnerability is present on the server side in REST endpoint '/inventory/configuration/categories' that allow the injection and persistence of malicious JavaScript code through parameters such as 'code', 'name', and other text fields. The scripts that are entered are not filtered or v...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-6088	New	5.1	MEDI		0.002		Stored Cross-Site Scripting (XSS) vulnerability in StockAgile API and management panel. The vulnerability is present on the server side in REST endpoint '/inventory/configuration/categories' that allow the injection and persistence of malicious JavaScript code through parameters such as 'code', 'name', and other text fields. The scripts that are entered are not filtered or v...
CVE-2026-63205	New	5.1	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, when creating or updating an email signature, Zammad processes inline images referenced in the signature body. If a signature body contains an HTML img tag pointing to any existing attachment, the system copies that attachment into a new signature-owned record, without checking whether the us...
CVE-2026-63208	New	5.1	MEDI				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, when a Microsoft Graph request fails, Zammad logs the error including the authentication token used to access the mailbox. The system attempts to hide this token in the log, but the masking is incomplete: for the token format Microsoft uses (JWT), only the first part is hidden, while the rema...
CVE-2026-67407	New	5.1	MEDI				RabbitMQ is a messaging and streaming broker. From 4.0.0 until 4.3.3 and 4.2.9 and 4.1.14 and 4.0.23, Incomplete fix for CVE-2026-44838: escaperegexchar/1 does not escape -, leaving room for an MQTT topic permission bypass. the CVE-2026-44838 fix made expandtopicpermission/2 escape regex metacharacters in expanded topic-permission variables (escaperegex(V)), but escaperegexc...
CVE-2026-100502	New	5.0	MEDI				Flame through 2.4.0 contains an insufficient session expiration vulnerability in the login endpoint that allows attackers with former admin access to obtain tokens with arbitrary lifespans by supplying unvalidated duration parameters. Attackers can mint near-permanent administrator tokens that survive password changes, retaining full control of the dashboard since tokens are...
CVE-2026-17602	New	4.9	MEDI		0.006		The SSL Zen — SSL Certificate Installer & HTTPS Redirects plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 4.7.42 via the 'file_name' parameter parameter. This makes it possible for authenticated attackers, with administrator-level access and above, to read the contents of arbitrary files on the server, which can contain sensi...
CVE-2026-39372	New	4.9	MEDI				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane stores and serves uploaded image attachments without stripping EXIF metadata. When an administrator uploads an image through invoice attachments, quote attachments, or another attachment feature and shares it with another user, the recipient can re...
CVE-2026-100376	New	4.8	MEDI				Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - TemplateSandbox Extension allows Cross-Site Scripting (XSS). This issue affects Mediawiki - TemplateSandbox Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100383	New	4.8	MEDI				Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - WikiLambda Extension allows Cross-Site Scripting (XSS). This issue affects Mediawiki - WikiLambda Extension: 1.47.0-alpha. The issue has been remediated on the `master` branch.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-27867	New	4.8	MEDI				An attacker with access via network to the Regesta Smart HD-PLC of the provider Teldat (in this case, registration action is required) who has the vulnerable firmware version could inject a specific payload via the parameter "cmdcookie" withing the /upgrade/index.html resulting in to a Cross-Site Scripting (XSS). This issue affects Regesta Smart HD-PLC - TLDPH16D2: 11.02.06...
CVE-2026-67241	New	4.8	MEDI				RabbitMQ is a messaging and streaming broker. From 4.2.0 until 4.2.9 and 4.3.3, AMQP 1.0 management exchange.declare skips alternate-exchange permission check. pUT /exchanges/:name (lines 192-240) checks only configure on the declared exchange and passes XArgs straight to rabbitexchange:declare/7. It omits the checkreadpermitted(X) + checkwritepermitted(AE) that rabbitchanne...
CVE-2026-85292	New	4.8	MEDI				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2, InvoicePlane's User_Controller compares the session user_type value with the required role by using PHP's loose inequality operator. Under a non-standard session backend that returns unexpected scalar types, type juggling can cause a value that is not strictly ...
CVE-2026-85293	New	4.8	MEDI				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. In version 1.7.2-beta-1, InvoicePlane stores client_email values without enforcing email syntax and renders them unescaped inside double-quoted value attributes in the invoice mailer form and quote mailer form. An administrator who can edit a client can store attribute-breakin...
CVE-2026-49469	New	4.6	MEDI				GLPI is a free asset and IT management software package. From 0.70 until 10.0.26 and 11.0.8, an authenticated hotliner or technician can submit crafted criteria through the user import feature to bypass the configured default LDAP filter. This allows access to LDAP objects that the default filter was intended to exclude. This issue is fixed in versions 11.0.8 and 10.0.26.
CVE-2026-67406	New	4.6	MEDI				RabbitMQ is a messaging and streaming broker. From 4.0.0 until 4.3.3, 4.2.9, 4.1.14, and 4.0.23, Shovel does not format state logged by the crash reporter and can leave unencrypted credentials in a crash dump file. the shovel worker genserver processes does not implement the formatstatus/2 callback. When these processes crash (e.g., due to network partitions, connection fail...
CVE-2026-80430	New	4.6	MEDI				Improper Link Resolution Before File Access in the drag source staging path of the drag and drop protocol in kitty from 0.47.0 before 0.49.0 allows a program writing to the terminal to create files and directories at paths outside the staging directory, because subdir_data_for_drag() in kitty/dnd.c resolves a descendant of the staged item tree by constructing a path string a...
CVE-2026-95834	New	4.6	MEDI				Use After Free in the drag source path of the drag and drop protocol in kitty from 0.47.0 before 0.49.0 allows a program writing to the terminal to cause the terminal to read from and write to freed heap memory, because drag_remote_file_data() in kitty/dnd.c holds a DragRemoteItem pointer into an array it does not own, calls toplevel_data_for_drag() or subdir_data_for_drag()...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67421	New	4.5	MEDI				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.19, 4.0.24, 4.1.15, 4.2.10, and 4.3.5, RabbitMQ Management rendered an AMQP authorization-error reason containing an attacker-controlled queue name as HTML when the OAuth management UI was enabled. Exploitation requires an attacker with queue configure permission, a management administrator who can see but ...
CVE-2026-100505	New	4.4	MEDI				Ghidra versions 11.2 through 12.1.4 contain a heap out-of-bounds read vulnerability in StringManager::getCodepoint when decoding multi-byte UTF-8, UTF-16, or UTF-32 characters without validating remaining buffer length. Attackers can craft malicious binaries with constant byte stores ending in multi-byte lead units to trigger out-of-bounds reads that crash the decompiler or ...
CVE-2026-100305	New	4.3	MEDI				TDuck survey form through 6.0 fails to enforce form fill-in restrictions on the authenticated submission endpoint POST /user/form/data/create. Authenticated attackers who know a form's key can submit unlimited entries to any form, bypassing publish status, time window, quota, and per-IP restrictions to falsify collected results.
CVE-2026-100525	New	4.3	MEDI				The OpenClaw Prometheus diagnostics plugin (@openclaw/diagnostics-prometheus) before version 2026.9.3 does not enforce the operator.read scope on its authenticated metrics endpoint. In deployments using an identity-bearing Gateway authentication mode such as trusted-proxy, a caller whose effective role has no read scope can retrieve the diagnostics document even though ordin...
CVE-2026-100553	New	4.3	MEDI				OpenClaw versions >= 2026.6.9 and < 2026.8.1 do not declare the native chatId parameter as a delivery target in the Feishu unpin feature, so unpin requests can bypass the shared same-provider cross-context target check. When tools.message.crossContext.allowWithinProvider is disabled, an admitted (authenticated) sender can remove a pin from another Feishu group that the sende...
CVE-2026-100583	New	4.3	MEDI				OpenClaw Discord versions before 2026.7.1 contain an authorization bypass vulnerability in guild metadata read actions that allows lower-trust senders to retrieve information excluded by channel allowlists. Attackers can bypass the configured Discord read-target policy to access guild metadata from servers or channels outside the operator's allowlist.
CVE-2026-100590	New	4.3	MEDI				OpenClaw before 2026.7.1 contains an authorization bypass vulnerability in the /voice set command that allows non-owner external-channel senders to persist Gateway voice configuration. Attackers with command access can change the voice used by Talk responses for the configured provider, affecting configuration integrity without exposing credentials or granting additional hos...
CVE-2026-19775	New	4.3	MEDI		0.002		The OpenStation — Desktop Windows, Dock & Virtual Desktops for WP Admin plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 1.1.7. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for authenticated attackers, with custom-level access and above, to read the titl...
CVE-2026-6103	New	4.3	MEDI				phar_tar_number() parses the octal size field of a TAR header into a uint32_t with no overflow check. The field is 11 octal digits wide and holds values up to 0xFFFFFFFF, so a size above 0xFFFFFFFF silently wraps. The parser then skips the wrong number of data blocks and interprets attacker-controlled file content as the next TAR header, which lets a crafted archive inject ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91769	New	4.3	MEDI				PHP's OpenSSL stream peer verification checks the certificate's subjectAltName entries first and, whenever no entry matches, falls back to the Common Name. RFC 6125 requires the CN to be ignored once the certificate presents any service identity, so a certificate carrying a non-matching DNS SAN was still accepted when its CN matched the requested peer_name. A certificate tru...
CVE-2026-92829	New	4.3	MEDI		0.003		The Blog2Social: Social Media Auto Post & Scheduler plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 9.1.0. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for authenticated attackers, with contributor-level access and above, to view, modify, or delete othe...
CVE-2026-97469	New	4.3	MEDI				PostgreSQL Anonymizer contains a vulnerability that allows unprivileged masked users to repeatedly call the anon.hash() function and collects (seed, hash_output) pairs to perform an offline brute-force attack and deduce the salt. A masked role can run a RESTRICTED function when the call is placed inside the sub-select. The problem is resolved in PostgreSQL Anonymizer 3.2.3 a...
CVE-2026-100554	New	4.2	MEDI				OpenClaw (npm package 'openclaw') versions >= 2026.5.12 and < 2026.8.1 do not immediately invalidate Canvas HTTP authorization when a paired node is revoked. Node revocation invalidates the WebSocket client, but Canvas HTTP authorization continues to accept and renew the previously granted capability until WebSocket close cleanup completes. As a result, a revoked paired node...
CVE-2026-88848	New	4.2	MEDI		0.001		The MasterStudy LMS WordPress plugin from 1.9 before 3.7.50 does not verify that a course a member asks to enrol in is covered by their membership plan, nor that the plan identifier submitted with the request is one they actually hold, allowing any member to enrol themselves into restricted paid courses outside their plan and beyond the number of courses it entitles them to.
CVE-2026-78394	New	4.1	MEDI		0.002		The Link Library WordPress plugin before 7.9.6 does not sanitize a user-supplied destination folder before writing a generated image to disk, allowing users with the Contributor role and above to create directories and write or overwrite image files anywhere the web server can write, including outside the site's document root. The written file name is always numeric with a ...
CVE-2026-78397	New	4.0	MEDI		0.001		The Link Library WordPress plugin before 7.9.6 does not validate the destination of a user-supplied URL before falling back to an unprotected fetch when its safe request is rejected, allowing unauthenticated visitors to make the site issue requests to hosts on its internal network and to learn from the response whether an internal service answered. Versions below 7.8.8 are ...
CVE-2026-97896	New	3.5	LOW				A vulnerability was identified in krayin laravel-crm up to 2.2.5. This vulnerability affects the function ConfigurationForm::rules of the file packages/Webkul/Admin/src/Http/Requests/ConfigurationForm.php of the component Upload Functionality. The manipulation leads to cross site scripting. The attack is possible to be carried out remotely. The exploit is publicly available ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97897	New	3.5	LOW				A security flaw has been discovered in Krayin laravel-crm up to 2.2.5. This issue affects some unknown processing of the file Sanitizer.php of the component TinyMCE Media Upload. The manipulation results in cross site scripting. The attack may be performed from remote. Upgrading to version 2.2.6 is capable of addressing this issue. The patch is identified as 734aa10ae6c2ffa4...
CVE-2025-1218	New	3.4	LOW				The mysqlnd wire protocol parser reads fields out of server packets before checking that the packet still holds enough bytes for them. A malicious or compromised MySQL server can send a truncated packet and make the client read past the end of the packet buffer, which is undefined behaviour and can crash the process.
CVE-2026-100503	New	3.3	LOW				Ghidra versions through 12.1.4 contain a heap use-after-free vulnerability in the decompiler's Funcdata::opInsertAfter function caused by stale INDIRECT effect-op references. Attackers can craft a malicious binary with a specific x86-64 sequence that triggers the vulnerability during decompilation, causing the decompile helper process to crash and denying service to analysts...
CVE-2026-100573	New	3.3	LOW				OpenClaw versions before 2026.8.1 contain a sandbox policy bypass vulnerability in the MCP loopback component that allows sandboxed coding-agent sessions to invoke tools explicitly denied by sandbox.tools.deny policy. Attackers can list and invoke denied tools to access data or perform actions the operator intended to exclude from the sandbox.
CVE-2026-100417	New	3.1	LOW				RustDesk before 1.5.0 on Windows fails to enforce the one-way file transfer option against peer clipboard file requests, allowing authenticated peers to read files from the host clipboard. Attackers can send FormatDataRequest and FileContentsRequest messages to retrieve copied files by guessing the FileGroupDescriptorW format identifier.
CVE-2026-100534	New	3.1	LOW				OpenClaw versions before 2026.8.1 contain an authorization bypass vulnerability in webhook TaskFlow cancellation that allows attackers to cancel unrelated sessions. An attacker with a webhook route secret can supply an arbitrary child session key to cancel ACP or subagent work outside the route's configured authority.
CVE-2026-100537	New	3.1	LOW				OpenClaw (npm package 'openclaw') before 2026.8.1 fails to apply the originating requester's effective tool policy during Active Memory automatic recall. In deployments that use Active Memory together with requester-specific tool rules, deterministic and hidden recall paths can retrieve durable memory and inject it into the agent's context even when toolsBySender explicitly ...
CVE-2026-100542	New	3.1	LOW				OpenClaw (npm package 'openclaw') versions >= 2026.5.28 and < 2026.8.1 mishandle archive listings in the tar.bz2 skill installer: bounded command-output suffixes were treated as complete listings of the archive. A crafted .tar.bz2/.tbz2 skill archive can push prohibited entries out of both retained listings so that entry-count and size checks pass, and the archive is then ex...
CVE-2026-97866	New	2.9	LOW				A weakness has been identified in Zhonglun CloudPOS 3.0. Affected by this vulnerability is an unknown functionality of the file Program.cs of the component Automatic Update. Executing a manipulation of the argument version/url/packagekey/package name can lead to channel accessible by non-endpoint. The attack can be launched remotely. Attacks of this nature are highly complex...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97228	New	2.7	LOW				Rapid7 Bulk Export MCP versions 0.2.5 through 0.6.1 suffer from a GraphQL query injection issue in the export-status component (<code>`get_export_status`</code> in <code>`src/export_manager.py`</code>), whereby the <code>`export_id`</code> value — an unvalidated MCP tool argument reaching the function via the <code>`check_rapid7_export_status`</code> and <code>`download_rapid7_export`</code> tools — is interpolated directly into the Graph...
CVE-2026-97721	New	2.7	LOW		0.002		A weakness has been identified in Sanluan PublicCMS up to 6.202506.e. This vulnerability affects the function <code>CmsContentAdminController</code> of the file <code>publiccms-parent/publiccms-core/src/main/java/com/publiccms/controller/admin/sys/SysUserAdminController.java</code> of the component <code>exportExcel/exportData</code> . This manipulation of the argument <code>userId/deptId</code> causes authorization bypass. It...
CVE-2026-100539	New	2.6	LOW				OpenClaw (npm package 'openclaw') before 2026.8.1 fails to revoke memory tool access when an operator hot-disables memory configuration. Existing <code>memory_search</code> and <code>memory_get</code> tool instances retain the enabled configuration captured at creation time because the execution-time resolver treats explicit disablement like an unavailable configuration snapshot and restores the stal...
CVE-2026-75553	New	2.4	LOW		0.001		Smartphone application Tohoku Electric Power "Yorisou e Net" uses a hard-coded cryptographic key, which may allow an attacker to retrieve a hard-coded cryptographic key from the affected product.
CVE-2026-63204	New	2.3	LOW				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, an authenticated user with agent permissions can supply an arbitrary AI analytics run identifier to the ticket summarize endpoint and receive the AI provider error message stored for that run, even if the run belongs to a ticket the agent is not authorized to access. The disclosure is limited...
CVE-2026-65828	New	2.3	LOW				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, the legacy <code>destroy_form</code> action on <code>AttachmentsController</code> deletes <code>UploadCache Store</code> records based solely on a user-supplied <code>form_id</code> without verifying that the requesting user owns those records. An authenticated attacker who learns another user's pending-upload UUID can silently remove temporar...
CVE-2026-67234	New	2.3	LOW				RabbitMQ is a messaging and streaming broker. From 4.2.0 until 4.2.8 and 4.3.2, <code>get_auth_mechanism/1</code> used <code>term_to_binary/1</code> on the <code>strict_auth_mechanism</code> or <code>preferred_auth_mechanism</code> atom when clearing the corresponding cookie, producing a non-ASCII cookie name that violates RFC 6265 and can prevent the browser from deleting the preference. The issue is not directly exploitable...
CVE-2026-67420	New	2.3	LOW				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.19, 4.0.24, 4.1.15, 4.2.10, and 4.3.5, RabbitMQ OAuth credential refresh retains revoked runtime tags. when an existing AMQP connection refreshes from an OAuth token that grants the impersonator tag to a valid same-username token that no longer grants that tag, RabbitMQ updates the OAuth backend implementat...
CVE-2026-92106	New	2.3	LOW		0.005		Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in dashbitco <code>lazy_html</code> allows mutation XSS via a parse and serialize round-trip of attacker-supplied HTML. <code>LazyHTML.to_html/2</code> and <code>LazyHTML.Tree.to_html/2</code> decide whether to escape an element's text from its tag name alone. A style or script element inside SVG or MathML foreign ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96874	New	2.3	LOW				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in the Mediawiki - Cargo extension allows Stored XSS. This issue affects Mediawiki - Cargo extension: through 3.9.4.
CVE-2026-56729	New	2.1	LOW				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, when multiple KB categories have different editor roles assigned, a user with knowledge_base.editor in one category can see answer titles and updated_at timestamps from categories they do not have editor access to , via the global quick search. Category names are not leaked, and opening the a...
CVE-2026-56730	New	2.1	LOW				Zammad is a web based open source helpdesk/customer support system. Prior to 7.0.2, an authorization bypass vulnerability was found that allows an authenticated agent to read knowledge base answer content they should not be able to access. The vulnerable GraphQL mutation is meant to transform a knowledge base answer suggestion so it can be inserted into the ticket editor, bu...
CVE-2026-66078	New	2.1	LOW				RabbitMQ is a messaging and streaming broker. From 3.13.0 until 3.13.15 and 4.0.20 and 4.1.11 and 4.2.6, protected tag bypass via bulk-delete. dDELETE /api/users/:name refuses to delete users tagged protected (rabbitmqmtwmuser:deleteresource/2 checks isprotecteduser). POST /api/users/bulk-delete iterates the supplied username list and calls rabbitauthbackendinternal:deleteuse...
CVE-2026-97884	New	2.1	LOW				A vulnerability was detected in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbf3300d60c3494db3fb95b66e7be. This impacts an unknown function of the file updatestudent.php of the component Student Update Functionality. The manipulation of the argument eno results in sql injection. The attack can be launched remotely. The exploit is now public and may be used. This...
CVE-2026-97868	New	2.0	LOW				A security vulnerability has been detected in sheshbabu zen up to 1.5.0. Affected by this issue is the function dangerouslySetInnerHTML of the file features/notes/NotesEditor.jsx of the component Note Editor. The manipulation leads to cross site scripting. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted ...
CVE-2026-97869	New	1.2	LOW				A flaw has been found in langchain4j up to 1.5.3-beta10/1.11.10-beta18/1.18.1-beta27. This vulnerability affects the function AgenticScopeSerializer.fromJson of the file AgenticScopeJsonSerializationIT.java of the component LangChain4j-agentic. This manipulation causes deserialization. Remote exploitation of the attack is possible. The attack's complexity is rated as high. I...
CVE-2026-100070	New						In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_nat_sip: rewind offset when NAT shrinks the packet sashiko says: If map_addr() changes the packet length, such as when the public NAT IP string is shorter or longer than the internal IP, coff will still point to the offset relative to the pre-mangled packet. If the packet shrinks, coff co...
CVE-2026-100071	New						In the Linux kernel, the following vulnerability has been resolved: net: hsr: free learned nodes on device setup failure hsr_dev_finalize() can fail after a lower-device RX handler has already been registered (slave A is added before the failable slave B and interlink adds). RX handlers run in softirq regardless of the master's state, so frames received in that window can ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100072	New						In the Linux kernel, the following vulnerability has been resolved: ACPI: platform: Use acpi_bus_get_primary_device() The acpi_get_first_physical_node() usage in acpi_platform_fill_resource() and acpi_create_platform_device() is generally unsafe because in theory the device returned by it may be freed at any time [1]. It is also inefficient because acpi_get_first_physical...
CVE-2026-100073	New						In the Linux kernel, the following vulnerability has been resolved: ext4: fix transaction overflow during writeback Commit 95ad8ee45cdb ("ext4: correct the reserved credits for extent conversion") was correct to note that we need to reserve enough credits for all extents possibly underlying a large folio. However it was too eager to reduce the number of reserved credits. E...
CVE-2026-100074	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark bpf_refcount field as unique BPF_REFCOUNT is not marked as a unique field, while it should be. Fix this oversight.
CVE-2026-100076	New						In the Linux kernel, the following vulnerability has been resolved: staging: rtl8723bs: fix xmit_frame/xmit_buf leaks on mgnt-frame error paths issue_beacon(), issue_probersp() and issue_asocrsp() obtain a management xmit_frame together with its xmit_buf from the driver's fixed-size management-TX pools via alloc_mgtxmitframe(). On the normal path the frame is handed to dum...
CVE-2026-100077	New						In the Linux kernel, the following vulnerability has been resolved: drm/msm: Recover HW before retire hung submit During recovery, it is not safe to retire the hung submit before we recover the GPU. Retiring the submit triggers BO free and that can result in GPU pagefaults since the GPU may be actively accessing those BOs. To fix this, retire the submits after gpu recover...
CVE-2026-100078	New						In the Linux kernel, the following vulnerability has been resolved: wifi: iwlwifi: mei: pass correct argument to function The first argument to iwl_mei_write_cyclic_buf() should be the cldev but the q_head pointer is passed instead. Fix it.
CVE-2026-100079	New						In the Linux kernel, the following vulnerability has been resolved: usb: typec: ucsi: unregister debugfs entries on teardown ucsi_register() creates per-instance debugfs entries, but ucsi_unregister() keeps them around until ucsi_destroy(). Drivers like ucsi_glink that unregister/register the same UCSI instance across remoteproc restart then try to create an already exist...
CVE-2026-45234	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-45235	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-45236	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-45237	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-45238	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-45239	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-45240	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-45241	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-49117	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-49118	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-51772	New						A Server-Side Request Forgery (SSRF) vulnerability exists in the Image API (v2) of OpenStack Glance. When the show_multiple_locations configuration option is enabled in glance-api.conf, an authenticated attacker can manipulate the locations attribute of an image in the queued state by sending a crafted HTTP PATCH request
CVE-2026-53971	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-53972	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-53973	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-53990	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-57861	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-57864	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-60096	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-60097	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-60098	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-60099	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-60100	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-60101	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-7799	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-7800	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-86439	New		HIGH		0.011	npm:knowns	## Overview Verified. Multiple **Unrestricted Path Traversal** vulnerabilities exist in the Knowns MCP `docs` and `memory` tools, allowing arbitrary file read, write, and deletion operations outside the project sandbox. The storage layer functions (`Get`, `Create`, `Update`, `Rename`, `Delete`) in both `doc_store.go` and `memory_store.go` concatenate user-controlled paths w...
CVE-2026-88389	New						Espruino 2v29 (commit bffc6d0) contains a NULL pointer dereference vulnerability in jslGetRawString() in src/jslex.c. Crafted raw/binary string input can cause the lexer to pass a NULL iterator target to jsvLockAgain(). In RELEASE/NO_ASSERT builds, the missing assertion guard allows a write through the NULL pointer, resulting in memory corruption and application termination ...
CVE-2026-88420	New						A reflected cross-site scripting (XSS) vulnerability in the EntryAbstract.save() component of APSL puput v1.2.1 through v2.2.0 allows authenticated attackers with Wagtail Editor privileges to execute arbitrary code in the context of the victim's browser via a crafted payload.
CVE-2026-92564	New				0.002		A pre-authentication attacker could leverage type nesting to cause a StackOverflowError potentially leading to denial of service. This issue affects Apache Qpid Broker-J: through 10.1.0. Users are recommended to upgrade to version 10.1.1, which fixes the issue.
CVE-2026-9313	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-9652	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-9655	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-97522	New						In the Linux kernel, the following vulnerability has been resolved: mptcp: fix bad accounting in __mptcp_subflow_push_pending() If __subflow_push_pending() errors out we should avoid updating the copied byte counters, to avoid mismatch push call later on.
CVE-2026-97526	New						In the Linux kernel, the following vulnerability has been resolved: s390/pai: Support CPU hotplug for PMU PAI The command 'perf stat -e pai_crypto/CRYPTO_ALL/ -- <command>' crashes the kernel when CPUs are hotplug added during that run. Root cause is the missing allocation of per-CPU data structures for that new CPU. The allocation is dynamic and the first event that has ...
CVE-2026-97529	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Validate BSG request_len before reading vendor_cmd[] The FC BSG transport allocates job->request via memdup_user() using the exact user-supplied request_len. For FC_BSG_HST_VENDOR, fc_bsg_host_dispatch() only guarantees request_len covers msgcode and vendor_id; it does not account for the ve...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97530	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix soft lockup polling continuation IOCB signature qla27xx_copy_multiple_pkt() and qla27xx_copy_fpin_pkt() poll rsp_q->ring_ptr->signature for RESPONSE_PROCESSED (0xDEADDEAD) to decide whether the next continuation IOCB has arrived, spinning on cpu_relax() without advancing the ring or decr...
CVE-2026-97532	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Null out freed pointers in qla2x00_mem_alloc() error path When qla2x00_mem_alloc() fails, qla2x00_probe_one() jumps to probe_hw_failed and calls qla2x00_mem_free(). Several error labels in qla2x00_mem_alloc() freed adapter members (elsrej.c, purex_dma_pool, flt, sfp_data, loop_id_map, async_...
CVE-2026-97533	New						In the Linux kernel, the following vulnerability has been resolved: x86/mm/pat: Acquire init_mm read lock on attribute changes to avoid UAF A previous commit protected against races between ptdump and CPA collapse, however one still exists between attribute changes and collapse as reported by Denis V. Lunev (linked). When an attribute change arises, a lockless page table ...
CVE-2026-97534	New						In the Linux kernel, the following vulnerability has been resolved: f2fs: accurately adjust free_sections during free_segment_range In free_segment_range(), MAIN_SECS(sbi) is temporarily reduced by `secs` to restrict block allocation to the safe remaining main area while valid blocks in the truncated range are evacuated by GC. However, FREE_I(sbi)->free_sections tracks th...
CVE-2026-97535	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Bound VP index against VP_CTRL IOCB bitmap size The VP control IOCB selects its target virtual port by setting one bit in vp_idx_map, a fixed 16-byte (128-bit) array in both vp_ctrl_entry_24xx and vp_ctrl_entry_24xx_ext. qla25xx_ctrlvp_iocb() computes map = (vp_index - 1) / 8 and writes vce-...
CVE-2026-97537	New						In the Linux kernel, the following vulnerability has been resolved: scsi: qla2xxx: Fix queue teardown NULL dma_free and bitmap locking qla25xx_free_req_que() and qla25xx_free_rsp_que() have two pre-existing bugs exposed on the error path of qla25xx_create_{req,rsp}_que(): 1. When dma_alloc_coherent() fails during queue creation, the error path calls the free function...
CVE-2026-97538	New						In the Linux kernel, the following vulnerability has been resolved: hwmon: (asus_rog_ryujin) Validate HID report lengths rog_ryujin_raw_event() parses response headers and payload fields without first checking that they are present in the received report. A short report can therefore make the driver consume uninitialized bytes from the HID transport buffer and expose them ...
CVE-2026-97539	New						In the Linux kernel, the following vulnerability has been resolved: usb: xusbatm: don't rely on id table pointer arithmetic The current code is broken when dynamic ID is involved; in such cases usb_device_id parameter of probe lives on the heap and the pointer arithmetic will get an index that is wildly out of bound. xusbatm initialize the USB device IDs dynamically so it ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97540	New						In the Linux kernel, the following vulnerability has been resolved: net: usb: pegasus: don't rely on id table pointer arithmetic The current code is broken when dynamic ID is involved; in such cases usb_device_id parameter of probe lives on the heap and the pointer arithmetic will get an index that is wildly out of bound. Instead of keeping a side table for additional info...
CVE-2026-97541	New						In the Linux kernel, the following vulnerability has been resolved: wifi: ath9k_htc: don't store usb_device_id usb_device_id is not guaranteed to live longer than probe due to presence of dynamic ID. All information apart from driver_data can be easily retrieved from usb_device, so just store driver_data.
CVE-2026-97542	New						In the Linux kernel, the following vulnerability has been resolved: xfs: bail out on bitmap errors in xrep_agfl_fill LOLLN also points out that the xagb_bitmap_set call in xrep_agfl_fill can fail, but we don't check the result of xagb_bitmap_walk, so we silently drop the error and proceed with inconsistent incore data. That shouldn't be allowed.
CVE-2026-97543	New						In the Linux kernel, the following vulnerability has been resolved: xfs: destroy seen inode bitmap when we fail to add a dirpath LOLLN observes a memory leak in xchk_dirtree_create_path if we create the directory path object but appending the name to the path fails. When this happens, we don't tear down the (empty) seen inode bitmap. This is a pretty trivial error, but let...
CVE-2026-97544	New						In the Linux kernel, the following vulnerability has been resolved: xfs: don't leak dqacct if rhashtable insertion fails LOLLN observes that xqcheck_mod_live_ino_dqtrx doesn't free the newly allocated dqa object if rhashtable insertion fails. Fix this leak.
CVE-2026-97545	New						In the Linux kernel, the following vulnerability has been resolved: xfs: don't leak new_bp if xfs_btree_bload_drop_buf fails LOLLN observes that in xfs_btree_bload_prep_block, xfs_btree_bload_drop_buf can hit an IO error if writing the delwri buffer list to disk fails. In this case, we fail to release new_bp, which means we lose a locked buffer. Fix that.
CVE-2026-97546	New						In the Linux kernel, the following vulnerability has been resolved: xfs: don't spin forever on zero-length dirents when salvaging them LOLLN noticed that xrep_dir_recover_data can spin forever if it encounters an unused dirent that claims to have length zero. Fix that, and prevent the same thing from happening with a zero-length entry.
CVE-2026-97547	New						In the Linux kernel, the following vulnerability has been resolved: xfs: fix exchange-range reflink flag clearing issue with INO1_WRITTEN When exchanging two full-file ranges, xmi_can_exchange_reflink_flags() can move the reflink inode flag from the file that currently has it to the other file, as long as exactly one side is marked. This assumes that the file contents, an...
CVE-2026-97549	New						In the Linux kernel, the following vulnerability has been resolved: xfs: fix under-reservation of blocks when repairing sf directories Whilst running QA on XFS for-next as of 7.3-rc2 with MKFS_OPTIONS="-n size=8192", I observed the following (trimmed) dmesg splat: XFS: Assertion failed: args->total >= dp->i_nblocks - nblks, file: fs/xfs/libxfs/xfs_da_btree.c, line: 2387 ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97550	New						In the Linux kernel, the following vulnerability has been resolved: xfs: fix unit conversions in per_binval computation LOLLM noticed that we're doing the unit conversion in the per_binval computation backwards -- xfs_buf_inval_log_space's second parameter is supposed to be in bytes, but max_binval is in units of fsblocks. Hence the conversion should be FSB -> B, not the ...
CVE-2026-97551	New						In the Linux kernel, the following vulnerability has been resolved: xfs: initialise args->total for parent pointer updates xfs_parent_da_args_init() builds an xfs_da_args from a zeroed xfs_parent_args (kmem_cache_zalloc), leaving args->total == 0. xfs_da_grow_inode_int() treats that field as a running block reservation and subtracts from it; because it is an xfs_extlen_t (...
CVE-2026-97552	New						In the Linux kernel, the following vulnerability has been resolved: xfs: initialise error in xfs_defer_finish_one() xfs_defer_finish_one() declares error without an initialiser and only assigns it inside the loop over dfp->dfp_work. When that list is empty the loop body never runs, control falls through to the "Done with the dfp, free it" path, and the function returns an...
CVE-2026-97553	New						In the Linux kernel, the following vulnerability has been resolved: xfs: lock the healthmon when inserting unmount event LOLLM complains that xfs_healthmon_unmount does an unlocked insert of the unmount event into the health monitor's event list. Fix that.
CVE-2026-97554	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: avoid using uninitialized SIDs in cifs_posix_to_fattr() cifs_posix_to_fattr() ignores the return value of posix_info_parse(). When a malformed POSIX directory entry is encountered (e.g. invalid SID lengths from an untrusted server), posix_info_parse() returns -1 without populating the 'parsed'...
CVE-2026-97556	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: avoid leaking refcount when cifs_sb_tlink() fails cifs_oplock_break() takes over the reference that cifs_queue_oplock_break() acquired when it queued the work, and drops it with _cifsFileInfo_put() once the break has been processed. Only in setups with "-o multiuser", cifs_sb_tlink() may fail...
CVE-2026-97558	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: fix cifsFileInfo reference leak in deferred close When cifs_close() defers a close, it hands the cifsFileInfo reference of the closing struct file to the queued work. Each execution of smb2_deferred_work_close() drops one such reference. deferred_close_scheduled can be false while the work is...
CVE-2026-97559	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: fail DACL rewrite when the new DACL exceeds 64K replace_sids_and_copy_aces() and set_chmod_dacl() accumulate the size of the DACL they build in a u16. That accumulator can wrap. validate_dacl() caps num_aces at (dacl_size - sizeof(struct smb_acl)) / 20, i.e. 3276 for a maximally sized DACL, w...
CVE-2026-97560	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: fix one-byte OOB read in smb2_parse_native_symlink() When parsing a share-root relative native symlink, memcpy copies smb_target+1 (skipping the leading separator) but uses strlen(smb_target)+1 as the length, reading one byte past the allocated buffer. This fixes the following KASAN splat whe...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97561	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: honor forceuid/forcegid when mapping SIDs to uid/gid When the administrator mounts with forceuid or forcegid (uid=/gid= mount options), they expect all files to appear owned by the specified user/group. However, several code paths unconditionally called sid_to_id() to overwrite cf_uid/cf_gid ...
CVE-2026-97563	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: reject out-of-bounds DataOffset in CIFSSMBRead() The SMB1 synchronous read helper CIFSSMBRead() validates the server's DataLength against CIFSSMBMaxBufSize and the caller's count, but never validates DataOffset. The copy source is formed as &pSMB->hdr.Protocol + le16_to_cpu(pSMB->DataOffset) ...
CVE-2026-97564	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: reject userspace cifs.idmap descriptions cifs.idmap key descriptions carry authority-bearing fields (owner and group SIDs and uid/gid values in "os:"/"gs:"/"oi:"/"gi:" form) that the cifs.idmap upcall helper treats as kernel-originating inputs. Unlike its sibling cifs.spnego, the cifs.idmap k...
CVE-2026-97565	New						In the Linux kernel, the following vulnerability has been resolved: smb: client: reject short READ responses in CIFSSMBRead() CIFSSMBRead() reads DataLengthHigh, DataLength and DataOffset out of the READ_RSP returned by the server without first checking that a whole READ_RSP was actually received. The length of the response is recorded in rsp_iov.iov_len, but nothing const...
CVE-2026-97566	New						In the Linux kernel, the following vulnerability has been resolved: mptcp: pm: kernel: drop pending ADD_ADDR when removing ID0 The in-kernel MPTCP path manager can leave a stale ADD_ADDR announcement entry alive when removing the id 0 endpoint. This happens because the id 0 removal path does not tear down pending announcements, unlike the non-zero id path. When the PM lat...
CVE-2026-97567	New						In the Linux kernel, the following vulnerability has been resolved: mptcp: prevent race between disconnect() and rx Sashiko noted that the two event can race, leading to inconsistent status. Prevent the race using the synchronous timer stop operation.
CVE-2026-97568	New						In the Linux kernel, the following vulnerability has been resolved: mptcp: synccookies: remember the request backup flag Instead of using an uninitialised bit when copying the info in subflow_ulp_clone(). To fix this, no need to extend the join_entry structure: backup is coming from struct mptcp_subflow_request_sock, only one bit. Do the same here by using one bit for both.
CVE-2026-97569	New						In the Linux kernel, the following vulnerability has been resolved: bnxt_en: Prevent queue stop with deferred completions When the driver receives a burst of packets, it can mark a BD with the NO_CMPL bit to defer completions. The expectation is that the last packet in the ring will have this bit unset and the completion generated by that packet will cleanup that packet an...
CVE-2026-97571	New						In the Linux kernel, the following vulnerability has been resolved: bnxt_en: Propagate TPA buffer allocation failures in bnxt_queue_mem_alloc() bnxt_alloc_one_tpa_info_data() returns -ENOMEM as soon as one allocation fails. This leaves the remaining rx->rx_tpa[] entries zeroed. bnxt_queue_mem_alloc() discards that return value, so the partially initialized ring is instal...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97572	New						In the Linux kernel, the following vulnerability has been resolved: bnxt_en: Propagate RX ring init failures in bnxt_init_nic() bnxt_init_rx_rings() returns an error when bnxt_alloc_one_rx_ring() fails, but bnxt_init_nic() discards that return value and calls bnxt_init_chip(), which enables TPA. If an allocation fails, this could leave rxr->rx_tpa[] partially zeroed and T...
CVE-2026-97574	New						In the Linux kernel, the following vulnerability has been resolved: bnxt_en: Don't free the live ring's TPA state on queue restart failure bnxt_queue_mem_alloc() shallow copies the live RX ring into the clone: memcpy(clone, rxr, sizeof(*rxr)); the code currently clears pointers that the clone owns (such as rx_agg_bmap), but rx_tpa and rx_tpa_idx_map are left pointing a...
CVE-2026-97581	New						In the Linux kernel, the following vulnerability has been resolved: media: verisilicon: hantro: bound G2 HEVC tile loop to the buffer capacity prepare_tile_info_buffer() writes one entry per tile into the tile_sizes DMA buffer, sized for a grid equal to the PPS uAPI array capacity. Use the bounded v4l2_hevc_pps_num_tile_columns() / v4l2_hevc_pps_num_tile_rows() helpers so ...
CVE-2026-97582	New						In the Linux kernel, the following vulnerability has been resolved: hwmon: (gpio-fan) Fix use-after-free in alarm work fan_alarm_irq_handler() queues fan_data->alarm_work, but nothing cancels it. fan_alarm_notify() dereferences fan_data and its hwmon device. On unbind, devres frees the interrupt, which only waits for the handler itself, and then releases the hwmon device...
CVE-2026-97585	New						In the Linux kernel, the following vulnerability has been resolved: afs: Fix double-unmap of directory block Fix afs_edit_dir_remove() to use a cleanup function to unmap the block pointed to by afs_dir_iter::block if it's left pointing to something rather than manually kunmapping the blocks. Manually kunmapping without clearing iter.blocks can result in a double-kunmap if...
CVE-2026-97586	New						In the Linux kernel, the following vulnerability has been resolved: afs: Fix missing kunmap in afs_dir_search_bucket() Fix afs_dir_search_bucket() to kunmap the block it's using in the "bad:" path.
CVE-2026-97587	New						In the Linux kernel, the following vulnerability has been resolved: perf: RISC-V: store available counter mask as bitmap The available-counter mask was a single unsigned long, but iteration uses RISCV_MAX_COUNTERS, which is 64. On RV32 that reads past the object. Filling with an unsigned-long bit at index 32 and above is also wrong. Use DECLARE_BITMAP and set_bit/bitmap h...
CVE-2026-97588	New						In the Linux kernel, the following vulnerability has been resolved: s390/crypto: Map EBUSY to EIO when key conversion fails repeatedly When hardware persistently returns -EBUSY after exhausting retries, the error propagates to crypto_finalize_*_request(). The crypto API's completion wrapper treats -EBUSY as a queueing status and swallows it, preventing the completion callb...
CVE-2026-97590	New						In the Linux kernel, the following vulnerability has been resolved: s390/crypto: Fix missing scrub of temp buffers with PAES algorithm In function ctr_paes_do_crypt() there is a buffer used to process remaining bytes < AES_BLOCK_SIZE. This buffer was not scrubbed and thus could lead to expose of unwanted data. Rework the code to explicitly scrub the buffer at the end of th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97591	New						In the Linux kernel, the following vulnerability has been resolved: s390/crypto: Fix handling of EBUSY in PHMAC when req is pushed to crypto engine When a request is transferred to the engine via crypto_transfer_hash_request_to_engine() there are two return codes signaling a successful transfer: EINPROGRESS and EBUSY. However the correct handling of EBUSY was missing and h...
CVE-2026-97592	New						In the Linux kernel, the following vulnerability has been resolved: s390/crypto: Fix missing scrub of temp buffers with AES ctr and gcm algorithm In function ctr_aes_crypt() there is a buffer used to process remaining bytes < AES_BLOCK_SIZE. This buffer was not scrubbed and thus could lead to expose of unwanted data. When the buffer is used explicitly scrub it at the end o...
CVE-2026-97593	New						In the Linux kernel, the following vulnerability has been resolved: iommu/s390: Fix NULL dereference in iova_to_phys() with ZPCI_TABLE_TYPE_RFX When using a 5-level translation table via ZPCI_TABLE_TYPE_RFX get_rso_from_iova() returns NULL when the region-first entry is invalid. Yet in get_rto_from_iova() the region-second origin rso is not checked to be non-NULL before ac...
CVE-2026-97596	New						In the Linux kernel, the following vulnerability has been resolved: ipv6: reject invalid states in connection template sync records IPVS sync receivers validate protocol states before creating or updating a connection. For connection templates, however, they only log states outside the template state range and still store the value in the connection. A template can be ret...
CVE-2026-97597	New						In the Linux kernel, the following vulnerability has been resolved: ipv6: flowlabel: cap duplicate leases per socket ipv6_flowlabel_get() allocates an ipv6_fl_socklist entry for every successful GET. The recheck path for a compatible existing flowlabel links another lease without applying any lease admission check. Repeated GET requests for one shareable label can therefor...
CVE-2026-97598	New						In the Linux kernel, the following vulnerability has been resolved: ipv4: fib: bound automatic table ID allocation fib_empty_table() probes every table ID from 1 until it finds a free one. IPv4 tables are stored in a 256-bucket hash table, so a dense set of IDs makes each probe walk a growing hash chain while RTNL is held. Automatic table assignment ("ip rule ... table 0...
CVE-2026-97599	New						In the Linux kernel, the following vulnerability has been resolved: ieee802154: hwsim: serialize pib updates to fix double-free hwsim_update_pib() does an unserialized read-swap-free of phy->pib: pib_old = rtnl_dereference(phy->pib); ... rcu_assign_pointer(phy->pib, pib); kfree_rcu(pib_old, rcu); It assumes the RTNL is held, but ->set_channel is not always called und...
CVE-2026-97600	New						In the Linux kernel, the following vulnerability has been resolved: ieee802154: cc2520: fix FIFOP work use-after-free The FIFOP interrupt handler queues cc2520_fifop_irqwork. On removal, cc2520_remove() only flushes the work. The devm-managed FIFOP IRQ remains active until after ->remove() returns and can queue the work again after that flush, allowing it to run after th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97601	New						In the Linux kernel, the following vulnerability has been resolved: ieee802154: 6lowpan: fix NULL dereference in lowpan_newlink TUNSETLINK allows a TUN device to change its link-layer type to ARPHRD_IEEE802154 without initializing ieee802154_ptr. lowpan_newlink() checks only the device type before dereferencing the pointer, so an RTM_NEWLINK request can trigger a NULL poin...
CVE-2026-97603	New						In the Linux kernel, the following vulnerability has been resolved: idpf: disable DIM work before freeing q_vectors idpf never drains the Tx/Rx DIM works before freeing the memory they live in. tx_dim and rx_dim are embedded in struct idpf_q_vector, they are queued from the NAPI poll via net_dim(), and idpf_vport_intr_rel() ends with kfree(rsrc->q_vectors). Nothing in th...
CVE-2026-97604	New						In the Linux kernel, the following vulnerability has been resolved: fbdev: vfb: defer cleanup until the last reference FBIOGETCMAP takes a shallow snapshot of info->cmap and performs the usercopy after dropping info->lock. vfb_remove() frees the colormap immediately after unregistering the framebuffer, even when an open file still holds a reference to fb_info. A concurrent...
CVE-2026-97605	New						In the Linux kernel, the following vulnerability has been resolved: erofs: preserve LZMA decoders on resize failure The pool-resize path frees each stream's old decoder before allocating its replacement. If an allocation fails after some streams have already been replaced, the failed stream is put back on the list with state == NULL. z_erofs_lzma_max_dictsiz... is still adva...
CVE-2026-97606	New						In the Linux kernel, the following vulnerability has been resolved: fs: autofs: fix memory leak in autofs_fill_super() In autofs_fill_super(), we create a new inode using autofs_new_ino(), however, if we fail to create root_inode, (that is, root_inode failure path), we return -ENOMEM without freeing the new inode(ino) that we created causing a memory leak. Fix this by addi...
CVE-2026-97607	New						In the Linux kernel, the following vulnerability has been resolved: vdpa: ifcvf: Put device on unsupported feature error Route unsupported provisioned features through the common error path after vdpa_alloc_device() so the allocated device and adapter pointer are released consistently.
CVE-2026-97610	New						In the Linux kernel, the following vulnerability has been resolved: netfs: Fix uninitialized return value in netfs_unbuffered_write() If preparation of the first subrequest fails, netfs_unbuffered_write() exits its loop before ret is initialized. The empty-iterator check can do the same. For synchronous writes, netfs_unbuffered_write_iter_locked() may then return an unrel...
CVE-2026-97613	New						In the Linux kernel, the following vulnerability has been resolved: net: mana: Reserve extra CQ slot for the fence completion CQE The RX completion queue is sized to hold exactly one CQE per posted RX WQE. MANA_FENCE_RQ makes hardware post an additional CQE_RX_OBJECT_FENCE after the packet CQEs. The current sizing reserves no extra slot for it and in rare cases, CQ has no ...
CVE-2026-97614	New						In the Linux kernel, the following vulnerability has been resolved: net: dsa: tag_brcm: legacy FCS: request needed tailroom The legacy FCS tagger calculates the CRC over skb->len bytes starting at skb->data. When a nonlinear skb reaches the tagger, this reads past the linear head into unrelated slab memory. The tagger appends an Ethernet FCS but does not declare that tail...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97615	New						In the Linux kernel, the following vulnerability has been resolved: net: bridge: use option bits for CFM/MRP frame handlers CFM and MRP register a global br_frame_type whose hlist_node is linked into the per-bridge frame_type_list when the first MEP/MRP instance is created. Enabling the protocol on multiple bridges therefore inserts the same node into multiple lists. Unreg...
CVE-2026-97616	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: act_api: release all action references on NEWACTION failure When a batched RTM_NEWACTION request replaces an existing action, tcf_idr_check_alloc() takes a temporary reference on it. If a later action fails to initialize, tcf_action_destroy() uses strict release semantics to clean up the actions...
CVE-2026-97617	New						In the Linux kernel, the following vulnerability has been resolved: ring-buffer: Check resize_disabled before publishing the new subbuf order ring_buffer_subbuf_order_set() stores the new order and only then walks the CPUs, returning -EBUSY if any of them has resizing disabled. A user mapped buffer has resizing disabled, and __rb_map_vma() reads buffer->subbuf_order withou...
CVE-2026-97618	New						In the Linux kernel, the following vulnerability has been resolved: io_uring/net: don't overconsume buffers when using MSG_TRUNC When a recv/recvmsg is issued with MSG_TRUNC and the incoming packet is larger than the provided buffer, the net layer returns the full length of the packet rather than the number of bytes actually copied into the buffer. As a result, io_uring a...
CVE-2026-97619	New						In the Linux kernel, the following vulnerability has been resolved: io_uring/rw: end write accounting from ->ki_complete Commit b000145e9907 moved both the fsnotify calls and the write accounting out of the kiocb completion handler and into the io_req_rw_complete() task_work. However, only the fsnotify part actually needed to move as it may sleep. Ending the write accounti...
CVE-2026-97620	New						In the Linux kernel, the following vulnerability has been resolved: drm/xe: Flush LSC untyped L1 dataport cache after rcs/ccs batches emit_render_cache_flush() sets PIPE_CONTROL0_HDC_PIPELINE_FLUSH to flush the L2/HDC data cache before fence signalling, but it never requests a flush of the LSC untyped L1 data cache via the 'Untyped Data-Port Cache Flush Enable' bit in PIPE...
CVE-2026-97621	New						In the Linux kernel, the following vulnerability has been resolved: drm/rockchip: analogix_dp: fix unchecked bound endpoint name length rockchip_dp_drm_encoder_enable() uses sprintf() to format a device tree path into a 32-byte stack buffer. Device tree paths are not limited to this size, so a sufficiently long path can overflow the buffer. Use snprintf() with the destina...
CVE-2026-97622	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: CVE-2026-62062. Reason: This candidate is a reservation duplicate of CVE-2026-62062. Notes: All CVE users should reference CVE-2026-62062 instead of this candidate. All references and descriptions in this candidate have been removed to prevent accidental usage.
CVE-2026-97899	New						In the Linux kernel, the following vulnerability has been resolved: drm/i915: Fix memory leak in query_perf_config_list() When krealloc() fails, free the original oa_config_ids before returning to avoid a memory leak. (cherry picked from commit 9977e9d84f46d4f12ad35fbbc0ec4638554bce87)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97900	New						In the Linux kernel, the following vulnerability has been resolved: drm/drm_exec: fix up contended obj when num_objects is 0 drm_exec_prepare_array() silently returns success without calling drm_exec_lock_contended() when num_objects is zero. This breaks the invariant upheld by drm_exec_lock_obj(), where every entry point into the locking sequence must first attempt to loc...
CVE-2026-97901	New						In the Linux kernel, the following vulnerability has been resolved: genetlink: pin family module during policy dump The generic netlink controller's policy dump keeps pointers to the target family's operation and policy tables in its callback state. A dump may be split across multiple skbs and remain pending after the initial request. Netlink pins the module which owns t...
CVE-2026-97902	New						In the Linux kernel, the following vulnerability has been resolved: fs: don't return -EINVAL for successful nested thaw Commit 7366f8b6fc6a ("fs: handle freezing from multiple devices") replaced the freeze_holders bitmask with per-holder counters to allow nested freezes. In the bitmask version, a thaw that released a shared hold while another holder remained returned 0. Si...
CVE-2026-97904	New						In the Linux kernel, the following vulnerability has been resolved: cpufreq: initialize policy rwsem before sysfs publication cpufreq_policy_alloc() initializes policy->rwsem after kobject_init_and_add() has created the policy sysfs directory and its default attributes. A sysfs access can therefore reach a policy callback before the semaphore has been initialized. Initial...
CVE-2026-97905	New						In the Linux kernel, the following vulnerability has been resolved: cpufreq: zero-initialize policy cpumask before sysfs publication cpufreq_policy_alloc() allocates policy->cpus with alloc_cpumask_var(), i.e. without __GFP_ZERO, unlike the sibling related_cpus and real_cpus masks. With CONFIG_CPUMASK_OFFSTACK=y the mask is a separate kmalloc_node() allocation, so its bitm...
CVE-2026-97906	New						In the Linux kernel, the following vulnerability has been resolved: bootconfig: Fix integer overflow in initrd size check Sashiko reported that in get_boot_config_from_initrd(), a crafted initrd with a huge bootconfig size (such as 0xFFFFFFFF) can cause the pointer arithmetic: data = ((void *)hdr) - size; to wrap around on 32-bit systems (or when pointer subtraction ...
CVE-2026-97907	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: btrtl: Don't leak return code when parsing firmware format v2 When key_id from chip is zero, rtlbt_parse_firmware_v2() intentionally ignores all security headers. However, the implementation simply breaks from a switch statement and leaks uninitialized return code `rc' (if the first section is a...
CVE-2026-97908	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: btqcomsmgd: destroy RPNsg endpoints before freeing hci_dev The command and ACL RPNsg endpoints store struct btqcomsmgd as their callback private data. The receive callbacks dereference btq->hdev without taking an hci_dev reference. The current teardown order frees the hci_dev before destroying th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97909	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: sti: initialize IRQ lock before requesting IRQ uni_reader_init() registers the shared IRQ before initializing reader->irq_lock. A pending interrupt can invoke the handler while the lock is still uninitialized. Initialize the lock before registering the IRQ so the interrupt path always sees valid loc...
CVE-2026-97912	New						In the Linux kernel, the following vulnerability has been resolved: accel: ethosu: Ensure SRAM size is 0 on mapping failure On a mapping failure of the SRAM, the SRAM size is left as non-zero. The probe will succeed as the error return is not checked since having SRAM is not a hard requirement. The non-zero size allows jobs to access SRAM which is left pointing to physical...
CVE-2026-97913	New						In the Linux kernel, the following vulnerability has been resolved: accel: ethosu: Ensure cmd stream ends with a stop op While the QSIZE register setting should prevent an out of bounds access of the command stream, it is not clear whether the h/w generates an interrupt in this case as is required (to prevent a timeout). As a stop op is expected end of the command stream, ...
CVE-2026-97914	New						In the Linux kernel, the following vulnerability has been resolved: accel: ethosu: Fix ethosu_job_open() return value A WARN_ON() returns a 0 or 1, not the original negative errno. Just drop the WARN_ON() as the FD open will pass the return code to userspace and there's only one possible source of the error (drm_sched_entity_init()).
CVE-2026-97915	New						In the Linux kernel, the following vulnerability has been resolved: accel/ivpu: Limit firmware log name prints to field size The name in struct vpu_tracing_buffer_header is a fixed-size array populated by the NPU firmware. It is expected to be NUL-terminated, but nothing on the host side enforces this, so printing it with an unbounded string conversion would read past the ...
CVE-2026-97916	New						In the Linux kernel, the following vulnerability has been resolved: accel/ivpu: Validate firmware log buffer metadata The tracing log headers parsed by fw_log_print_buffer() reside in DMA-shared BOs that the NPU firmware can write to. fw_log_from_bo() validated log->header_size and log->size, but fw_log_print_buffer() re-read those same fields from shared memory afterward...
CVE-2026-97917	New						In the Linux kernel, the following vulnerability has been resolved: accel/ivpu: Validate full buffer range in ivpu_to_cpu_addr Add a size parameter to ivpu_to_cpu_addr() and validate that the whole [vpu_addr, vpu_addr + size) range stays within the BO.
CVE-2026-97918	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Undo the registration when enabling the histogram trigger fails Commit 6f86bdeab633 ("tracing: Fix bad hist from corrupting named_triggers list") described how a trigger that is registered but not on file->triggers ends up freed while still on the global named_triggers list, and moved the registra...
CVE-2026-97919	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Take the reference before publishing the named histogram trigger event_hist_trigger_named_init() puts the trigger on the global named_triggers list and only then takes the reference on the trigger it shares its histogram with: data->ref++; save_named_trigger(data->named_data->name, data); re...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97920	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Keep the entry count when the histogram stats allocation fails print_entries() uses n_entries both as the number of sort entries and as its own return value, so the -ENOMEM it stores when the stats allocation fails overwrites the count that the cleanup still needs: n_entries = tracing_map_sort_e...
CVE-2026-97921	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Free histogram the field rejected for a bad modifier Writing a hist trigger whose value or variable carries a modifier that is not allowed there leaks the fields that were built for it. __create_val_field() takes the field from parse_expr() and stores it in hist_data->fields[] only after the modi...
CVE-2026-97922	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Free histogram var refs regardless of how often they are referenced Using the same variable three or more times in one hist trigger leaks the variable reference and its strings when the trigger is removed. commit 656fe2ba85e8 ("tracing: Use hist trigger's var_ref array to destroy var_refs") made ...
CVE-2026-97923	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Free histogram the var ref when its initialization fails create_var_ref() allocates a VAR_REF hist_field and then calls init_var_ref() to fill it in. When that fails the field is leaked. commit 656fe2ba85e8 ("tracing: Use hist trigger's var_ref array to destroy var_refs") made destroy_hist_field(...
CVE-2026-97924	New						In the Linux kernel, the following vulnerability has been resolved: tracing/user_events: Don't destroy fields when event removal fails destroy_user_event() destroys the event's fields before attempting to remove the trace event call. If user_event_set_call_visible() fails, e.g. because the event is still enabled and trace_remove_event_call() returns -EBUSY, the event is le...
CVE-2026-97925	New						In the Linux kernel, the following vulnerability has been resolved: tick/broadcast: Plug clockevents replacement race ■■■■ reported and decoded the following race condition when a broadcast device is replaced: CPUA CPUB __tick_broadcast_oneshot_control() bc = tick_broadcast_device.evtdev; tick_install_broadcast_device(dev) clockevents_exchange_devi...
CVE-2026-97927	New						In the Linux kernel, the following vulnerability has been resolved: ufs: create the root dentry after loading cylinder metadata ufs_fill_super() installed sb->s_root before it loaded the cylinder group structures for a writable mount: sb->s_root = d_make_root(inode); ... if (!sb_rdonly(sb)) if (!ufs_read_cylinder_structures(sb)) goto failed; When ufs_read_cylinde...
CVE-2026-97928	New						In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: skip the VMID 0 flush for VRAM Clear-on-release only runs on VRAM, which amdgpu_ttm_map_buffer() reaches via its direct MC address without programming a GART window, yet the wipe still forces a VMID 0 flush. On GFX11 (e.g. Navi33) that spurious SDMA flush can wedge the engine; only flush when a...
CVE-2026-97929	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: usbux2y: validate URB actual_length in interrupt callback i_usx2y_in04_int() processes the interrupt URB data without checking urb->actual_length. A short transfer from a malfunctioning device would cause the handler to process uninitialized heap data from the kmalloc-allocated in04_buf, which is t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97930	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: usb2y: fix in04_last array size mismatch with in04_buf The in04_last array in struct usx2ydev is declared as char[24], but in04_buf is allocated as sizeof(struct us428_ctls) which is 21 bytes. In i_usx2y_in04_int(), when ctl_snapshot_last == -2 (initialization path): memcpy(usx2y->in04_last, ...
CVE-2026-97932	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Don't dereference trace_event_file in deferred trigger free The enable_event trigger defers trace_event_put_ref() to the trigger free kthread, but the trace_event_file can already be freed when the instance is removed. Keep the trace_event_call directly in enable_trigger_data so the deferred free...
CVE-2026-97933	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Take trace_array reference when opening a tracer options file When a tracer option file is opened, it is passed a descriptor that points to an element on the trace_array's topts array. This element has information to find the trace array and other information. It uses this element to take a refere...
CVE-2026-97934	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Fix memory corruption from a "STACKTRACE" histogram key "cpu", "CPU", "stacktrace" and "STACKTRACE" are generic fields, defined with an offset and a size of zero so that the filter code can match them by name. parse_field() maps them onto their common_* equivalents for backward compatibility, but ...
CVE-2026-97935	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Set the trace clock before registering the histogram trigger hist_register_trigger() puts the trigger on the global named_triggers list in cmd_ops->init(), and only then sets the trace clock: if (data->cmd_ops->init) { ret = data->cmd_ops->init(data); if (ret < 0) goto out; } if (hist_...
CVE-2026-97936	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Fix memory corruption from the histogram stacktrace modifier parse_field() sets HIST_FIELD_FL_STACKTRACE from the ".stacktrace" modifier before it looks the field name up, and nothing afterwards checks that the name resolved to a field which holds a stacktrace. create_hist_field() picks HIST_FIELD...
CVE-2026-97938	New						In the Linux kernel, the following vulnerability has been resolved: reboot: fix cad_pid use-after-free race cad_pid is a single kernel-wide struct pid pointer. proc_do_cad_pid() reads it and passes it to pid_vnr() without protecting the lifetime of the referenced struct pid. A concurrent writer can replace cad_pid and drop the final reference to the old struct pid after th...
CVE-2026-97939	New						In the Linux kernel, the following vulnerability has been resolved: ipmr: account multicast table and route memory A netadmin in a user+net namespace can create many IPv4 and IPv6 multicast routing tables with MRT_TABLE and MRT6_TABLE. Each unseen id allocates an mr_table via the shared mr_table_alloc(), links it into the per-net list, and leaves it until netns teardown. T...
CVE-2026-97942	New						In the Linux kernel, the following vulnerability has been resolved: x86/alternatives: Exclude text poking against change_page_attr() From time to time, the following BUG can be observed in the x86 alternatives patching code [0]: > kernel BUG at arch/x86/kernel/alternative.c:2576! > Oops: invalid opcode: 0000 [#1] SMP NOPTI > CPU: 0 UID: 0 PID: 355 Comm: (udev-worker...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97943	New						In the Linux kernel, the following vulnerability has been resolved: x86/mm/pat: Acquire init_mm write lock on collapse to avoid UAF x86 implements page attribute modification using its Change Page Attributes (CPA) mechanism. This tracks properties of ranges such as cache mode through x86 page attributes, and as part of that logic manipulates kernel page tables. Since com...
CVE-2026-97944	New						In the Linux kernel, the following vulnerability has been resolved: x86/cfi: Fix FineIBT hash offset in cfi_get_func_hash() The switch of the FineIBT preamble from "subl \$hash, %r10d" to the shorter "subl \$hash, %eax" moved the hash immediate from offset 7 to offset 5 of the preamble. fineibt_preamble_hash was updated to match, but the open-coded offset in cfi_get_func_has...
CVE-2026-97945	New						In the Linux kernel, the following vulnerability has been resolved: x86/mm: Fix user-space data loss with MADV_FREE and THP Some of users of Polars (a data analytics library) have lost production data from this bug. They seem to have just the right combination of huge pages, MADV_FREE and heavy reclaim pressure. pmd_modify() masks the old value with (_HPAGE_CHG_MASK & ~_P...
CVE-2026-97946	New						In the Linux kernel, the following vulnerability has been resolved: x86/amd_node: Fix PCI device reference counting in amd_smn_init() The local "root" pointer is a temporary variable used during the device search. Therefore, refcount related to the search iterators should be cleaned up after the search is complete. Use the __free() cleanup macro to ensure the refcount is ...
CVE-2026-97947	New						In the Linux kernel, the following vulnerability has been resolved: x86/amd_node: Fix potential NULL pointer dereference amd_smn_read/write() are exported functions around __amd_smn_rw(), so they are always available even if amd_smn_init() fails. In that case, 'amd_roots' is NULL and __amd_smn_rw() will access uninitialized memory. Then, commit: 83518453074d ("x86/amd_...
CVE-2026-97948	New						In the Linux kernel, the following vulnerability has been resolved: powerpc/eeh: Fix recursive locking on devices without EEH sensitive driver The commit 1010b4c012b0 ("powerpc/eeh: Make EEH driver device hotplug safe") refactored the EEH code such that the pci_rescan_remove_lock is held at the beginning of eeh_handle_normal_event() and the eeh_reset_device() is called wit...
CVE-2026-97949	New						In the Linux kernel, the following vulnerability has been resolved: configfs: unhash the dentry before dropping the item in rmdir configfs_get_config_item() treats a hashed dentry as proof that sd->s_element is a live config_item. configfs_rmdir() breaks that: simple_rmdir() leaves the dentry hashed, the last reference to the item is dropped right after, and the dentry is...
CVE-2026-97950	New						In the Linux kernel, the following vulnerability has been resolved: configfs: pin the symlink target's dirent instead of chasing ->ci_dentry create_link() reads the target's configfs_dirent from item->ci_dentry->d_fsdata, relying on the item reference taken by get_target(). That reference pins the item, not its dentry: the dentry is pinned by DCACHE_PERSISTENT, which conf...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97951	New						In the Linux kernel, the following vulnerability has been resolved: scsi: target: iscsi: Fix hang for aborted WRITE_PENDING commands When a LUN_RESET aborts a WRITE command that is in the TRANSPORT_WRITE_PENDING state, the target core sets CMD_T_ABORTED and waits for the frontend to finish processing. If the initiator subsequently sends the remaining dataout PDUs, __iscsi...
CVE-2026-97952	New						In the Linux kernel, the following vulnerability has been resolved: sunvdc: unmap LDC cookies when the descriptor send fails __send_request() maps the request's pages into the LDC channel's map table (ldc_map_sg()), fills in the descriptor and marks it VIO_DESC_READY before ringing the doorbell via __vdc_tx_trigger(). When the trigger fails, the error path only prints a me...
CVE-2026-97954	New						In the Linux kernel, the following vulnerability has been resolved: net/rds: fix tcp stream corruption with large pages rds_message_map_pages() assigns PAGE_SIZE bytes to every scatterlist entry, even when total_len ends in a partial page. The RDS congestion map is defined as 8192 bytes, so on systems with PAGE_SIZE greater than 8192 the scatterlist maps bytes beyond the e...
CVE-2026-97955	New						In the Linux kernel, the following vulnerability has been resolved: net: mana: restore the XDP program pointer when pre-allocation fails mana_xdp_set() publishes the new program into apc->bpf_prog before it allocates anything, because mana_pre_alloc_rxbufs() sizes the buffers from it via mana_get_rxbuf_cfg(). When that allocation fails the function returns the error direct...
CVE-2026-97956	New						In the Linux kernel, the following vulnerability has been resolved: net: net_failover: Fix the deadlock in net_failover_slave_name_change() This is a sibling fix of commit b84c5632c7b3 ("net: net_failover: Fix the deadlock in slave register"). There is netdev_lock_ops() in the upper callers, so using netif_open() instead of dev_open(). Call Trace: __schedule+0x2bb/0x650 ...
CVE-2026-97958	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: cls_api: Don't replay RTM_GETCHAIN in tc_ctl_chain(). If a netlink socket sends RTM_GETCHAIN requests repeatedly without recv()ing the responses, tc_ctl_chain() hogs CPU and triggers Hung Task splat. [0] As caught in the stack trace, netlink_attachskb() could confuse tc_ctl_chain() by returning...
CVE-2026-97959	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: cls_route: free emptied bucket on filter move route4_change can move an existing filter to a different top-level bucket: route4_set_parms recomputes the handle from TCA_ROUTE4_TO/ FROM/IIF, and the handle-mismatch check is gated on the 'new' flag, so for an existing filter the new handle may dif...
CVE-2026-97960	New						In the Linux kernel, the following vulnerability has been resolved: perf/x86/intel: Prevent drain_pebs() reentry The PEBS buffer is shared by all events on a CPU, so drain_pebs() must not be reentered. If so, one instance may observe stale buffer state and potentially access out-of-bound memory. Most invocations happen in NMI context, which naturally prevents reentry. How...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97961	New						In the Linux kernel, the following vulnerability has been resolved: perf/core: Allow list_del during perf_event_overflow() A PMU might use perf_sched_cb_inc() and perf_sched_cb_dec() interface to get the PMU call back function pmu::sched_task invoked at schedule in and schedule out. This is achieved by walking along the list anchored by sched_cb_list. The following scenar...
CVE-2026-97962	New						In the Linux kernel, the following vulnerability has been resolved: net/mlx5e: Move representor vnic reporter to eswitch devlink port The representor vnic devlink health reporter is created and destroyed along the representor netdev (un)load path, which is not serialized by the devlink instance lock. Destroying the reporter from there triggers a devl_assert_locked() splat ...
CVE-2026-97963	New						In the Linux kernel, the following vulnerability has been resolved: net: stmmac: initialize ptp_lock at probe time priv->ptp_lock is only initialized in stmmac_ptp_register(), which runs during __stmmac_open(). However, the lock is also used while the interface is down and has never been opened: tc_taprio_configure() invokes the PTP gettime64() callback to compute the EST ...
CVE-2026-97964	New						In the Linux kernel, the following vulnerability has been resolved: ppp_synctty: ensure a writeable skb header ppp_sync_txmunge() checks headroom before prepending the address and control bytes, but does not ensure that the skb header is writable. A received skb can reach this function through PPP channel bridging without passing through ppp_start_xmit(), which calls skb_c...
CVE-2026-97965	New						In the Linux kernel, the following vulnerability has been resolved: vxlan: initialize _md in vxlan_xmit_one() If a VXLAN device is configured with both VXLAN_F_COLLECT_METADATA and VXLAN_F_GBP, and a packet is transmitted through it using an external ip_tunnel_info that lacks the IP_TUNNEL_VXLAN_OPT_BIT flag, md is left pointing to the uninitialized _md stack variable: ...
CVE-2026-97966	New						In the Linux kernel, the following vulnerability has been resolved: octeontx2-pf: reset HTB scheduler topology before freeing queues HTB offload programs NIX_AF_TLxX_TOPOLOGY on QoS-allocated scheduler queues via otx2_qos_txschq_set_parent_topology(), but teardown freed those queues without clearing TOPOLOGY. The AF only restores PARENT and SCHEDULE on free, so PRIO_ANCHO...
CVE-2026-97967	New						In the Linux kernel, the following vulnerability has been resolved: hwmon: (corsair-cpro) Remove debugfs entries when probe fails ccp_debugfs_init() registers debugfs files whose private data is the devm allocated ccp. If hwmon_device_register_with_info() fails right after it, ccp_probe() returns without removing them: the HID core then frees ccp, and ccp_remove() is not ...
CVE-2026-97968	New						In the Linux kernel, the following vulnerability has been resolved: hwmon: (corsair-cpro) Create debugfs entries after hwmon registration ccp_debugfs_init() registers debugfs files whose private data is the devm allocated ccp. It runs before hwmon_device_register_with_info(), so when that registration fails, ccp_probe() returns with the files still in place. The HID core...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97969	New						In the Linux kernel, the following vulnerability has been resolved: watchdog: msc313e: Fix clock leak and spurious timer in settimeout() msc313e_wdt_settimeout() unconditionally calls msc313e_wdt_start() which introduces two severe bugs: 1. If the watchdog is already active, calling start() again will increase the reference count of the clock again. However stop() is ...
CVE-2026-97970	New						In the Linux kernel, the following vulnerability has been resolved: watchdog: msc313e: Avoid division by zero clk_get_rate() could return 0. Avoid a division by zero panic.
CVE-2026-97972	New						In the Linux kernel, the following vulnerability has been resolved: net: macb: put the "mdio" child node reference on success macb_mii_init() holds the reference returned by of_get_child_by_name() for macb_mdio_register() and drops it only on the error paths, so every successful probe leaks a node reference. On a CM5, overlay removal after four bind cycles reports OF...
CVE-2026-97973	New						In the Linux kernel, the following vulnerability has been resolved: net: macb: destroy the phylink instance on the probe error path macb_mii_init() creates a phylink instance on both of its success paths, but the probe unwind frees the netdev without destroying it, so a failing macb_alloc_tioff() or register_netdev() leaks the instance. Destroy it at err_out_unregister_m...
CVE-2026-97974	New						In the Linux kernel, the following vulnerability has been resolved: ipv6: null-check fib6_node before accessing in __ip6_del_rt_siblings() syzbot reported a null-ptr-deref in __ip6_del_rt_siblings() [0]. The stack trace hinted towards a null dereference of rt->fib6_node when fr->leaf is accessed in __ip6_del_rt_siblings(). With RTNL_FLAG_DOIT_UNLOCKED set, inet6_rtm_delro...
CVE-2026-97975	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: hci_sysfs: Fix NULL pointer dereference in device_del() A NULL pointer dereference in klist_put() occurs when a child device (such as a BNEP network device in bnep_session) is concurrently being unregistered while hci_conn_del_sysfs() reparents child devices. This is caused by a race condition ...
CVE-2026-97976	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: btintel_pcie: validate packet_len before skb_put_data btintel_pcie_submit_rx_work() reads packet_len from rfh_hdr without checking if it exceeds the RX buffer size. An oversized packet_len can lead to an out-of-bounds read in skb_put_data(). Validate packet_len to ensure it is non-zero and does...
CVE-2026-97977	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: btusb: Fix UAF of btusb_data by rx_work btusb_close() and btusb_flush() cancel data->rx_work with the asynchronous cancel_delayed_work(), so if btusb_rx_work() is already running on another CPU it keeps running after the cancel returns. btusb_disconnect() calls hci_unregister_dev(), which invok...
CVE-2026-97978	New						In the Linux kernel, the following vulnerability has been resolved: eth: ice: don't dereference pointers from TP_printk() After forwarding net-next during the v7.3 merge window we started seeing: TRACE EVENT ERROR: Event ice_tx_dim_work has double dereference in TP_printk: REC->q_vector->tx.tx_ring->q_index WARNING: kernel/trace/trace_events.c:420 at test_double_deref...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97979	New						In the Linux kernel, the following vulnerability has been resolved: ice: add missing xa_destroy for sched_node_ids Commit 16dfa49406bc ("ice: Introduce new parameters in ice_sched_node") added a sched_node_ids xarray to the port info structure, but never called xa_destroy on it. Since xarrays can allocate internal memory, this can result in a memory leak even if every ele...
CVE-2026-97980	New						In the Linux kernel, the following vulnerability has been resolved: s390/debug: Fix NULL pointer dereference in debug_set_level() Commit a2cec6863709 ("s390/debug: Add s390dbf kernel parameter") incorrectly removed a null-id check from debug_set_level(), introducing a possible NULL pointer dereference for debug-API users that put debug_register() results unchecked into deb...
CVE-2026-97981	New						In the Linux kernel, the following vulnerability has been resolved: net: ethernet: cortina: Count dropped frames as NAPI work The RX loop only consumes budget when it successfully delivers a frame. Error paths keep consuming descriptors without reducing the budget, so a stream of bad frames can process the entire receive ring in one poll. Move the budget accounting to a c...
CVE-2026-97982	New						In the Linux kernel, the following vulnerability has been resolved: net: ethernet: cortina: Fix budget accounting The gmac_rx() function returns the remaining NAPI budget, but its caller treats the return value as the number of packets received. An idle poll therefore reports a full budget and remains scheduled. Return the number of received packets instead. Preserve the ...
CVE-2026-97983	New						In the Linux kernel, the following vulnerability has been resolved: vduse: return compat ioctl results directly The compat handler handles VDUSE_IOCTL_GET_FD and VDUSE_VQ_GET_INFO, but then calls the native handler. Their different command sizes make native dispatch return -ENOIOCTLCMD. For GET_FD, this overwrites receive_fd()'s return value after the descriptor is instal...
CVE-2026-97984	New						In the Linux kernel, the following vulnerability has been resolved: net: ipv6: Fix UDP length overflow with PMTU discover and big MTU This commit bounds cork->base.fragsize to IP6_MAX_MTU for UDP sockets to avoid a possible overflow of UDP length that triggers a WARN in udp_set_len_short when setsockopt IPV6_MTU_DISCOVER is set to IPV6_PMTUDISC_DO or IPV6_PMTUDISC_PROBE, a...
CVE-2026-97985	New						In the Linux kernel, the following vulnerability has been resolved: af_unix: Update last skb marker in manage_oob(). Fahad Alharbi reported that blocking recv(MSG_PEEK) could hog CPU due to OOB skb. In the following cases, manage_oob() skips OOB skb(s) and returns NULL for the last recv(MSG_PEEK): socketpair(AF_UNIX, SOCK_STREAM, 0, sk); 1) skb -> OOB skb -> NULL ...
CVE-2026-97986	New						In the Linux kernel, the following vulnerability has been resolved: virtio_input: stop callbacks before unregistering input device virtinput_remove() unregisters the input device before resetting the virtio device. virtinput_recv_events() drops vi->lock around input_event(), so clearing vi->ready does not stop a callback that passed the entry check. It can still use vi->id...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97987	New						In the Linux kernel, the following vulnerability has been resolved: virtio_input: reset device if input_register_device() fails Probe marks the device DRIVER_OK with virtio_device_ready() before calling input_register_device(). If registration fails, the error path cleared vi->ready and called del_vqs() while the device was still live, so the device could keep DMA to queue...
CVE-2026-97988	New						In the Linux kernel, the following vulnerability has been resolved: vhost: invalidate vring access on IOTLB transitions When VIRTIO_F_ACCESS_PLATFORM changes, cached vring pointers and IOTLB metadata are interpreted in a different address space. Keeping them across the transition can leave stale ring mappings in use. Clearing d->iotlb before taking the VQ locks also lets ...
CVE-2026-97989	New						In the Linux kernel, the following vulnerability has been resolved: vduse: validate virtqueue alignment vduse_validate_config() only checks the upper bound of vq_align. Invalid values can therefore reach vring_create_virtqueue_map(). The split-ring helpers use align - 1 as a bit mask, so the alignment must be a non-zero power of two. A zero value makes vring_size() drop th...
CVE-2026-97992	New						In the Linux kernel, the following vulnerability has been resolved: vhost-vdpa: protect config_ctx from being freed under the config callback vhost_vdpa_config_cb() loads v->config_ctx and signals it without taking a reference and without holding any lock: struct eventfd_ctx *config_ctx = v->config_ctx; if (config_ctx) eventfd_signal(config_ctx); VHOST_VDPA_SET_CONF...
CVE-2026-97993	New						In the Linux kernel, the following vulnerability has been resolved: vhost-vdpa: don't install the eventfd_ctx_fdget() error in config_ctx vhost_vdpa_set_config_cal() swaps the eventfd_ctx_fdget() return value into v->config_ctx before checking it, so on failure the field briefly holds an ERR_PTR: ctx = fd == VHOST_FILE_UNBIND ? NULL : eventfd_ctx_fdget(fd); swap(ctx, v...
CVE-2026-97994	New						In the Linux kernel, the following vulnerability has been resolved: vhost/vdpa: reject VRING_NUM larger than device max vhost_vring_set_num() accepts any non-zero power-of-two queue size that fits in 16 bits. vhost-vdpa then passes that value to set_vq_num() without comparing it with get_vq_num_max(). A process with access to /dev/vhost-vdpa-* can therefore configure a qu...
CVE-2026-97995	New						In the Linux kernel, the following vulnerability has been resolved: virtio_console: do not free control-out buffers on remove __send_control_msg() publishes &portdev->cpkt as the control-out virtqueue cookie. remove_vqs() walks every virtqueue and passes leftover cookies to free_buf(), which treats them as struct port_buffer and reads sgpages. If a control message is stil...
CVE-2026-97996	New						In the Linux kernel, the following vulnerability has been resolved: virtio: fix use-after-free in unregister_virtio_device() device_unregister() is device_del() plus put_device(). When the caller holds no extra reference, that drops the last one and runs the release callback, which for several transports frees the memory the embedded struct virtio_device sits in. unregiste...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97997	New						In the Linux kernel, the following vulnerability has been resolved: virtio_ring: fix stale descriptor flags after a failed packed add In a packed ring the AVAIL and USED bits sit in the descriptor itself, so writing them makes that descriptor available. Those bit combinations flip meaning on every round of the ring, tracked by a wrap counter, so invalidating or validating ...
CVE-2026-97998	New						In the Linux kernel, the following vulnerability has been resolved: netfilter: nfnetlink_log: cope with concurrent instance destruction Instances are refcounted. However, only memory release happens on the 1 -> 0 transition; the unlink from hashes can occur with any refcount. Uncooperative userspace can force a situation where a queue is pending for destruction from netli...
CVE-2026-98000	New						In the Linux kernel, the following vulnerability has been resolved: hwmon: Fix potential UAF in pec_store Sashiko reports: In pec_store(), a guard(mutex)(&hwdev->lock) is taken. If the chip write operation returns an error other than -EOPNOTSUPP, the code jumps to the put label, which calls put_device(hdev). If this drops the final reference, the device is freed. When the...
CVE-2026-98001	New						In the Linux kernel, the following vulnerability has been resolved: hwmon: (ltc4282) Make sure clk_init_data is fully initialized The clk_init_data structure contains several mutually-exclusive members for different methods to specify the possible parents of a clock, prompting drivers to initialize only the members they need. However, not initializing all members may caus...
CVE-2026-98003	New						In the Linux kernel, the following vulnerability has been resolved: iommu/amd: Do not reallocate GA log buffers on resume Commit c5e1a1eb9279 ("iommu/amd: Simplify and Consolidate Virtual APIC (AVIC) Enablement") moved the GA log allocation from iommu_init_pci() to enable_iommu_vapic(), which is called on every resume. iommu_init_ga_log() assigns iommu->ga_log and iommu-...
CVE-2026-98004	New						In the Linux kernel, the following vulnerability has been resolved: iommu/riscv: Serialize command queue publishing Serialize command queue publishing so software producer state advances only after a command is written and the hardware tail is updated. Wait for hardware consumption outside the queue lock when the command queue is full so other CPUs are not blocked behind a...
CVE-2026-98005	New						In the Linux kernel, the following vulnerability has been resolved: erofs: delimit inode_share cache key components Previously, inode_share keys were encoded as follows: fingerprint domain_id It would be better to have a separator between the fingerprint and domain ID so that the fingerprint won't be parsed as part of a domain ID. Change the key encoding as follows...
CVE-2026-98006	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: caiaq: Decoupling ep1_in_urb in caiaq dev The epq_in_urb object belonging to the caiaq device is coupled within the struct snd_usb_caiaqdev. After usb_submit_urb(epq_in_urb, GFP_KERNEL) executes successfully, epq_in_urb is successfully added to the urbp_list queue of the dummy HCD driver (userspace s...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98007	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject non-scalar bpf_loop iteration counts bpf_loop() declares its nr_loops argument as ARG_ANYTHING. Privileged programs may pass pointer values to such arguments, so check_func_arg() lets a pointer-valued R1 reach the helper-specific checks. Since commit bb124da69c47 ("bpf: keep track of max numbe...
CVE-2026-98008	New						In the Linux kernel, the following vulnerability has been resolved: net: macb: fix NULL pointer dereference on unbind with fixed-link When the device tree describes a fixed-link and has no "mdio" child node, macb_mii_init() returns early without allocating the MDIO bus, leaving bp->mii_bus as NULL. Two cleanup paths then dereference this NULL bus: 1. On driver unbind, ma...
CVE-2026-98009	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: ets: clamp quantum in parse and fallback paths ets_qdisc_change() falls back to psched_mtu() with no floor for bands without an explicit quantum. With a crafted size table qdisc_pkt_len reaches ~2 GiB, so a zero psched_mtu on a headerless device makes the deficit-refill loop spin under the qdisc...
CVE-2026-98010	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: drr: clamp quantum in change class drr_change_class() rejects explicit quantum==0 but falls back to psched_mtu() with no floor. With a crafted size table qdisc_pkt_len reaches ~2 GiB, so quantum=1 (or a zero psched_mtu on a headerless device) makes the deficit-refill loop spin under the qdisc lo...
CVE-2026-98011	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: hhf: clamp quantum in change and init paths hhf_change() accepts any quantum from userspace, including 1. With a crafted size table qdisc_pkt_len reaches ~2 GiB, so quantum=1 makes the deficit-refill loop spin ~2^31 times under the qdisc lock (a soft lockup / denial of service). Add max(256U,
CVE-2026-98012	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: sfq: clamp quantum in change path sfq_change() accepts any non-negative quantum (only rejects (int)ctl->quantum < 0). With a crafted size table qdisc_pkt_len reaches ~2 GiB, so quantum=1 makes the deficit-refill loop spin ~2^31 times under the qdisc lock (a soft lockup / denial of service). Add...
CVE-2026-98013	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: fq_pie: clamp quantum in change path fq_pie_change() accepts any quantum value from userspace, including 1. With a crafted size table qdisc_pkt_len reaches ~2 GiB, so quantum=1 makes the deficit-refill loop spin ~2^31 times under the qdisc lock (a soft lockup / denial of service). Add max(256U,...
CVE-2026-98014	New						In the Linux kernel, the following vulnerability has been resolved: net/mlx5: E-Switch, prevent mc_list repopulation during vport disable In mlx5_esw_vport_disable(), move esw_apply_vport_rx_mode() ahead of esw_vport_change_handle_locked() so vport->allmulti_rule is NULL before the change handler observes it. During FW-fatal recovery the disable runs while dev->state == I...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98015	New						In the Linux kernel, the following vulnerability has been resolved: net/mlx5: E-Switch: fix use-after-free in mlx5_eswitch_termtbl_put In mlx5_eswitch_termtbl_put(), the zero-ref cleanup check reads tt->ref_count after termtbl_mutex has been released. Two concurrent callers on the same mlx5_termtbl_handle race: one decrements ref_count to zero, removes the hash entry, and...
CVE-2026-98016	New						In the Linux kernel, the following vulnerability has been resolved: net/mlx5e: Fix use-after-free race in sample_restore_put() Concurrent teardown of TC sample rules sharing the same restore context may re-read restore->count after dropping restore_lock. At that point another thread may already have completed cleanup and freed the restore object. Use the result of the ref...
CVE-2026-98018	New						In the Linux kernel, the following vulnerability has been resolved: net: mctp: i3c: serialize probe with bus removal mctp_i3c_probe() drops busdevs_lock after finding the matching bus. A concurrent I3C_NOTIFY_BUS_REMOVE can then unregister and free the bus netdev before probe passes its private data to mctp_i3c_add_device(). The latter consequently adds a list node through...
CVE-2026-98019	New						In the Linux kernel, the following vulnerability has been resolved: bpf: mark a NULL call argument precise check_func_arg() allows bpf_register_is_null() for nullable arguments w/o marking the underlying scalar register precise. Hence a checkpoint created on such a path would prune against arbitrary scalar value. check_helper_call() enforces second parameter of the bpf_ge...
CVE-2026-98020	New						In the Linux kernel, the following vulnerability has been resolved: pds_core: fix cmd_regs access racing BAR unmap on reset pdsc_reset_prepare() and pdsc_reset_done()'s pdsc_mapBars() error path clear/iounmap cmd_regs without devcmd_lock, and pdsc_legacy_firmware_update()'s download loop derefs cmd_regs after dropping and retaking the lock without re-checking. An FLR conc...
CVE-2026-98021	New						In the Linux kernel, the following vulnerability has been resolved: net: reject oversized tx_queue_len at netlink parse time rtnl_create_link() assigns IFLA_TXQLEN directly to dev->tx_queue_len without going through netif_change_tx_queue_len(), so a device created with "ip link add ... txqueuelen 500000" bypasses the S16_MAX cap and still triggers the oversized ring alloca...
CVE-2026-98022	New						In the Linux kernel, the following vulnerability has been resolved: net: cap tx_queue_len at S16_MAX to prevent oversized ring allocations Several subsystems allocate ring buffers sized by dev->tx_queue_len with no upper bound. An unprivileged user (via unshare -Urn) can set a huge tx_queue_len and exhaust global memory with ring allocations: - pfifo_fast: pfifo_fast_init...
CVE-2026-98024	New						In the Linux kernel, the following vulnerability has been resolved: s390/ism: folio_put() after error dmb->cpu_addr was allocated via folio_alloc(). Use folio_put() instead of kfree() in the error exit of ism_alloc_dmb() to avoid slab allocator corruption. While at it, reset dmb->cpu_addr after folio_put to avoid unintentional UAF by future callers.
CVE-2026-98025	New						In the Linux kernel, the following vulnerability has been resolved: net: usb: cx82310_eth: drop URB after 0xffff reboot sentinel to prevent partial_data heap overflow The 0xffff length sentinel detects a router reboot and schedules re-enabling of ethernet mode, but then falls through to the rest of the loop body. The next check is } else if (len > CX82310_MTU) { which ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98026	New						In the Linux kernel, the following vulnerability has been resolved: net: bridge: mcast: properly convert mglist to rcu Sashiko reported a bug [1] that br_multicast_del_port_group unlists the port group not using proper rcu helper that preserves the next pointer and after that immediately frees the port group without waiting for rcu grace period. The only rcu walker of mgli...
CVE-2026-98028	New						In the Linux kernel, the following vulnerability has been resolved: eth: nfp: drop the replaced rule from the list when reprogramming fails nfp_net_fs_add() replaces an existing rule by deleting it from the hardware, decrementing nn->fs.count and programming the new one. If nfp_net_fs_add_hw() fails the old entry stays on nn->fs.list - only the success path reaches list_r...
CVE-2026-98031	New						In the Linux kernel, the following vulnerability has been resolved: nexthop: Initialize extack in remove_nh_grp_entry() remove_nh_grp_entry() prints the extack message when a listener fails to replace the reduced nexthop group. However, extack is not initialized and listeners are not required to set a message when returning an error. Neither netdevsim nor mlxsw do so when ...
CVE-2026-98032	New						In the Linux kernel, the following vulnerability has been resolved: tracing: Fix subbuff resize races with trace_pipe_raw readers Concurrent subbuffer resizes may crash trace_pipe_raw readers or leak uninitialized memory to userspace due to stale size values. Modify ring_buffer_alloc_read_page() to handle the resizing of an existing buffer_data_read_page if necessary and a...
CVE-2026-98033	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Preserve inner map identity in callback frames Callback frame constructors initialize map-typed argument registers with __mark_reg_known_zero() and then restore map_ptr. This clears map_uid, which is the only field distinguishing inner maps that share an inner_map_meta template. When a timer callback...
CVE-2026-98034	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark NULL kptr stores precise check_map_kptr_access() permits a scalar store into an untrusted kptr field only when the register is known to contain zero. Unlike other verifier checks whose outcome depends on a scalar value, it does not mark that register precise. A state checkpoint reached with an i...
CVE-2026-98035	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Cancel special fields when recycling rhtab elements rhtab_map_update_existing() and rhtab_delete_elem() call bpf_obj_free_fields() when replacing or deleting a value. These map operations can run from BPF programs in NMI context, where releasing a referenced kptr or another complex field is not genera...
CVE-2026-98036	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Preserve special fields in recycled rhtab elements rhtab_map_update_elem() initializes special fields after obtaining an element from bpf_mem_cache_alloc(). The allocator can return a fresh, zeroed unit, or recycle one from its RCU-pending lists before the registered destructor has run. A BPF program...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98037	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject untrusted allocated-object pointers When the final RCU read-side critical section ends, a local kptr is demoted to PTR_UNTRUSTED but retains MEM_ALLOC. The pointer may be NULL or may refer to an object whose lifetime is no longer protected. type_is_ptr_alloc_obj() nevertheless recognizes any P...
CVE-2026-98038	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Keep refcount_acquire nullable for borrowed RCU kptrs bpf_refcount_acquire() is fallible for a borrowed reference because the object may have reached a zero refcount. The verifier therefore keeps KF_RET_NULL on the return value unless the argument is an owning reference. An RCU-protected load of a lo...
CVE-2026-98039	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Require MEM_PERCPU for percpu kptr stores map_kptr_match_type() treats perm_flags as the set of register type flags that a kptr field permits. Adding MEM_PERCPU to that set for BPF_KPTR_PERCPU does not require the source register to carry it, however. The subset test consequently accepts both a plain ...
CVE-2026-98040	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark the zero register precise for a register-form NULL check check_cond_jump_op() accepts "if rA <op> rB" as a NULL check for a nullable pointer rA when rB is a scalar known to be zero, lifts PTR_MAYBE_NULL from rA in the corresponding branch and does not mark rB precise. Consider the following progra...
CVE-2026-98042	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Don't resurrect a scalar id dropped by collect_linked_regs() check_cond_jump_op() copies the compared registers into env->{false,true}_reg{1,2} before collect_linked_regs() runs and copies those snapshots back into both branch states afterwards. collect_linked_regs() records at most LINKED_REGS_MAX me...
CVE-2026-98043	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Don't infer non-NULL from a pointer with an unbounded offset reg_not_null() decides that a register holds a non-NULL value by looking at its type alone. For pointer types that allow arithmetic the type only guarantees a non-NULL base, in case of an unbound offset the runtime offset value might still a...
CVE-2026-98044	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject legacy packet loads from callbacks check_id_abs() models a failed BPF_LD_ABS or BPF_LD_IND in a subprogram as an implicit return with R0 set to zero. It calls prepare_func_exit() to explore this synthesized path. When the load is reached directly from a synchronous callback, prepare_func_exit(...
CVE-2026-98045	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark faultable stack helpers as sleepable The faultable variants of bpf_get_stack() and bpf_get_task_stack() pass may_fault=true into the common stack collection code. Resolving user-space build IDs may then call build_id_parse_file() and block on filesystem reads. Neither helper prototype sets might...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98046	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark bpf_btf_find_by_name_kind() as sleepable When bpf_btf_find_by_name_kind() finds a type in module BTF, it returns a new BTF object fd through __btf_new_fd(). This reaches anon_inode_getfd(), which can sleep while allocating or expanding the current task fd table. The helper prototype does not set...
CVE-2026-98047	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Check ancestor frames for rbtree callbacks bpf_rbtree_add() invokes its comparator while the caller holds the root lock. The native insertion code retains raw parent and link pointers across the callback, so the verifier prohibits unlocking, consuming tree nodes, or changing RCU state from that callba...
CVE-2026-98048	New						In the Linux kernel, the following vulnerability has been resolved: bpf: don't rewrite bpf_fastcall patterns entered by a jump mark_bpf_fastcall_pattern_for_call() must ensure that matched "spill; call; fill" instruction series is not interrupted by a jump. Otherwise the rewrite applied by bpf_remove_fastcall_spills_fills() is not sound. Record the instructions targeted by ju...
CVE-2026-98049	New						In the Linux kernel, the following vulnerability has been resolved: bpf: zero extend the result of an arena 32-bit cmpxchg bpf_convert_ctx_accesses() rewrites an atomic on an arena pointer from BPF_STX BPF_ATOMIC to BPF_STX BPF_PROBE_ATOMIC, and it runs before bpf_opt_subreg_zext_lo32_rnd_hi32(). That pass emits an explicit zero extension for a 32-bit cmpxchg even whe...
CVE-2026-98051	New						In the Linux kernel, the following vulnerability has been resolved: net: bcmasp: fix tx_spb_ring_full() checking same slot cnt times The loop initialised next_index from intf->tx_spb_index on every iteration, so incr_ring() always produced the same result and only one slot was ever tested. Move the initialisation before the loop so each iteration advances next_index and t...
CVE-2026-98053	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: Intel: avs: Refactor and fix init_config access Existing code accesses entries found in ->init_configs array through indexes that are part of ->config_ids array. Those two are limited by: ->num_init_configs and ->num_config_ids respectively. Using ID larger or equal to ->num_init_configs leads to ou...
CVE-2026-98054	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: Intel: avs: Fix unbalanced module reference count strace_open() invokes try_module_get() which on success takes the module reference. If any follow up operation causes strace_open() to fail, the refcount shall be put down.
CVE-2026-98055	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: Intel: avs: Clean up the bus when fetching ML caps fails snd_hdac_ext_bus_get_ml_capabilities() may fail and its return code shall be checked and accounted for. Address the issue by updating the error-path for avs_pci_probe(). At the same time, if the function in question succeeds but the next part ...
CVE-2026-98057	New						In the Linux kernel, the following vulnerability has been resolved: ring-buffer: Add checking nr_subbufs to persistent ring buffer validation Sashiko reported that the code was using meta->nr_subbufs without making sure that it matched the nr_pages + 1 on data that was assuming the two were the same. Add a check to the persistent ring buffer validation code to make sure t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98058	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark syscall helpers as sleepable bpf_sys_bpf() executes the bpf(2) syscall body, which can take mutexes, allocate with GFP_KERNEL, and wait for an RCU grace period. bpf_sys_close() reaches close_fd() and filp_close(), which can sleep as well. Both helpers are limited to BPF_PROG_TYPE_SYSCALL, whose ...
CVE-2026-98059	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark sched_process_wait argument as nullable do_wait() passes wo->wo_pid to the sched_process_wait tracepoint. kernel_wait4() leaves wo_pid NULL for wait4(-1), and kernel_waitid_prepare() does likewise for waitid(P_ALL). btf_ctx_access() currently types argument 0 as PTR_TO_BTF_ID PTR_TRUSTED. With...
CVE-2026-98060	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject resilient lock operations in rbtree callbacks __bpf_rbtree_add() keeps parent and link pointers live across calls to the program-supplied comparison callback. The verifier therefore requires the root's lock to remain held throughout the callback. The helper path enforces this rule for bpf_spin...
CVE-2026-98061	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject tail calls directly from callback frames A tail call from a non-zero frame is modeled as a return from that frame. The verifier makes R0 unknown and calls prepare_func_exit() for the taken branch. When the current frame is a synchronous callback, prepare_func_exit() enforces the callback retur...
CVE-2026-98062	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Mark signal tracepoint siginfo arguments as scalar The signal_generate and signal_deliver tracepoints declare their info argument as a struct kernel_siginfo pointer. btf_ctx_access() therefore treats it as a trusted pointer for tp_btf programs. Signal delivery also uses SEND_SIG_NOINFO and SEND_SIG_P...
CVE-2026-98063	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix NULL-ptr-deref in btf_var_show() btf_var_show() calls btf_type_id_resolve() unconditionally, which dereferences btf->resolved_ids. That is NULL for a base BTF - e.g. the vmlinux BTF that bpf_snprintf_btf() renders against - since base BTF is not resolved during parsing. btf_modifier_show() guards ...
CVE-2026-98064	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix NULL-ptr-deref when showing a void BTF type btf_modifier_show() resolves the modifier and then calls btf_type_ops(t)->show() unconditionally. For the void type (type_id 0, BTF_KIND_UNKN) kind_ops[] has no entry, so ->show is NULL. A "const void" (a modifier resolving to void) cannot be a map key ...
CVE-2026-98065	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Reject key-less BTF for hash maps map_check_btf() allows a key-less BTF (btf_key_type_id == 0) only for maps that have a ->map_check_btf callback, and leaves the actual decision to that callback. Hash maps used to have no ->map_check_btf, so a key-less BTF was rejected outright. That changed when hta...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98066	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: caiaq: Fix potential double-free at error path The fix for caiaq driver's resource management to handle the errors tries to release the resources in a common destructor call, but as a sashiko review for another patch suggested, some of the audio resources such as URBs have been already freed, and thi...
CVE-2026-98067	New						In the Linux kernel, the following vulnerability has been resolved: erofs: disable LZ4 rolling decompression for now LZ4 rolling decompression [1] was introduced to reduce the memory footprint of temporary pages: For many cases, it is needed for users to read small data within a compressed extent (pcluster), either due to random small read, or since uptodate folios (ty...
CVE-2026-98068	New						In the Linux kernel, the following vulnerability has been resolved: net/rds: don't let rds_conn_shutdown() consume a concurrent drop rds_conn_shutdown() finishes by moving the path from RDS_CONN_DISCONNECTING to RDS_CONN_DOWN, and also accepts RDS_CONN_ERROR as the starting state of that final transition, so that a FIN processed in softirq context during the teardown does ...
CVE-2026-98071	New						In the Linux kernel, the following vulnerability has been resolved: net/rds: clear cp_flags bits individually in rds_conn_path_reset() rds_conn_path_reset() wipes the whole flag word with a plain cp->cp_flags = 0 store. Every other accessor of that word uses atomic bitops, and some of them can run concurrently with the reset: RDS_LL_SEND_FULL is set from rds_send_xmit() a...
CVE-2026-98072	New						In the Linux kernel, the following vulnerability has been resolved: net/rds: use wq_has_sleeper() in release_in_xmit() release_in_xmit() clears RDS_IN_XMIT with clear_bit_unlock() and then checks waitqueue_active() to decide whether anyone needs waking. clear_bit_unlock() is only a release operation: it orders the critical section before the bit clear, but does not order t...
CVE-2026-98074	New						In the Linux kernel, the following vulnerability has been resolved: bonding: do not clear curr_active_slave prematurely when releasing all slaves When releasing all slaves during bond destruction (all == true), __bond_release_one() unconditionally clears bond->curr_active_slave to NULL in every iteration. If a backup slave is released before the active slave, bond_alb_dei...
CVE-2026-98075	New						In the Linux kernel, the following vulnerability has been resolved: bpf: reject BPF_PSEUDO_FUNC reference to the main program fixups.c:jit_subprogs() rewrites BPF_PSEUDO_FUNC loads to contain real function addresses. This function is invoked from bpf_jit_subprogs() only when env->subprog_cnt > 1. Meaning that for any program like below: int main(void *ctx) { void *p...
CVE-2026-98076	New						In the Linux kernel, the following vulnerability has been resolved: tracing/probes: Fix use-after-free on field name/type of events with multiple probes The fields of a probe-based dynamic event (kprobe, uprobe, eprobe and fprobe events) are created in traceprobe_define_arg_fields() by handing the probe_arg name/type strings to trace_define_field(), which only stores the p...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98077	New						In the Linux kernel, the following vulnerability has been resolved: netfilter: nf_conntrack_sip: fix OOB read in sip_skip_whitespace() sip_skip_whitespace() returns dptr unchanged when its own loop exhausts the buffer (dptr == limit), instead of NULL like its sibling sip_follow_continuation() returns on its own "no more data" path. ct_sip_get_header() only checks for NULL...
CVE-2026-98078	New						In the Linux kernel, the following vulnerability has been resolved: ipv6: fix reversed sequence option serialization hton_seq() expects the host-order source first and the unaligned network-order destination second. The version 1 sync sender passes these arguments in reverse for both sequence blocks. This leaves 24 bytes of the kmalloc-backed message unwritten. It may disc...
CVE-2026-98079	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: zstd: fix lost wakeup when waiting for a workspace A writer can sleep forever in zstd_get_workspace() even though a workspace is free. When zstd_alloc_workspace() fails, the task is queued on zwsm->wait and schedules unconditionally, never re-testing the pool. zstd_put_workspace() publishes the wor...
CVE-2026-98080	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: do not force reloc root creation during qgroup_account_snapshot() [BUG] When running btrfs/252 with quota enabled through MKFS_OPTIONS="-O quota", it has a high chance to trigger the following kernel warning and flips the fs RO: BTRFS info (device dm-2): relocating block group 30408704 flags meta...
CVE-2026-98081	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: zoned: finish active block group cleanup if call_zone_finish() fails do_zone_finish() clears BLOCK_GROUP_FLAG_ZONE_IS_ACTIVE before finishing the zones. If call_zone_finish() then fails it returned early, leaving the now inactive block group on fs_info->zoned_active_bgs, leaking its reference, the BT...
CVE-2026-98082	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: fix the possible bioc_list memory leak during error There are two possible ways to leak bioc memory on btrfs_ordered_extent::bioc_list: - An error occurred for btrfs_insert_one_raid_extent() Then the function btrfs_insert_raid_extent() immediately return without freeing any bioc in the bioc_lis...
CVE-2026-98084	New						In the Linux kernel, the following vulnerability has been resolved: bpf: backtracking shouldn't clear outer frame R1-R5 for callbacks When processing calls to bpf_loop() verifier marks R1 (and R4) as precise. R1 tracks loop iterations number and because of the 'callback_depth < R1' mechanics in check_helper_call() must be marked precise. However, precision propagation for ...
CVE-2026-98085	New						In the Linux kernel, the following vulnerability has been resolved: bpf: backtrack_insn(): Handle ld_{abs,ind} subprog exit edge Nicholas Carlini reported a bug in precision backtracking mechanism for BPF_LD BPF_{IND,ABS} instructions. These instructions are modelled as two branches: - fallthrough; - implicit exit from current subprogram. The implicit exit case was not ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98086	New						In the Linux kernel, the following vulnerability has been resolved: ALSA: ump: do not touch legacy_rmidi before it exists snd_ump_parse_endpoint() sets ump->parsed on every exit, including error, before the caller attaches the legacy rawmidi device. ump_handle_ep_name_msg() then treats parsed as "legacy_rmidi is live" and calls ump_legacy_set_rawmidi_name(), which snprintf...
CVE-2026-98087	New						In the Linux kernel, the following vulnerability has been resolved: sched/rt,dl: Skip migrate-disabled tasks when picking a push candidate A migrate_disable()'d RT task cannot be moved to another CPU, but the scheduler still keeps such a task on that CPU's pushable list (rq->rt.pushable_tasks) and still marks the runqueue RT-overloaded (rq->rt.overloaded = 1). So the RT ba...
CVE-2026-98088	New						In the Linux kernel, the following vulnerability has been resolved: scsi: mpt3sas: Avoid out-of-bounds cpumask_of_node() call in _base_assign_reply_queues() dev_to_node() can return NUMA_NO_NODE (-1) on systems without NUMA topology information for the PCI device, such as single-socket boards that don't expose device-to-node affinity. Passing -1 directly into cpumask_of_no...
CVE-2026-98089	New						In the Linux kernel, the following vulnerability has been resolved: bonding: alb: fix uninitialized transport header access in alb_determine_nd() alb_determine_nd() uses icmp6_hdr(skb) to inspect ICMPv6 headers. However, in xmit paths (e.g. packets sent via AF_PACKET / raw sockets or forwarded packets), skb->transport_header is not guaranteed to be initialized. While pskb_...
CVE-2026-98090	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: restore active device pointers after failed sprout btrfs_init_new_device() switches latest_dev and possibly s_bdev from the seed device to the new sprout device before creating the first writable chunks. If chunk creation or the subsequent sprout setup fails, the error path releases the new device ...
CVE-2026-98091	New						In the Linux kernel, the following vulnerability has been resolved: btrfs: detach failed sprout device from transaction update list When creating the first metadata chunk for a sprout filesystem, create_chunk() adds the new device to the transaction dev_update_list through device->post_commit_list. If the subsequent system chunk creation fails, btrfs_init_new_device() abo...
CVE-2026-98092	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: amd: yc: fix memory leak in acp6x_pdm_dma_close() acp6x_pdm_dma_close() does not free the runtime->private_data buffer allocated in acp6x_pdm_dma_open(). Add the missing kfree.
CVE-2026-98093	New						In the Linux kernel, the following vulnerability has been resolved: ASoC: fsl_micfil: balance mclk enable/disable hw_params() enables mclk unconditionally and hw_free() disables it unconditionally, but the PCM core does not guarantee 1:1 pairing: hw_free() can run without hw_params(), and hw_params() can be called multiple times from the SETUP state. This triggers an "alre...
CVE-2026-98094	New						In the Linux kernel, the following vulnerability has been resolved: staging: fbttf: make dirty_lock IRQ-safe fbttf_mkdirty() can be reached from the fbcon rendering path while processing printk() in hardirq context. Meanwhile, dirty_lock is also taken by fbttf_deferred_io() in workqueue context with local interrupts enabled. Lockdep reports a possible IRQ lock inversion i...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98095	New						In the Linux kernel, the following vulnerability has been resolved: af_packet: Don't cast tpacket_hdr.tp_len to int in tpacket_parse_header(). syzbot reported BUG() in sock_sendmsg_nosec(). [0] The problem is that tpacket_parse_header() casts user-provided tpacket_hdr.tp_len, which is u32, to int. If the length is larger than INT_MAX, the following condition in tpacket_p...
CVE-2026-98097	New						In the Linux kernel, the following vulnerability has been resolved: tipc: Dont send random pad bytes in RESET/ACTIVATE messages The interface name is passed in a fixed length (TIPC_MAX_IF_NAME) buffer. Replace the strcpy(data, l->if_name) with memcpy() so that the pad bytes are actually written (l->if_name[] is zero padded) rather than sending random bytes from the skb to ...
CVE-2026-98098	New						In the Linux kernel, the following vulnerability has been resolved: tipc: fix NULL deref in tipc_named_node_up() on empty publication list User-space applications can bind a large number of service addresses to one or more sockets. Each binding of a local-scope service address inserts one entry (publication) into the TIPC name table. If the number of these publications exc...
CVE-2026-98099	New						In the Linux kernel, the following vulnerability has been resolved: ipv6: mcast: use rcu_assign_pointer() for __rcu list updates Several places in net/ipv6/mcast.c update RCU-protected lists (np->ipv6_mc_list, idev->mc_list, idev->mc_tomb) using direct pointer assignments instead of rcu_assign_pointer(): 1. In __ipv6_dev_mc_dec(), unlinking a group from idev->mc_list did:...
CVE-2026-98101	New						In the Linux kernel, the following vulnerability has been resolved: ipv6: mcast: use copy-on-write RCU updates in ip6_mc_source() pmc->slst is read locklessly under rcu_read_lock() by inet6_mc_check() during packet reception in the UDP and RAW multicast receive paths. ip6_mc_source() mutated psl->sl_addr and psl->sl_count in-place when adding or removing a source filter...
CVE-2026-98102	New						In the Linux kernel, the following vulnerability has been resolved: ipv6: mcast: fix RCU list diversion in ip6_mc_del1_src() When removing a source filter whose count reaches zero, ip6_mc_del1_src() unlinks psf from pmc->mca_sources. If the filter was previously active, the code moved psf directly into pmc->mca_tomb by updating psf->sf_next. Because pmc->mca_sources is tr...
CVE-2026-98103	New						In the Linux kernel, the following vulnerability has been resolved: igmp: convert struct ip_sf_list to RCU Commit 23d2b94043ca ("igmp: Add ip_mc_list lock in ip_check_mc_rcu") added spin_lock_bh(&im->lock) to ip_check_mc_rcu() to prevent a use-after-free while iterating im->sources during concurrent deletions. However, ip_check_mc_rcu() is called from RCU read-side critic...
CVE-2026-98104	New						In the Linux kernel, the following vulnerability has been resolved: net/sched: cls_u32: fix duplicate handle when node ID pool is exhausted gen_new_kid() falls back to returning max (htid 0xFFFF) when both idr_alloc_u32() ranges are full, instead of reporting an error. u32_change() trusts that value and inserts a new knode with a handle that is already live in the hash ta...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98105	New						In the Linux kernel, the following vulnerability has been resolved: net: ethernet: oa_tc6: Improve the error recovery When oversubscribed traffic causes lot of buffer overflow errors, probably due to loss of data chunks, driver fails to find a data chunk with end_valid bit set, before it runs out of sk buffer space. As a result, assert is seen during skb_put. Now, check i...
CVE-2026-98106	New						In the Linux kernel, the following vulnerability has been resolved: drm/pagemap: Prevent double migration of device pages A device-private folio migrated to system memory by a CPU fault can remain reachable through the raw-PFN eviction path until migration finalization drops the source reference. If eviction selects the same device-private folio during this window, it can...
CVE-2026-98107	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: L2CAP: fix out-of-bounds write in l2cap_ecred_connect l2cap_chan_connect() tries to ensure there are no more than L2CAP_ECRED_CONN_SCID_MAX pending ECRED channels, so they fit in the same L2CAP_ECRED_CONN_REQ that l2cap_ecred_connect() constructs. However, the check only counts deferred channel...
CVE-2026-98109	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: hci_core: Fix race condition during device registration In hci_register_dev(), the power_on work item is queued to hdev->req_workqueue before initializing hdev->adv_monitors_idr and registering the MSFT extension via msft_register(). For devices marked with quirks such as HCI_QUIRK_RAW_DEVICE, t...
CVE-2026-98110	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: btintel: bound firmware ID by TLV length The firmware ID is treated as a NUL-terminated string even though the TLV length is its only boundary. If the value does not contain a NUL terminator, snprintf() can read beyond the received response. Limit the conversion to the advertised TLV value length.
CVE-2026-98111	New						In the Linux kernel, the following vulnerability has been resolved: Bluetooth: btintel: validate version TLV value lengths btintel_parse_version_tlv() verifies that a complete TLV is present in the response, but it does not ensure that the value is long enough for the specific TLV type. A short value can therefore cause an out-of-bounds read through get_unaligned_le16(), g...
CVE-2026-98113	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: rate limit unmapped SID errors A client can include many structurally valid but unmapped SIDs in a DACL. Logging every mapping failure lets one request generate hundreds of kernel error messages. Rate limit the message to prevent an authenticated client from flooding the kernel log.
CVE-2026-98114	New						In the Linux kernel, the following vulnerability has been resolved: ksmbd: propagate DACL parsing errors parse_dacl() silently accepts truncated ACEs and allocation failures, allowing set_info_sec() to continue with an incomplete ACL conversion. Return parsing and allocation errors to parse_sec_desc() so malformed security descriptors are rejected before inode attributes ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98117	New						In the Linux kernel, the following vulnerability has been resolved: cachefiles: Fix potential UAF/KASAN warning Currently, trace_cachefiles_coherency() is being passed a pointer to a __be64 lain over the coherency data in struct cachefiles_xattr so that it can display the first 8 bytes. However, the data is of variable length and could even be 0 bytes. This could lead to...
CVE-2026-98118	New						In the Linux kernel, the following vulnerability has been resolved: netfs: Fix readahead synchronisation issues by loading all folios upfront There are some synchronisation issues that derive from the app thread adding more folios to the rolling buffer whilst the collector thread is looking at them or trying to clear them, such as determining the setting of front_folio_ord...
CVE-2026-98119	New						In the Linux kernel, the following vulnerability has been resolved: netfs: break unbuffered write when netfs_alloc_subrequest() fails syzbot reported a null-ptr-deref below [1] following a fault injection in netfs_alloc_subrequest(). [0] When netfs_alloc_subrequest() fails, subreq is NULL. Later, netfs_prepare_write() tries to initialize members of subreq(e.g., source), t...
CVE-2026-98120	New						In the Linux kernel, the following vulnerability has been resolved: netfs: Fix subreq ref leak Fix a subrequest ref leak in netfs_unbuffered_write() in the event that subreq->io_iter ends up zero length during preparation.
CVE-2026-98121	New						In the Linux kernel, the following vulnerability has been resolved: watchdog: msc313e: Fix NULL pointer dereference in PM callbacks msc313e_wdt_probe() doesn't set the driver data for the platform device. As a result, dev_get_drvdata() in msc313e_wdt_suspend() and msc313e_wdt_resume() will return NULL, leading to a NULL pointer dereference afterward. Set the platform devi...
CVE-2026-98123	New						In the Linux kernel, the following vulnerability has been resolved: sctp: fix soft lockup from unpadded ASCONF-ACK parameter iteration sctp_verify_asconf() walks ASCONF-ACK parameters with sctp_walk_params(), which advances by SCTP_PAD4(length), while the consumer sctp_get_asconf_response() iterates the same parameters advancing by the raw length, without padding. A single...
CVE-2026-98124	New						In the Linux kernel, the following vulnerability has been resolved: smb/client: invalidate fscache for fallocate range operations smb3_zero_range(), smb3_punch_hole(), smb3_insert_range(), and smb3_collapse_range() modify file contents through server-side range operations. These operations discard the affected page cache, but leave the FS-Cache cookie valid, so a later rea...
CVE-2026-98125	New						In the Linux kernel, the following vulnerability has been resolved: smb/client: fix stale page cache in insert/collapse range smb3_insert_range() and smb3_collapse_range() use truncate_pagecache_range() to invalidate the affected page cache. However, if off or old_eof is not page-aligned, the boundary pages are only partially zeroed and remain uptodate. As a result, the cl...
CVE-2026-98126	New						In the Linux kernel, the following vulnerability has been resolved: smb/client: validate new EOF for zero range When FALLOC_FL_ZERO_RANGE is used without FALLOC_FL_KEEP_SIZE, smb3_zero_range() may extend EOF without checking RLIMIT_FSIZE, allowing the file to grow beyond the caller's file-size limit. Fix this by calling inode_newsize_ok() before sending the zero-range req...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98127	New						In the Linux kernel, the following vulnerability has been resolved: smb/client: validate new EOF for insert range smb3_insert_range() does not check if the new file size (i_size + len) is valid. This allows FALLOC_FL_INSERT_RANGE to bypass RLIMIT_FSIZE, exceed s_maxbytes, or produce a size outside the loff_t range. Use check_add_overflow() to calculate the new EOF. Valida...
CVE-2026-98128	New						In the Linux kernel, the following vulnerability has been resolved: scsi: mpi3mr: Fix target device refcount leak in mpi3mr_sas_port_add() mpi3mr_get_tgtdev_by_addr() increments the target device kref when it returns a device. If a subsequent error triggers a goto out_fail after the tgtdev reference is acquired, the reference is never released because the out_fail path doe...
CVE-2026-98129	New						In the Linux kernel, the following vulnerability has been resolved: scsi: mpi3mr: Fix NULL pointer dereference in mpi3mr_sas_port_add() sas_port_alloc_num() can return NULL on memory allocation failure. The return value is passed directly to sas_port_add() without a NULL check, which causes a NULL pointer dereference. Additionally, if sas_port_add() fails, the allocated p...
CVE-2026-98131	New						In the Linux kernel, the following vulnerability has been resolved: net: stmmac: fix dma mapping leak in stmmac_tso_xmit() In stmmac_tso_xmit(), if the DMA mapping of an skb fragment fails, the frame is dropped but the DMA mappings already created for the linear part and for the fragments mapped before the failure are never unmapped, leaking DMA mappings. Fix the leak by ...
CVE-2026-98132	New						In the Linux kernel, the following vulnerability has been resolved: bpf: don't downgrade half-dead scalar zero spills to STACK_ZERO states.c: __clean_func_state() can downgrade scalar zero spill to STACK_ZERO in the following case: *(u64 *)(r10 - 8) = 0; ... checkpoint ... r1 = *(u32 *)(r10 - 4); ... no reads from r10-8 ... Here 4 bytes at r10-8 are dead and verif...
CVE-2026-98133	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: leave HasEA flag untouched on setxattr failure In ntfs_set_ea(), the exit path unconditionally updates the HasEA flag based on ea_info_qsize. When an error occurs before ea_info_qsize is updated, NInoClearHasEA() hides existing on-disk EAs until the inode is evicted. Only update the flag on success.
CVE-2026-98134	New						In the Linux kernel, the following vulnerability has been resolved: bpf: check_cond_jump_op(): properly infer if register is null Nicholas Carlini reported a bug when verifier can incorrectly infer that a pointer is non-null. The bug occurs when two pointers are compared and one of them has a type w/o PTR_MAYBE_NULL flag, but which allows a value to be NULL at runtime. Here...
CVE-2026-98135	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: reject invalid sectors_per_cluster in the boot sector is_boot_sector_ntfs() checks the boot sector's sectors_per_cluster field with a range test that rejects 0x81..0xf3 but accepts 0 and other non-power-of-two counts. A zero value reaches parse_ntfs_boot_sector(): sectors_per_cluster_bits = ffs(sec...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98136	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: bound \$AttrDef table walk to the loaded table size ntfs_attr_find_in_attrdef() walks the in-memory \$AttrDef table, but the loop condition bounds only the start of each entry, not the whole entry: for (ad = vol->attrdef; (u8 *)ad - (u8 *)vol->attrdef < vol->attrdef_size && ad->type; ++ad) struct...
CVE-2026-98137	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: treat any nonzero dio zero-range return as an error ntfs_dio_zero_range() returns either 0 or a negative errno from blkdev_issue_zeroout(); it never returns a positive value. The zeroing failure check in ntfs_attr_fallocate() therefore never fired, so a failed zeroing operation was silently ignored:...
CVE-2026-98138	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: do not mark the volume clean in sync_fs when errors were recorded ntfs_put_super() and the remount-read-only path both clear the dirty bit only when NVolErrors(vol) is false. ntfs_sync_fs() clears it unconditionally, so any sync() on a volume that recorded an error marks that volume clean. A volume w...
CVE-2026-98139	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: only count successfully cleared runs when freeing clusters ntfs_cluster_free_from_rl_nolock() adds a run's length to nr_freed whenever the error bookkeeping condition is false, which includes cases where ntfs_bitmap_clear_run() actually failed - e.g. a second run failing with the same errno as an ear...
CVE-2026-98140	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: fix kmap_local leak in write_mft_record_nolock() error paths write_mft_record_nolock() maps the MFT record folio with kmap_local_folio(), but the pre_write_mst_fixup() and bio_add_folio() failure paths jump to the error label without unmapping it. kmap_local mappings are stack-ordered per task, so le...
CVE-2026-98141	New						In the Linux kernel, the following vulnerability has been resolved: ntfs: propagate reparse index insertion failure update_reparse_data() ignores the return value of set_reparse_index(). When index insertion fails, the code removes the just-written reparse data as cleanup but still returns 0, so symlink(2) (and WSL special file creation) reports success while no reparse da...
CVE-2026-98142	New						In the Linux kernel, the following vulnerability has been resolved: drm/cirrus-qemu: Validate BAR0 size during probe The `cirrus-qemu` driver relies on `CIRRUS_VRAM_SIZE` (4 MB) to validate framebuffer sizes. However, during PCI probe, the driver mapped BAR0 without verifying that its size matches `CIRRUS_VRAM_SIZE`. If a PCI device with a BAR0 smaller than 4 MB is bound ...
CVE-2026-98144	New						In the Linux kernel, the following vulnerability has been resolved: accel/amxdna: put the chained BO when its mapping fails amdxdna_cmd_set_error() looks up the first BO of a command chain, which takes a reference, and drops it at the end of the function. The mapping of that BO is established in between, and the failure path returns without the put, so the reference is le...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98145	New						In the Linux kernel, the following vulnerability has been resolved: accel/amdxdna: reject a command chain that carries no commands A chain whose command_count is zero passes the payload length check, because struct_size(payload, data, 0) is just the header. The fill loop then does not run, so offset stays zero and the request is submitted with a zero-length buffer. On fir...
CVE-2026-98146	New						In the Linux kernel, the following vulnerability has been resolved: accel/amdxdna: Remove __counted_by from struct amdxdna_cmd_chain struct amdxdna_cmd_chain contains a flexible array annotated with __counted_by(command_count). Since the structure is stored in shared AMDXDNA_BO_SHARE memory, userspace can modify command_count concurrently. If command_count is changed to ze...
CVE-2026-98147	New						In the Linux kernel, the following vulnerability has been resolved: printk: Don't WARN on kthread_run failure. Since __kthread_create_on_node() returns -EINTR upon SIGKILL, we should not use WARN_ON() in order to catch kthread_run() failure.
CVE-2026-98148	New						In the Linux kernel, the following vulnerability has been resolved: drm/gud: validate GUD_ROTATION_0 is present in supported rotations The rotation argument to drm_plane_create_rotation_property() is set to DRM_MODE_ROTATE_0, and the device reported rotation bitmask is used as the supported_rotations argument. The driver never validates that GUD_ROTATION_0 is present, so a...
CVE-2026-98149	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix percpu map update indexing with sparse CPU IDs Per-CPU array, hash, and cgroup storage map updates without BPF_F_CPU or BPF_F_ALL_CPUS use a value buffer whose per-CPU slots are packed in possible-CPU order. The buffer is sized as: round_up(value_size, 8) * num_possible_cpus() The update paths...
CVE-2026-98151	New						In the Linux kernel, the following vulnerability has been resolved: bpf: Fix REG INVARIANTS VIOLATION on speculative pointer arithmetic Take the following unprivileged program as an example: r0 = bpf_map_lookup_elem(...) /* PTR_TO_MAP_VALUE, offset 0 */ ... 14: r0 += r1 /* r1 is a bounded scalar */ 15: r9 = r0 Loading it triggers a verifier warning from reg_bounds_...
CVE-2026-98152	New						In the Linux kernel, the following vulnerability has been resolved: nvmet-rdma: fix queue leak when connect backlog is exceeded When pending disconnecting queues exceed the backlog limit, the connect path only drops the device reference and leaks the newly allocated queue and its IB resources.
CVE-2026-98153	New						In the Linux kernel, the following vulnerability has been resolved: nvme: fix racy access to FDP placement id array nvme_query_fdp_info() is called per-path and therefore prone to races. It populates head->nr_plids/head->plids for fdp registration. But nothing protects that pair from concurrent access - two paths scanning the same namespace can race to populate it. Avoid...
CVE-2026-98155	New						In the Linux kernel, the following vulnerability has been resolved: accel/qaic: Address potential out-of-bounds read in resp_worker() Although 'commit 2feec5ae5df7 ("accel/qaic: Handle DBC deactivation if the owner went away")' fixes the scenario it was intended for by walking the message and only decoding QAIC_TRANS_DEACTIVATE_FROM_DEV, if present, it skipped over the bou...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-98157	New						In the Linux kernel, the following vulnerability has been resolved: EDAC/device_sysfs: Use kstrtol() for poll_msec to prevent truncation The poll_msec sysfs store file uses simple_strtol() which accepts an unsigned long, but the target field (poll_msec) is unsigned int. On 64-bit systems, a value > UINT_MAX is silently truncated when stored. Fix the mismatch by using ...
CVE-2026-98158	New						In the Linux kernel, the following vulnerability has been resolved: ppp_async: drop the errored frame instead of resetting its headroom ppp_receive_nonmp_frame() prepends a two-byte direction tag before running the pass/active BPF filters: *(__be16 *)skb_push(skb, 2) = htons(PPP_FILTER_INBOUND_TAG); Nothing on the receive path guarantees those two bytes of headroom. The...
CVE-2026-98159	New						In the Linux kernel, the following vulnerability has been resolved: wifi: mt76: mt7921: validate CLC firmware records The CLC region is supplied by firmware, but the loader trusts the region count and each record length. A malformed image can make the region table pointer precede the firmware buffer, make the record loop fail to advance, or index phy->clc past its end. Val...
CVE-2026-98160	New						In the Linux kernel, the following vulnerability has been resolved: staging: rtl8723bs: fix mismatched free of HalData in rtw_sdio_if1_init() padapter->HalData is allocated via vzalloc(), but incorrectly freed using kfree() in the rtw_sdio_if1_init() error path. Using kfree() to release this vmalloc-backed buffer can lead to memory corruption. Use rtw_hal_data_deinit() to...
CVE-2026-98161	New						In the Linux kernel, the following vulnerability has been resolved: nvdim: pmem: keep PREFLUSH before data writes pmem_submit_bio() records a REQ_PREFLUSH error, but continues to copy the bio data and can later overwrite the error with a successful REQ_FUA flush. That lets data writes run after a failed preflush and can complete the bio successfully despite the failed ord...
CVE-2026-98162	New						In the Linux kernel, the following vulnerability has been resolved: smb/server: fix tree connection leak in smb2_tree_connect() See the procedure below: smb2_tree_connect ksmbd_tree_conn_connect xa_store(&sess->tree_conns, tree_conn->id, tree_conn) ksmbd_counter_inc(KSMBD_COUNTER_TREE_CONNS) ksmbd_share_tree_conn_inc(sc) ksmbd_iov_pin_rsp // fa...
GHSA-29h2-jr22-frmh	New		HIGH			npm:@openzeppelin/confidential-contracts	### Impact Two locations consume an encrypted handle returned by an untrusted external party and use it without verifying that the party is ACL-authorized on it. #### `VestingWalletConfidential` Malicious users can call `release` with a malicious token. This token could return an alternative handle on `confidentialBalanceOf`, which represents the balance of the vesting wa...
GHSA-62mm-xwmv-crhg	New		HIGH			PyPI:khoj	### Summary The `/home/{file_path:path}` endpoint in `web_client.py` serves static files by directly concatenating the user-supplied `file_path` with the `home_directory` constant. There is no path traversal filtering, no path normalization check, and no authentication required. An attacker can use `../` sequences to read arbitrary files from the server filesystem. ### Deta...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-7qx8-98q7-66p4	New					npm:@nubjs/types	--- _-= Per source details. Do not edit below this line.=_ ## Source: ghsha-malware (1b292cfe4598353bc8491677099fd2c056f4136eb686345bbdbe68fa887e368c) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
MAL-2026-17181	New					PyPI:reqparser	--- _-= Per source details. Do not edit below this line.=_ ## Source: kam193 (982923c14e644e82a839621d37715fd123568fc378aed45b6afa6247bc0b5054) During the module import, the package starts an infostealer. It exfiltrates data from crypto currency wallets and web browsers, ensures persistence and installs further malware. --- Category: MALICIOUS - The campaign has clearl...
MAL-2026-17182	New					npm:app-sca-info-banking	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (9733b1d7500efca385ba6dc866f4ef1b04e0d1cd4ead564b9445551a2d72a51b) package.json declares scripts.postinstall: `node poc.js`, causing poc.js to execute automatically on npm install. poc.js issues DNS (dns.resolve4) and HTTP (http.get) callbacks to unique subdomains under ki6rmdjinq5q8y7v8...
MAL-2026-17183	New					PyPI:tego-managed-agents-test	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (72c8a01de8d706d83a4b80b845099c11602ba778a392337cad2d9a8a40090b5d) The package's custom install command serializes the entire process environment (dict(os.environ)) to JSON and POSTs it to the hardcoded endpoint https://gateway.tego.security during `pip install`. The exfiltration runs a...
MAL-2026-17184	New					npm:@airbnb-extended/typescript-config	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (8424e4bf8731b950511535a2cb9b41b0bedba02092a73ea304b6730f04aa95fe) package.json for @airbnb-extended/typescript-config@99.9.1 declares a dependency `ltdisafe` sourced from a bare HTTPS tarball URL (https://ltdi.storage.googleapis.com/dependconf/ltdisafe-3.7.8.tgz) instead of a registr...
MAL-2026-17185	New					npm:shoplist-app	--- _-= Per source details. Do not edit below this line.=_ ## Source: amazon-inspector (fdceadb01f08162934382b121e813236b86adc0d4d74b7b2f062c78e529c34f6) shoplist-app@99.99.99 is a dependency-confusion / typosquat beacon. preinstall.js is wired into every lifecycle hook (preinstall, install, postinstall, prepare, prepublish) and issues an HTTPS GET to the hardcoded endpoi...
MAL-2026-17187	New					npm:@digift/cli	--- _-= Per source details. Do not edit below this line.=_ ## Source: ossf-package-analysis (5508ba462afd4a4d6f311cca1a00d728ea27b8fe03a2fba93878a9fabbb7f309) The OpenSSF Package Analysis project identified '@digift/cli' @ 99.99.100 (npm) as malicious. It is considered malicious because: - The package communicates with a domain associated with malicious activity.
MAL-2026-17188	New					PyPI:sherpy	--- _-= Per source details. Do not edit below this line.=_ ## Source: kam193 (2e5440f1e24545fd14e73c7fc459a9abf893f4674683899ed29ff7c4189416b6) When used, the package exfiltrates Chrome extension files (likely targeting cryptocurrency wallets) and sensitive Telegram files. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88351	Updated - CVSS added	9.8	CRIT		0.001		An integer overflow vulnerability exists in the MPack Node API in MPack 1.1.1 on 32-bit platforms. When parsing a specially crafted MessagePack array32 or map32 object with an excessively large element count, the page allocation size calculation in mpack_tree_parse_children() can overflow size_t and produce an undersized allocation. Subsequent parsing writes mpack_node_data_...
CVE-2026-97230	Updated - CVSS added	9.8	CRIT		0.001		IO::Socket::SSL::SelfCertificate versions 1.00 for Perl contains malware which executes Python code from an obfuscated URL. The generate_certificate runs a Python script saved as a certificate file. The python script attempts to retrieve code from a hardcoded http URL that is obfuscated with base64 encoding and run the response body directly. The impact is that arbitrary ...
CVE-2026-51994	Updated - CVSS added	9.1	CRIT		0.002		mcp-remote versions 0.1.32 through 0.1.38 are vulnerable to Server-Side Request Forgery (SSRF) via the resource_metadata URL extracted from a remote MCP server's WWW-Authenticate header
CVE-2026-92288	Updated - CVSS added	9.1	CRIT		0.002		Lemonldap::NG::Portal versions from 2.20.0 before 2.21.6, from 2.22.0 before 2.23.4 for Perl allow unauthenticated OAuth2 token introspection because checkEndPointAuthenticationCredentials does not verify the client secret of a public Relying Party. checkEndPointAuthenticationCredentials() skips the secret comparison for a Relying Party marked public and still returns the a...
CVE-2026-51997	Updated - CVSS added	8.8	HIGH		0.003		An issue in geelen mcp-remote 0.1.16 through 0.1.38 allows a remote attacker to execute arbitrary code via the open() functions
CVE-2026-85491	Updated - CVSS added	8.8	HIGH		0.004		Catalyst::Seal versions before 0.03 for Perl allow one request to disable a path or route a later one past an authorization check via a dispatch memo keyed on the request path alone. Catalyst::Seal replaces the dispatcher's prepare_action with a version that memoises how a path resolved: which dispatch type matched, at which level, and what was left over as arguments. The k...
CVE-2026-88361	Updated - CVSS added	7.5	HIGH		0.002		SumatraPDF 3.6.1 contains an integer overflow vulnerability in EngineMupdf::BuildPageLabelRec() when parsing PDF PageLabels /Nums entries.
CVE-2026-88362	Updated - CVSS added	7.5	HIGH		0.002		MuJS e892c9fdb contains an incorrect numeric conversion vulnerability in jsR_isindex() in jsrun.c. A specially crafted JavaScript input containing an excessively large numeric array index can cause an out-of-range floating-point value to be converted to an integer without proper range validation. This results in undefined behavior and can cause process termination, leading t...
CVE-2026-88373	Updated - CVSS added	7.5	HIGH		0.002		libde265 commit 4d45a6b contains a NULL pointer dereference vulnerability in the NAL parsing path. When de265_push_NAL() is called with a zero-length NAL unit, the resulting NAL_unit may retain a NULL backing buffer, which is subsequently passed as the destination argument to memcpy() in NAL_unit::set_data(). Although the copy length is zero, this violates the nonnull requir...
CVE-2026-88388	Updated - CVSS added	7.5	HIGH		0.002		Espruino 2v29 (commit bffc6d0) contains a stack-based buffer overflow vulnerability in the JavaScript error stack-trace handling path on 64-bit builds. A remote attacker can supply JavaScript input that triggers an exception and reaches jsIPrintTokenLineMarker(), which passes the address of a 4-byte int column variable to jsvGetLineAndCol() as a size_t pointer. jsvGetLineAnd...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-88369	Updated - CVSS added	7.3	HIGH		0.002		zserge jsmn commit 25647e6 is vulnerable to Buffer Overflow in example/jsondump.c dump().
CVE-2026-53493	Updated - Fix/version updated	6.9	MEDI		0.004	go:github.com/containerd/containerd, go:github.com/containerd/containerd/v2	### Impact A vulnerability exists in containerd's image pull handlers where a crafted OCI image index containing deeply nested or heavily fanned-out descriptor graphs can cause unbounded CPU and memory consumption. During the `PullImage` operation, the recursive traversal and processing of child descriptors lack sufficient depth and breadth limits, and fail to adequately de...
CVE-2026-88359	Updated - CVSS added	6.5	MEDI		0.002		libfyaml 0.9.6 contains a stack exhaustion vulnerability in fy_atom_iter_format(). When processing a specially crafted YAML document containing a very large literal or folded block scalar, the function repeatedly grows an internal buffer using alloca() inside a loop. The allocated stack memory is not released until the function returns, causing cumulative stack growth that c...
CVE-2026-88367	Updated - CVSS added	6.5	MEDI		0.001		NanoSVG 239e102ec contains an incorrect numeric conversion vulnerability in nsvg__curveDivs() during SVG stroke rasterization. A specially crafted SVG document containing an extremely large stroke-width can cause floating-point rounding to produce a zero subdivision angle. The subsequent arc division yields infinity, which is converted to int without range validation, result...
CVE-2026-95811	Updated - CVSS added	6.5	MEDI		0.003		Lemonldap::NG::Handler versions from 2.0.0 before 2.16.10, from 2.17.0 before 2.21.6, from 2.22.0 before 2.23.4 for Perl allow an equivalent spelling of a path to bypass the locationRules that restrict it. The handler matches each vhost's locationRules regular expressions against REQUEST_URI, the raw request line, while the web server routes on the path it has already perce...
CVE-2026-97636	Updated - CVSS added	6.5	MEDI		0.002		Apache Airflow HashiCorp provider: the HashiCorp Vault secrets backend's team-scope guard can be bypassed with a user-controlled key. In a multi-team deployment, a Dag author scoped to one team can supply a Variable key containing a path separator that causes the backend to resolve a secret belonging to a different team, because after the team-scoped lookup misses the backen...
CVE-2026-93353	Updated - CVSS changed (5.3 → 6.0)	6.0	MEDI		0.003		copyparty contains a volume restriction bypass vulnerability in its SFTP front end that allows authenticated SFTP users to create, remove, and truncate arbitrary paths outside permitted volume boundaries by exploiting three handlers that bypass the xvnl volflag enforcement. The _mkdir, _rmdir, and _chattr handlers construct destination paths using vfs.get(), vn.canonical(), ...
CVE-2026-88386	Updated - CVSS added	5.5	MEDI		0.001		libsndfile 1.2.2 contains a misaligned memory access issue in psf_binheader_readf() while parsing WAV fmt chunks. A specially crafted WAV file can cause the function to cast an unaligned destination address to unsigned int * and perform a 4-byte store. This results in undefined behavior leading to denial of service.
CVE-2026-97326	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A weakness has been identified in songxinjianqwe Chat up to ac63d25297079eed5e4ba7e88d3b7a032637150d. Affected by this issue is some unknown functionality of the file chat-server/src/main/java/cn/sinjinsong/chat/server/ChatServer.java of the component chat-server. This manipulation causes server-side request forgery. The attack may be initiated remotely. The exploit has been...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97646	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI		0.003		A weakness has been identified in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. This affects an unknown function of the file admin/fun/getStudent.php. This manipulation of the argument sid causes authorization bypass. The attack is possible to be carried out remotely. The exploit has been made available to the public and could be used f...
CVE-2026-88370	Updated - CVSS added	5.3	MEDI		0.001		libconfini 1.16.4 contains a heap out-of-bounds write condition involving the bundled load_ini_buffer.h utility and strip_ini_cache(). The bundled utility allocates exactly ini_length bytes, while strip_ini_cache() unconditionally writes a NUL terminator at ini_source[ini_length], requiring an additional writable byte. Applications using the bundled allocation pattern can tr...
CVE-2026-97225	Updated - CVSS changed (6.3 → 5.3)	5.3	MEDI		0.002		A flaw has been found in DbGate up to 7.2.5-beta.5. This affects an unknown function of the file packages/api/src/controllers/runners.js of the component JSON Runner. Executing a manipulation of the argument comment.text/script.schedule can lead to code injection. The attack may be performed from remote. Upgrading to version 7.2.5-beta.6 mitigates this issue. This patch is c...
CVE-2026-48543	Updated - CVSS changed (5.4 → 5.1)	5.1	MEDI		0.001		Krayin CRM through 2.2.6 contains a stored client-side template injection vulnerability that allows authenticated attackers to execute arbitrary JavaScript in other users' browsers by injecting Vue.js template expressions into the web form description field. Attackers can craft a web form description containing double-brace template syntax that reaches the Vue template compi...
CVE-2026-97320	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A flaw has been found in YunaiV/zhijiantianya ruoyi-vue-pro up to 2026.08. The affected element is the function AiKnowledgeDocumentServiceImpl.readUrl of the file AiKnowledgeDocumentServiceImpl.java of the component AI Knowledge Module. This manipulation of the argument url causes server-side request forgery. The attack is possible to be carried out remotely. The exploit has...
CVE-2026-97325	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.003		A security flaw has been discovered in YunaiV/zhijiantianya ruoyi-vue-pro up to 2026.08. Affected by this vulnerability is the function validOAuthClientFromCache of the file yudao-module-system/src/main/java/cn/iocoder/yudao/module/system/service/oauth2/OAuth2ClientServiceImpl.java of the component OAuth2 Client. The manipulation of the argument redirect_uri results in open ...
CVE-2026-97366	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.012		A security flaw has been discovered in jhen0409 react-native-debugger up to 0.14.0. The impacted element is the function openDevTools of the file electron/window.js of the component Open in Editor Handler. The manipulation of the argument host results in os command injection. It is possible to launch the attack remotely. The exploit has been released to the public and may be...
CVE-2026-97368	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW		0.002		A weakness has been identified in chillzhuang SpringBlade up to 5.0.2. This affects the function UserServiceImpl.userInfo of the file blade-service/blade-system/src/main/java/org/springblade/system/service/impl/UserServiceImpl.java of the component user-auth-info Endpoint. This manipulation of the argument userId causes authorization bypass. The attack can be initiated remot...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97648	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.002		A vulnerability was detected in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected is an unknown function. Performing a manipulation results in cross-site request forgery. It is possible to initiate the attack remotely. The exploit is now public and may be used. The project was informed of the problem early through an issue report b...
CVE-2026-97650	Updated - CVSS changed (4.3 → 2.1)	2.1	LOW		0.003		A vulnerability has been found in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this issue is the function echo of the file admin/fun/addLog.php. The manipulation of the argument reason/detail leads to cross site scripting. The attack can be initiated remotely. The exploit has been disclosed to the public and may be used. Th...
CVE-2026-97649	Updated - CVSS changed (4.7 → 2.0)	2.0	LOW		0.002		A flaw has been found in ningzichun student-management-system up to 98760f5711cf6dc8b4adca53a9e207ca49b02ebf. Affected by this vulnerability is an unknown functionality of the file example_lite.sql. Executing a manipulation can lead to use of default credentials. It is possible to launch the attack remotely. The exploit has been published and may be used. The project was inf...
CVE-2026-57440	Updated - Fix/version updated				0.003	composer:starcitizenwiki/embedvideo	### Summary With \$wgEmbedVideoRequireConsent disabled (not the default), the urls for videos are passed into an iframe src attribute without sanitization. When given a malformed url or id, the src attribute can be escaped via double quotes, allowing for html/javascript injection. ### Details The iframe assembled [here](https://github.com/StarCitizenWiki/mediawiki-extensions...
CVE-2026-61823	Updated - Fix/version updated				0.002	composer:code16/sharp	### Impact A Stored Cross-Site Scripting (XSS) vulnerability exists in the rich text editor due to improper sanitization of the srcdoc attribute on <iframe> elements. While the underlying Symfony HtmlSanitizer correctly HTML-encodes special characters inside the attribute value (e.g., converting <script> to <script>), the HTML specification mandates that browsers auto...
CVE-2026-61825	Updated - Fix/version updated				0.002	composer:code16/sharp	### Impact The vulnerability allows an attacker to bypass the HTML sanitizer by using the `data-html-content` attribute in the content of a `SharpEditorFormField`. ### Patches The field must now explicitly configure `SharpFormEditorField::RAW_HTML` in the toolbar to keep this behavior. **When using the `RAW_HTML` button, the application using `code16/sharp` must sanitize ...

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87902	Added to KEV	8.1	HIGH	Yes	0.029	wordpress:core	WordPress Core contains a remote file inclusion vulnerability which could allow an unauthenticated attacker to make page-template resolution include a chosen readable local `.php` file outside the active theme directories, leading to remote code execution.
CVE-2026-65660	Added to KEV			Yes	0.012	microsoft:sharepoint	Microsoft SharePoint contains a code injection vulnerability which could allow an authorized attacker to execute code over a network.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67279	Added to KEV			Yes	0.007	mikrotik:routeros	Mikrotik RouterOS contains an improper enforcement of behavioral workflow vulnerability that could allow an unauthenticated client to open a session channel and send an exec request. This vulnerability can be chained to achieve unauthenticated exploitation of CVE-2026-86060.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100382	New	10.0	CRIT				Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability in Wikimedia Foundation Mediawiki - ExternalData Extension allows OS Command Injection. This issue affects Mediawiki - ExternalData Extension: from * before 3.7.
CVE-2026-100075	New	9.8	CRIT				In the Linux kernel, the following vulnerability has been resolved: RDMA/srpt: Fix srpt_alloc_rw_ctxs() unwind counters When srpt_alloc_rw_ctxs() fails partway through a multi-buffer indirect descriptor, the unwind path destroys RDMA contexts but leaves stale n_rw_ctx and n_rdma values (and a dangling rw_ctxs pointer). Later sq_wr_avail accounting in srpt_queue_response() ...
CVE-2026-14281	New	9.8	CRIT		0.005		The Automation Web Platform – Notifications and OTP for WooCommerce, Advanced Country Code plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 4.8.6. This is due to missing permission enforcement on the publicly accessible REST route `POST /wp-json/wawp/v1/signup/<op>` and the absence of a key allowlist in the `finish_registration...
CVE-2026-92161	New	9.8	CRIT			composer:fof/oauth	FriendsOfFlarum OAuth allows users to log in to Flarum with GitHub, Twitter, Facebook, and other providers. Prior to 1.7.4 and 2.0.0-beta.4, the Discord OAuth provider does not check the verified field returned for an OAuth email before passing the address to Flarum core as trusted through provideTrustedEmail(). When Discord sign-in is enabled, an unauthenticated attacker wh...
CVE-2026-92609	New	9.8	CRIT		0.002		Session fixation in HTTP management authentication allows remote attackers to gain unauthorized access to an authenticated management session via reuse of a session identifier retained across successful authentication. This issue affects Apache Qpid Broker-J: through 10.1.0. Users are recommended to upgrade to version 10.1.1, which fixes the issue.
CVE-2026-93643	New	9.8	CRIT				When OnlyOffice/Document Editing is available, an unauthenticated remote attacker with access to an existing supported public Briefcase document can abuse unsigned save fields to perform path-traversal writes and execute commands as zimbra.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-48482	New	9.4	CRIT				GLPI is a free asset and IT management software package. From 11.0.0 until 11.0.8, a form administrator can use Form import with a crafted illustration or scene identifier that traverses outside the intended custom-asset directory. The imported file can be written to an executable server location, allowing a malicious script to be invoked remotely. This issue is fixed in ver...
CVE-2026-93641	New	9.3	CRIT				An unauthenticated sender can forge a share notification that triggers stored XSS when a signed-in Zimbra Classic recipient clicks Accept Share, allowing the attacker to access mailbox data and act as the victim.
CVE-2026-93642	New	9.3	CRIT				An unauthenticated sender can forge a share notification that triggers stored XSS when a signed-in Zimbra Modern recipient clicks Accept Share, allowing the attacker to access mailbox data and act as the victim.
CVE-2026-93647	New	9.3	CRIT				An unauthenticated calendar sender can place active markup in a COUNTER message's RFC From address. Selecting the message in Zimbra Classic triggers stored XSS, allowing the attacker to access mailbox data and act as the victim.
CVE-2026-95832	New	9.3	CRIT				Improper Neutralization of Special Elements in Output Used by a Downstream Component in the colour control escape code handler in kitty from 0.47.3 before 0.49.0 allows a program writing to the terminal to execute an arbitrary command in the user's shell, because color_control() in kitty/window.py answers a query for an unrecognised field name by placing that field name into...
CVE-2026-39353	New	9.1	CRIT				InvoicePlane is a self-hosted open source application for managing invoices, clients, and payments. Prior to 1.7.2-rc-1, InvoicePlane builds its permitted template list by scanning a PHP template directory that can be written through an administrator-controlled file-write capability. A malicious PHP file placed in the directory is automatically trusted by Mdl_templates and c...
CVE-2026-42322	New	9.1	CRIT				Piwigo is a full featured open source photo gallery application for the web. Prior to 16.4.0, admin/themes_standard_pages.php validates uploaded logo content by MIME type but reuses the attacker-controlled extension from std_pgs_logo when constructing the stored filename. An authenticated administrator can upload image content with a server-executable final extension, causin...
CVE-2026-62262	New	9.1	CRIT				Piwigo is a full featured open source photo gallery application for the web. In 17.0.0beta1 and earlier, when rating is enabled, an unauthenticated guest can call pwg.images.filteredSearch.create with a crafted ratings[] value and then open the returned search URL. include/ws_functions/pwg.images.php stores the unvalidated value in the search rules, and include/functions_sea...
CVE-2026-84458	New	9.1	CRIT				Zammad is a web based open source helpdesk/customer support system. Prior to 7.1.2, when the "Automatic account link on initial logon" setting is enabled, Zammad binds an incoming third-party (SSO) identity to an existing local account by matching the email address the identity provider reports, without verifying that the provider actually confirmed ownership of that email. ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89055	New	9.1	CRIT		0.004		The Customer Reviews for WooCommerce plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 5.120.0. This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for unauthenticated attackers to permanently delete arbitrary attachments from the Media Library — including admin...
CVE-2026-93399	New	9.1	CRIT		0.004		The Bookly plugin for WordPress is vulnerable to Insecure Direct Object Reference in versions up to, and including, 28.2 via the 'bookly_get_form_id', 'bookly_render_complete', 'bookly_add_to_calendar' and 'bookly_rollback_order' AJAX actions. This is due to the 'bookly_get_form_id' handler blindly storing the attacker-controlled 'order_id' from the submitted form_data into ...
CVE-2026-97063	New	9.1	CRIT				X-SpringBoot through 6.0 returns login verification codes in HTTP responses from unauthenticated endpoints GET /sys/mobile/code and GET /sys/email/code without sending them to account owners. Attackers can request codes using known mobile numbers or email addresses, read them from responses, and authenticate as victims via POST /sys/emailOrMobileLogin/login to hijack accounts.
CVE-2026-97064	New	9.1	CRIT				X-SpringBoot through 6.0 ships with a hardcoded static master login verification code 172839 enabled by default in the database seed. Unauthenticated attackers can authenticate as any user by submitting the public master code to the emailOrMobileLogin endpoint with a known email or mobile number.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.